

DOCUMENTO DE DECISÃO PRÉ-CÓDIGO

RELATÓRIO MESTRE MIDAS

PRD, UML, arquitetura, direção de arte, segurança, compliance, operações, roadmap e inventário de referências para um marketplace de itens digitais — condicionado à autorização do publicador.

Requisitos rastreáveis	180
------------------------	-----

Diagramas	23
-----------	----

Capítulos	7
-----------	---

Linhas-fonte	3.770
--------------	-------

PNGs manifestados	1.782
-------------------	-------

NO-GO atual. As regras oficiais do Standoff 2 proíbem comércio externo por dinheiro real sem permissão expressa. Não integrar APIs, publicar o marketplace ou reutilizar assets até obter autorização escrita da Axlebolt.

MIDAS — RELATÓRIO MESTRE DE PRODUTO

01

Documento de decisão pré-código

Versão: 1.0 · Data-base: 21 de agosto de 2026 · Idioma: pt-BR

Promessa do produto: veja o preço de referência, negocie com proteção e receba com rastreio.

STATUS DE GO-LIVE: NO-GO. As **Regras oficiais do Standoff 2**, atualizadas em 03/07/2026, proíbem comércio externo e intermediação por dinheiro real salvo permissão expressa. A **EULA oficial** proíbe comprar/vender contas e restringe uso comercial de conteúdo e bens virtuais. O projeto só pode avançar como marketplace Standoff 2 após autorização escrita da Axlebolt cobrindo comércio, transferência, API, dados e assets.

1. Decisão executiva

Midas deve ser construído como um **marketplace transacional de confiança**, não como uma simples loja de cards. O núcleo do produto é a consistência entre cinco coisas: anúncio aprovado, pagamento confirmado, entrega rastreável, disputa resolvível e saldo liberado de forma auditável.

Este relatório especifica o produto-alvo, mas a implementação comercial está condicionada ao gate de autorização do publicador. Enquanto o gate estiver bloqueado, apenas documentação, protótipo clean-room e motor genérico com dados sintéticos são aceitáveis.

O produto terá duas vitrines apoiadas pelo mesmo motor:

- 1. Market P2P** — anúncios de vendedores, todos submetidos à revisão manual antes da publicação.
- 2. Compre do Midas** — estoque próprio do operador, com preço definido pelo Midas e identificação visual inequívoca.

O desenho recomendado é um **monólito modular orientado a domínios**, acompanhado por gateway de chat e workers assíncronos. Essa forma entrega velocidade de execução sem abrir mão de limites internos claros. Microserviços não são requisito de MVP; integridade financeira e observabilidade são.

2. O que foi analisado

Nesha Store

Auditoria clean-room de navegação, densidade, hierarquia, catálogo e persuasão ética em neshastore.com. Foram inspecionadas as superfícies públicas de início, produto, carrinho, login, Prime, venda, FAQ, termos, privacidade e antiscam, além do sitemap público.

O que vale transportar como princípio:

- catálogo escuro e denso;
- categorias acessíveis logo no início;
- preço, desconto e disponibilidade visíveis no card;
- compra e entrega explicadas no contexto da ação;
- confiança tratada como parte da interface;
- produto detalhado com forte hierarquia entre imagem, preço e CTA.

O que **não** será transportado:

- logotipo, textos, banners, ilustrações, CSS ou tokens;
- escassez, contadores ou prova social sem evidência;
- estrutura B2C/C2B tratada como se fosse P2P;
- dependências e integrações particulares da Nesha.

Standoff 2 Shop de referência

Foi auditada a página standoff-2.com/shop, que oferece seleção de item, atributos, preço atual, mínimo, máximo, média, compra/venda, períodos e gráfico histórico.

Constatação crítica: o próprio rodapé do site informa que ele é **não oficial**. Seus endpoints observados são evidência de funcionamento daquela página, não uma API oficial, licenciada ou adequada para produção. O Midas só poderá chamar um feed de mercado se houver documentação pública, permissão contratual ou licença expressa.

A pesquisa em fontes oficiais não localizou portal público, OpenAPI, SLA, chave de parceiro ou licença para preço/histórico. A [central oficial de Marketplace](#) descreve o mercado do jogo, não autoriza integração externa. A [FAQ oficial de economia](#) também informa que não há intenção de oferecer troca direta entre amigos devido a golpes e impacto econômico; o fluxo de entrega pedido não pode ser presumido tecnicamente viável.

Inventário de catálogo observado

Na data-base desta auditoria, a interface expunha:

- 2.256 nomes selecionáveis;
- 1.782 registros de metadados;
- 1.782 referências com extensão `.png` ;
- 1.779 URLs de imagem únicas;
- 1.777 nomes únicos;
- 49 coleções preenchidas.

Essas URLs entram no **manifesto de proveniência**, não no produto. O download e a republicação dos binários permanecem bloqueados por licença.

3. Resultado proposto

Superfícies de cliente

- Início e descoberta personalizada;
- Market P2P;
- Compre do Midas;
- item-base e anúncio específico;
- busca, filtros, favoritos e perfil público do vendedor;
- wizard de anúncio com craft estruturado;
- chat e propostas pré-compra;
- checkout;
- sala de entrega pós-pagamento;
- compras, vendas, saldo de vendas administrado pelo PSP, saque e suporte;
- segurança, sessões, passkeys, 2FA e dispositivos.

Superfícies operacionais

- fila de moderação de anúncios;
- catálogo e ativos;
- estoque Midas;
- confiança, fraude, restrições e recursos;
- pedidos, disputas e evidências;
- financeiro, conciliação, holds e saques;
- suporte e caixa de e-mail unificada;

- usuários e dispositivos;
- Master, RBAC/ABAC, configurações, integrações e auditoria.

4. Decisões fechadas

Tema	Decisão
Arquitetura	Monólito modular + gateway de chat + workers; PostgreSQL canônico
Venda unitária	Um pedido compra um anúncio no MVP; sem carrinho multivendedor
Catálogo	Itens e adesivos administráveis, versionados e com proveniência
Craft	Modo NONE ou CRAFT ; craft possui exatamente quatro posições ordenadas
Moderação	Todo anúncio P2P exige decisão manual registrada
Pagamento	Estado pago nasce de webhook autenticado e reconciliado, nunca do redirect
Liquidação tardia	Entra em quarentena; só reassume a unidade atômicamente ou reembolsa; nunca abre entrega automaticamente
Dinheiro	PSP regulado movimenta fundos; ledger Midas registra obrigações e saldos
Retenção	Sete dias/168 horas após confirmação bilateral, sujeito a disputa e PSP
Entrega secreta	Só para publisher/tipo transferível autorizado; credencial em cofre, nunca em chat/e-mail/log; desabilitada para contas Standoff 2
Chat	Política distinta para pré-compra, entrega e suporte
PII	1ª e 2ª tentativas bloqueadas; 3ª restringe e abre revisão/recurso
Dispositivo	Chave/passkey + score de risco; fingerprint não prova identidade
Preço	Fonte autorizada, asOf , origem, qualidade e estado desatualizado
Recomendação	Regras explicáveis primeiro; ML apenas após volume e avaliação
Design	Clean room “Midas Foundry”; sem clone visual ou ativo de terceiros

5. Gates que impedem produção

O código comercial não deve avançar para produção até que estes pontos tenham resposta documental:

1. Autorização comercial/técnica escrita da Axlebolt para operar marketplace externo por dinheiro real.
2. Fonte licenciada de catálogo, PNGs, preços e histórico.
3. Mecanismo oficial/autorizado de transferência/entrega dos itens.
4. Exclusão de venda de contas do escopo Standoff 2, salvo mudança expressa dos termos e autorização individualizada.
5. PSP com recursos reais de marketplace, split/subcontas, retenção, reembolso, chargeback, KYC e payout.
6. Modelo jurídico do fluxo financeiro; o termo “escrow” não será usado sem suporte contratual.

7. Moeda, taxas, limites, território, idade mínima e política de vendedor.
8. Evidências aceitas, prazos e regra de disputa.
9. Bases legais, transparência, retenção e exercício de direitos sob LGPD/ECA Digital.
10. Política de WhatsApp/Instagram e uso exclusivo de integrações oficiais.
11. Política de strike: janela, expiração, revisão e recurso.
12. Responsáveis e dupla aprovação para operações financeiras sensíveis.

6. Métrica que guia o produto

North Star recomendada: valor e quantidade de pedidos cujo saldo de vendas chegou a **DISPONIVEL** no fluxo administrado pelo PSP, sem disputa procedente, reembolso ou chargeback.

Não otimizar isoladamente GMV, tempo no site, CTR, mensagens, banimentos ou velocidade de aprovação. O sistema deve premiar transação protegida e concluída, não apenas clique.

7. Ordem de construção recomendada

1. Autorização do publicador, direitos, integração e contrato financeiro.
2. Identidade, IAM, sessão, auditoria e configuração.
3. Catálogo, ativos, anúncio, craft e moderação.
4. Busca, Market P2P, canal Midas e preço com fallback manual.
5. Reserva, pedido, oferta e máquina de estado.
6. PSP sandbox, webhook, ledger e reconciliação.
7. Entrega, cofre, confirmação bilateral, disputa, hold e saque.
8. Chat, anti-PII, recurso e confiança de dispositivo.
9. Tickets, e-mail, observabilidade e operação.
10. Recomendação explicável, piloto e endurecimento.

8. Mapa dos artefatos

Arquivo	Conteúdo
01-PRD-MIDAS.md	visão, personas, escopo, rotas, jornadas, requisitos, aceites e métricas
02-UML-ARQUITETURA.md	C4, domínios, entidades, APIs, eventos, estados e sequências UML
03-DIRECAO-DE-ARTE.md	DNA clean-room, tokens, componentes, UX, conteúdo, motion e acessibilidade
04-SEGURANCA-COMPLIANCE-OPERACOES.md	threat model, auth, device trust, pagamentos, LGPD, suporte e operação

Arquivo	Conteúdo
05-BACKLOG-ROADMAP.md	gates, épicos, releases, dependências, DoR/DoD e estratégia de testes
06-INVENTARIO-REFERENCIAS-E-ASSETS.md	auditoria das referências, endpoints observados e inventário de ativos

9. Posição final

O Midas pode usar das referências a densidade, a clareza comercial e a leitura de mercado. Sua diferença não será “parecer com uma loja conhecida”; será tornar verificável o que geralmente fica solto: quem pode anunciar, o que foi aprovado, qual preço foi observado, quando o pagamento foi confirmado, o que foi entregue, quem confirmou, por que o saldo está retido e quem alterou uma decisão.

A interface vende. O sistema de estados sustenta a venda.

PRD — MIDAS MARKETPLACE

02

Versão 1.1 · Documento pré-código · 21 de agosto de 2026

Gate P0 — NO-GO atual. A operação descrita contraria as **Regras oficiais do Standoff 2** sem permissão expressa. A categoria de contas contraria também a **EULA** e o **Code of Conduct**. Este PRD é uma especificação condicional: nenhum marketplace, API, asset ou entrega real de Standoff 2 deve ser implementado/publicado antes de autorização escrita da Axlebolt.

1. Legenda de rastreabilidade

- **[C] Confirmado:** pedido explícito do usuário.
- **[R] Recomendado:** decisão proposta para segurança, coerência ou qualidade.
- **[D] Dependência:** fornecedor, licença, contrato ou validação externa.
- **[Q] Questão:** decisão de negócio que permanece aberta.

2. Visão

Midas é o produto-alvo de marketplace de itens digitais, condicionado a licença por publicador. Se a Axlebolt autorizar Standoff 2, terá duas vitrines:

1. **Market P2P [C]:** anúncios criados por vendedores e aprovados manualmente pela staff.
2. **Compre do Midas [C]:** estoque próprio, curado e precificado pelo operador Midas.

Promessa: “Veja o preço de referência, negocie com proteção e receba com rastreio.”

North Star [R]: valor e quantidade semanal de transações cujo saldo de vendas chegou a **DISPONIVEL** no fluxo administrado pelo PSP, descontando disputas procedentes, reembolsos e chargebacks.

O produto é orientado por estados verificáveis de anúncio, pagamento, entrega, disputa e saldo. O catálogo é a vitrine; a confiança operacional é o produto.

3. Problema

Compradores temem fraude, preço injusto e entrega incompleta. Vendedores temem chargeback, bloqueio indefinido e compradores mal-intencionados. Os dois lados tendem a levar a conversa para canais externos, o que apaga evidências e reduz a proteção da plataforma.

Midas precisa permitir descoberta e negociação rápidas sem esconder:

- quem vende;
- o que foi aprovado;
- de onde veio o preço em gold;
- quando o pagamento foi realmente confirmado;
- como e quando o produto foi entregue;
- quem confirmou;
- por que um valor está em retenção;
- como contestar uma decisão.

4. Jobs to be Done

- **Comprador:** quando eu quiser adquirir uma skin, craft ou outro item, quero entender seu valor de referência, negociar com segurança e acompanhar a entrega para não pagar sem receber.
- **Vendedor:** quando eu tiver um item para vender, quero anunciá-lo sem preencher dados errados, receber compradores qualificados e saber quando meu saldo estará disponível.
- **Midas:** quando eu vender estoque próprio, quero separá-lo do P2P, controlar o preço e manter a mesma transparência de mercado.
- **Staff:** quando surgir anúncio, mensagem, pagamento ou disputa de risco, quero decidir com contexto, permissão adequada e trilha de auditoria.
- **Master:** quando a operação mudar, quero configurar catálogo, equipe, permissões, taxas, integrações e regras sem editar banco ou código.
- **Suporte:** quando um usuário pedir ajuda por site ou e-mail, quero uma fila única com todo o contexto necessário e nenhum segredo exposto.
- **Financeiro:** quando uma transação avançar ou falhar, quero reconciliar cada valor e liberar somente o que estiver elegível.

5. Personas

Persona	Trabalho principal	Maior risco
Comprador iniciante	Entender item e preço antes de pagar	Confundir referência em gold com o preço monetário da oferta ou cair em golpe

Persona	Trabalho principal	Maior risco
Colecionador	Encontrar crafts e raridades relevantes	Busca pobre e recomendação repetitiva
Vendedor casual	Criar anúncio correto	Escolher item/adesivo errado
Vendedor profissional	Gerir anúncios, pedidos, hold e saque	Dupla venda e status financeiro opaco
Operador Midas	Gerir estoque e preço próprio	Misturar estoque da casa com P2P
Moderador	Decidir anúncios com velocidade e qualidade	Aprovação inconsistente
Trust & Safety	Tratar fraude, PII, restrições e recursos	Falso positivo e evasão ofuscada
Suporte	Resolver tickets e e-mails	Filas fragmentadas e acesso excessivo
Financeiro	Reconciliar, congelar, liberar e pagar	Duplicidade, chargeback e fraude interna
Master	Governar configuração e administradores	Privilégios excessivos e ação sem trilha

6. Objetivos

- **[C]** Publicar anúncios P2P somente após aprovação manual.
- **[C]** Permitir catálogo administrável de itens e adesivos.
- **[C]** Modelar crafts com quatro posições condicionais.
- **[C]** Exibir preço atual e histórico em gold da skin base e preço dos adesivos.
- **[C]** Permitir negociação no site com bloqueio anti-PII antes da compra.
- **[C]** Abrir sala pós-pagamento para entrega e confirmação bilateral.
- **[C]** Manter o saldo em retenção por sete dias antes do saque.
- **[C]** Permitir mensagem automática e WhatsApp somente após pagamento.
- **[C]** Oferecer tickets e caixa própria de e-mail na operação.
- **[C]** Oferecer painel Master e ADM com permissões granulares.
- **[C]** Proteger contas por passkeys/2FA e confiança de dispositivo.
- **[C]** Personalizar descoberta a partir de busca, visualização e compra.
- **[R]** Aumentar conversão por clareza, relevância e confiança, sem padrão manipulativo.

7. Não-objetivos do MVP

- Aplicativo nativo.
- Leilões, loyalty, mídia patrocinada ou crédito próprio.
- Carrinho multivendedor; cada pedido compra um anúncio.
- Transferência automatizada dentro do jogo sem API oficial autorizada.
- Custódia financeira própria ou armazenamento de PAN/CVV.
- Precificação automática do anúncio do vendedor ou do estoque Midas.
- Venda de contas de Standoff 2; atualmente incompatível com EULA/Code of Conduct e removida do escopo real.

- Reutilização de PNGs, textos, marca, CSS ou identidade de terceiros sem licença.
- “Tempo real” baseado em endpoint privado, engenharia reversa ou scraping autenticado.

8. Princípios de produto e UX

1. **Confiança antes da pressão.** Origem, preço, entrega, hold e disputa aparecem antes do pagamento.
2. **Gold é referência.** Nunca parecer moeda do checkout nem soma garantida do craft.
3. **Nenhum dado inventado.** Feed ausente fica indisponível; estoque e popularidade precisam de evidência.
4. **Uma ação, um próximo passo.** Rejeição, pagamento pendente e saque falho sempre oferecem recuperação.
5. **Progressive disclosure.** Craft só aparece quando aplicável; contato só depois do pagamento.
6. **Configuração versionada.** Catálogo, permissões, métodos, taxas, prazos e políticas não ficam hardcoded.
7. **Menor privilégio.** Nível hierárquico não concede automaticamente todas as capacidades.
8. **Clean room.** A referência ensina hierarquia; não fornece ativos nem código.
9. **Acessível e móvel.** Jornada completa por teclado e em viewport pequeno.
10. **Transparência algorítmica.** Personalização tem explicação, opção de desligar e diversidade.

9. Arquitetura de informação e rotas

Superfície	Rota sugerida	Função
Início	/	Busca, categorias, recomendações e duas vitrines
Market P2P	/market	Anúncios de usuários
Compre do Midas	/midas	Estoque próprio identificado
Busca	/buscar?q=	Resultado, filtros, ordem e recuperação
Item-base	/itens/:slug	Histórico, referência e ofertas disponíveis
Anúncio	/anuncios/:id	Oferta, craft, vendedor, chat, gráfico e compra
Vendedor público	/vendedores/:id	Reputação e anúncios públicos
Favoritos	/conta/favoritos	Itens e ofertas salvos
Entrar/cadastrar	/entrar , /cadastro	Identidade
Segurança	/conta/seguranca	MFA, passkeys, sessões e dispositivos
Conta	/conta	Resumo transacional
Criar anúncio	/vender/novo	Wizard estruturado
Meus anúncios	/vender/anuncios	Rascunhos, revisões e publicados
Conversas	/mensagens	Chat e propostas pré-compra
Checkout	/checkout/:intentId	Reserva e pagamento
Entrega	/pedidos/:id/entrega	Sala, cofre, contato e confirmações

Superfície	Rota sugerida	Função
Compras	<code>/conta/compras</code>	Pedidos do comprador
Vendas	<code>/conta/vendas</code>	Pedidos do vendedor
Saldo de vendas	<code>/conta/carteira</code> <i>(alias técnico legado; nome público: Saldo de vendas)</i>	Valores administrados pelo PSP: pendente, hold, disponível e extrato
Saques	<code>/conta/saques</code>	Solicitar e acompanhar
Suporte	<code>/conta/suporte</code>	Abrir e responder tickets
Recurso	<code>/conta/recurso</code>	Revisão de restrição/banimento
Direitos sobre dados	<code>/conta/privacidade</code>	Acesso, correção, exportação, oposição e eliminação
Preferências	<code>/conta/preferencias</code>	Personalização, cookies e comunicações
Cadastro de vendedor	<code>/vender/cadastro</code>	Elegibilidade, KYC/KYB e destino de recebimento via PSP
Central de ajuda	<code>/ajuda</code>	Compra, venda, entrega, disputa, segurança e contato
Central de confiança	<code>/seguranca</code>	Antigolpe, proteção da transação e canais de denúncia
Políticas públicas	<code>/termos</code> , <code>/privacidade</code> , <code>/cookies</code> , <code>/taxas</code> , <code>/politicas/*</code>	Termos, dados, taxas, vendedor, disputa, conteúdo e acessibilidade
Operação	<code>/admin</code>	Filas e alertas
Moderação	<code>/admin/anuncios</code>	Checklist e decisão
Catálogo	<code>/admin/catalogo</code>	Itens, adesivos, taxonomia e ativos
Confiança	<code>/admin/confianca</code>	PII, fraude, restrições e dispositivos
Pedidos	<code>/admin/pedidos</code>	Entrega e disputas
Suporte/inbox	<code>/admin/suporte</code>	Tickets e e-mails unificados
Financeiro	<code>/admin/financeiro</code>	Conciliação, hold, reembolso e saque
Estoque Mídias	<code>/admin/midas</code>	Inventário e preço próprio
Usuários	<code>/admin/usuarios</code>	Status e histórico permitido
Master	<code>/master</code>	IAM, configuração e integrações
Auditoria	<code>/master/auditoria</code>	Eventos e exportação governada

Contratos de API adicionais obrigatórios

As rotas abaixo completam os fluxos críticos do PRD. São contratos candidatos e permanecem condicionados aos gates de publicador, PSP, privacidade e políticas; sua presença neste documento não autoriza integração real com Standoff 2.

```
POST /v1/seller-accounts
GET /v1/me/seller-accounts
POST /v1/seller-accounts/{sellerAccountId}/onboarding
GET /v1/seller-accounts/{sellerAccountId}/onboarding
```

```

POST /v1/seller-accounts/{sellerAccountId}/onboarding/provider-session
POST /v1/seller-accounts/{sellerAccountId}/payout-destinations
POST /v1/listings/{id}/ownership-proofs
POST /v1/admin/listings/{id}/revalidate

POST /v1/orders/{orderId}/disputes
GET /v1/disputes/{disputeId}
POST /v1/disputes/{disputeId}/evidence
POST /v1/disputes/{disputeId}/evidence-submission
POST /v1/admin/disputes/{disputeId}/claim
POST /v1/admin/disputes/{disputeId}/decisions
POST /v1/disputes/{disputeId}/appeals
GET /v1/disputes/{disputeId}/appeals/{appealId}

POST /v1/account-restrictions/{restrictionId}/appeals
GET /v1/account-restrictions/{restrictionId}/appeals/{appealId}
POST /v1/admin/account-appeals/{appealId}/decisions

GET /v1/me/privacy
PATCH /v1/me/privacy/preferences
POST /v1/me/data-rights-requests
GET /v1/me/data-rights-requests/{id}
POST /v1/age-assurance/sessions
GET /v1/age-assurance/status

POST /v1/webhooks/email/{provider}
GET /v1/admin/payments/quarantined
POST /v1/admin/payments/{paymentId}/quarantine/reconcile
POST /v1/admin/payments/{paymentId}/quarantine/refund

```

Estes nomes e caminhos são canônicos para o OpenAPI e coincidem com o documento de arquitetura. Os rascunhos `/seller-onboarding`, `/me/data-rights/requests` e `/admin/payment-exceptions` estão aposentados e não devem virar aliases implícitos.

Todos os endpoints de mutação usam autorização por objeto/campo, `Idempotency-Key` quando houver efeito repetível, auditoria e `application/problem+json`. Evidência, recursos, dados pessoais e exceções financeiras exigem escopo próprio e nunca são retornados por listagens genéricas.

10. Hierarquia e permissões

Níveis funcionais

- **L0 — Usuário:** comprador; vendedor após requisitos de segurança.
- **L1 — Agente:** suporte ou moderador júnior com escopo limitado.
- **L2 — Especialista:** catálogo, confiança, financeiro ou estoque Midas.
- **L3 — Admin gerente:** gerencia filas e membros do próprio domínio.
- **L4 — Master:** governa roles, configurações e integrações.

A política combina `role template + grants explícitos + escopo + expiração + deny`. Um L4 continua incapaz de editar ledger histórico, segredo de autenticação ou auditoria imutável.

Matriz resumida

Função	Pode	Não pode
Comprador	comprar, negociar, confirmar, disputar	moderar ou ver PII de terceiro
Vendedor	anunciar, entregar, confirmar, sacar	aprovar próprio anúncio ou hold
Moderador	revisar anúncios no escopo	alterar pagamento ou ledger
Catálogo	gerir itens, adesivos e ativos	liberar saldo
Trust & Safety	restringir, revisar, banir/desbanir	editar preço Midas ou ledger
Suporte	tickets e ações de baixo risco	ver segredo ou mudar saldo
Financeiro operador	reconciliar e propor ação	aprovar a própria ação crítica
Financeiro aprovador	aprovar dentro do limite	editar catálogo ou auditoria
Operador Midas	estoque e preço próprio	burlar segregação de aprovação
Admin gerente	staff/configuração do domínio	conceder o que não possui
Master	RBAC, configuração e emergência	editar fatos financeiros históricos

Permissões atômicas mínimas

`catalog.read/write/publish` , `asset.manage` , `listing.review/approve/reject/override` ,
`midas.inventory/manage_price` , `chat.review` , `user.restrict/ban/unban` , `appeal.resolve` ,
`ticket.read/reply/assign/close` , `email.reply` , `order.read/intervene` , `dispute.resolve` ,
`refund.request/approve` , `hold.freeze/release` , `payout.request/approve` , `payment.configure` ,
`roles.read/manage` , `admin.invite/revoke` , `device.review/revoke` , `audit.read/export` ,
`feature_flag.manage` .

Guardas

- default deny; deny explícito vence;
- passkey ou 2FA obrigatória para staff;
- step-up para IAM, segredo, reembolso, hold, saque e exportação;
- maker-checker para ação financeira acima de limite configurável;
- elevação temporária expira;
- ninguém aprova a própria ação sensível;
- toda negação e todo override relevante são auditados.

11. Jornadas ponta a ponta

Comprador

1. Entra por Início, Market ou Midas.
2. Busca/filtra por arma, coleção, raridade, preço, craft e adesivo.
3. Abre anúncio e compara preço da oferta, referência em gold, componentes, gráfico, frescor e vendedor.
4. Favorita, conversa ou envia proposta estruturada.
5. PII detectada é bloqueada antes de chegar à outra parte.
6. Aceita preço e inicia checkout; o anúncio é reservado atomicamente.
7. O servidor aguarda confirmação autenticada do PSP.
8. Após pagamento: sala de entrega, mensagem automática/cofre e WhatsApp opcional são liberados.
9. Comprador e vendedor confirmam de forma independente.
10. Se não houver disputa, começa a retenção de 168 horas.
11. Comprador avalia ou abre disputa/ticket.

Vendedor

1. Ativa fator forte, conclui cadastro de vendedor e cumpre KYC/KYB e destino de recebimento exigidos pelo PSP/política.
2. Escolhe tipo e item do catálogo.
3. Declara craft; se **sim**, vê quatro slots; se **não**, slots desaparecem e são limpos.
4. Define preço, descrição, instrução e contato pós-pago.
5. Visualiza prévia e envia revisão imutável.
6. Corrige, se necessário; após aprovação, anúncio é publicado.
7. Negocia por chat/proposta.
8. Após pagamento, entrega na sala e confirma.
9. Acompanha retenção e, quando elegível, solicita saque.

Compre do Midas

1. Operador autorizado vincula item do catálogo ao estoque próprio.
2. Define preço, craft, quantidade/identificador e entrega.
3. Política decide se quatro-olhos é obrigatório.

4. Oferta aparece apenas na vitrine Midas e recebe identificação permanente.
5. Preço de referência, gráfico, pagamento, entrega e auditoria usam os mesmos motores.
6. Relatórios separam GMV P2P, estoque, receita e margem Midas.

Moderação

1. Fila prioriza risco e tempo.
2. Moderador assume um caso e verifica versão congelada.
3. Checklist valida item, craft, mídia, preço, descrição e entrega.
4. Aprova, rejeita ou solicita alteração com motivo estruturado.
5. Reenvio gera nova revisão; histórico não é apagado.

Suporte e e-mail

1. Ticket nasce no portal ou de inbound e-mail.
2. Threading associa resposta ao caso correto.
3. Fila aplica categoria, prioridade, SLA e responsável.
4. Agente vê apenas contexto necessário, responde no mesmo histórico e escala.
5. Bounce, reabertura e decisão preservam trilha.

Financeiro

1. Concilia PSP, pedido e ledger.
2. Monitora pendente, protegido, hold, congelado e disponível.
3. Divergência congela ação relacionada e abre caso.
4. Liberação depende de todos os gates, não apenas do relógio.
5. Saque usa maker-checker e confirmação do PSP.

12. Requisitos funcionais

Identidade, conta e dispositivo

- **RF-001 [C]** Cadastrar e autenticar com verificação de e-mail.

- **RF-002 [R]** Uma conta pode comprar e vender, sem duplicação de identidade.
- **RF-003 [R]** Estados: **ATIVO** , **RESTRITO** , **SUSPENSO** , **BANIDO** , **ENCERRADO** .
- **RF-004 [C]** Suportar 2FA e passkeys.
- **RF-005 [R]** TOTP, passkey e recovery codes; SMS não é fator principal.
- **RF-006 [C]** Disponibilizar API própria de dispositivo confiável.
- **RF-007 [R]** Registrar desafio, chave pública, risco, validade e revogação; sem fingerprint como identidade.
- **RF-008 [R]** Usuário lista e revoga sessões/dispositivos.
- **RF-009 [R]** Novo dispositivo ou ação de risco exige step-up e alerta.
- **RF-010 [R]** Staff e vendedor antes do primeiro saque possuem fator forte.

Catálogo e ativos

- **RF-011 [C]** Administradores autorizados gerenciam skins e adesivos.
- **RF-012 [R]** Item possui ID imutável, tipo, nome, coleção, arma, raridade, atributos e estado.
- **RF-013 [R]** Desativar item bloqueia novos anúncios sem quebrar históricos.
- **RF-014 [C]** Wizard aceita somente itens ativos do catálogo.
- **RF-015 [R]** Ativo guarda origem, licença, hash, versão, autor e vínculo.
- **RF-016 [D]** Importação de PNG depende de autorização comprovada.
- **RF-017 [R]** Catálogo é versionado e auditado.
- **RF-018 [R]** Importação em lote oferece dry-run, prévia, erros e rollback lógico.

Anúncios e craft

- **RF-019 [C]** Vendedor cria anúncio por wizard com rascunho.
- **RF-020 [C]** Skin exige seleção da skin base.
- **RF-021 [C]** “Tem craft?” controla quatro posições ordenadas.
- **RF-022 [R]** Craft ativo permite até quatro adesivos e exige ao menos um; vazio é explícito.
- **RF-023 [R]** Ordem persiste e repetição é permitida salvo regra do catálogo.
- **RF-024 [C]** Craft desligado oculta e remove posições.
- **RF-025 [C]** Vendedor define preço monetário da oferta.
- **RF-026 [R]** Gold aparece separado e rotulado como referência.
- **RF-027 [C]** Vendedor cadastra mensagem automática pós-pagamento.
- **RF-028 [C]** Vendedor cadastra WhatsApp opcional, oculto antes do pagamento.
- **RF-029 [D/R]** Somente para categoria de conta cuja transferência seja expressamente autorizada por outro publisher, login/senha/token ficam em cofre, nunca em texto comum. Esta capacidade permanece integralmente desabilitada no canal Standoff 2.

- **RF-030 [R]** Wizard salva e restaura rascunho.
- **RF-031 [R]** Prévia reproduz a página pública.
- **RF-032 [C]** Todo P2P exige aprovação manual.
- **RF-033 [R]** Estados cobrem rascunho, revisão, publicação, reserva, venda, pausa e expiração.
- **RF-034 [R]** Alteração material cria nova revisão e pode exigir nova aprovação.
- **RF-035 [R]** Reserva atômica impede dupla venda.
- **RF-036 [D]** Tipo **ACCOUNT** não existe no canal Standoff 2. Só poderá existir para outro publisher com prova de transferibilidade e autorização expressa.

Moderação

- **RF-037 [C]** Admin autorizado aprova, rejeita ou pede correção.
- **RF-038 [R]** Fila possui risco, prioridade, filtro, atribuição e SLA.
- **RF-039 [R]** Checklist cobre item, craft, preço, texto, mídia e entrega.
- **RF-040 [R]** Rejeição/ajuste exige código de motivo e orientação.
- **RF-041 [R]** Vendedor corrige sem perder histórico.
- **RF-042 [R]** Staff não aprova o próprio conteúdo quando segregação estiver ativa.
- **RF-043 [R]** Override exige permissão, step-up e justificativa.

Descoberta e recomendação

- **RF-044 [C]** Usuários pesquisam e navegam por anúncios.
- **RF-045 [R]** Filtros: arma, coleção, raridade, preço, craft, adesivo, vendedor e canal.
- **RF-046 [C]** Busca, visualização e compra alimentam prioridade personalizada.
- **RF-047 [R]** Sinais: busca, clique, favorito, proposta, compra, categoria, preço e recência.
- **RF-048 [R]** MVP usa ranking explicável por regras.
- **RF-049 [R]** Cold start usa tendências reais, disponibilidade e diversidade.
- **RF-050 [R]** Usuário limpa histórico e desliga personalização.
- **RF-051 [R]** Ranking limita repetição e concentração de vendedor.
- **RF-052 [R]** “Por que estou vendo isto?” explica sinais principais.

Preço e gráfico

- **RF-053 [C]** Página exibe preço atual em gold da skin base.
- **RF-054 [C]** Cada adesivo preenchido exibe preço atual em gold.

- **RF-055 [C]** Gráfico histórico representa a skin base.
- **RF-056 [R]** Feed mostra fonte, timestamp, cadência e estado de frescor.
- **RF-057 [R]** Soma de componentes é “referência bruta”, não valor garantido do craft.
- **RF-058 [R]** Períodos só aparecem se houver dados suficientes.
- **RF-059 [R]** Falha mostra último valor como desatualizado; ausência não vira zero.
- **RF-060 [D]** Conector depende de API/feed autorizado.
- **RF-061 [R]** Lacuna e divergência geram alerta operacional.
- **RF-062 [C]** Preço Midas é manual e não é sobrescrito por gold.

Chat, proposta e anti-PII

- **RF-063 [C]** Comprador e vendedor conversam antes da compra.
- **RF-064 [R]** Proposta tem valor, validade e estado estruturado.
- **RF-065 [R]** Oferta aceita cria checkout reservado com expiração.
- **RF-066 [C]** Pré-compra bloqueia telefone, e-mail, nick, URL, Pix e redes sociais.
- **RF-067 [R]** Detector combina normalização, padrões, ofuscação e classificador.
- **RF-068 [R]** Mensagem violadora não é entregue.
- **RF-069 [C]** Primeira tentativa bloqueia e avisa.
- **RF-070 [C]** Segunda bloqueia e apresenta aviso final.
- **RF-071 [C/R]** Terceira bloqueia uso normal e leva a **RESTRICTED_PENDING_REVIEW** ; banimento definitivo exige decisão humana.
- **RF-072 [C]** Restrito acessa recurso e funções essenciais.
- **RF-073 [R]** Staff autorizada vê evidência redigida, regra e confiança.
- **RF-074 [R]** Falso positivo pode ser contestado e revertido com motivo.
- **RF-075 [R]** Rate limit, spam e denúncia são controles independentes.
- **RF-076 [R]** Sala pós-pagamento usa política de contato diferente.

Checkout, pedido e entrega

- **RF-077 [C]** Métodos de pagamento são configuráveis pelo Master após escolha do PSP.
- **RF-078 [R]** Checkout reserva anúncio por prazo configurado.
- **RF-079 [R]** Criação/confirmação são idempotentes.
- **RF-080 [R]** Pago depende de confirmação server-side do PSP.
- **RF-081 [C]** Mensagem, cofre e WhatsApp só são revelados após pagamento.
- **RF-082 [C]** Pedido pago abre sala exclusiva.

- **RF-083 [R]** Sala registra mensagens, eventos e evidências permitidas.
- **RF-084 [C]** Vendedor confirma entrega.
- **RF-085 [C]** Comprador confirma recebimento.
- **RF-086 [C]** Venda conclui somente com as duas confirmações.
- **RF-087 [R]** Uma parte não confirma em nome da outra.
- **RF-088 [R]** Divergência abre disputa e congela o fluxo.
- **RF-089 [R]** Ausência gera lembretes/escalonamento; sem confirmação silenciosa no MVP.
- **RF-090 [R]** Avaliação só por participante de pedido concluído.

Ledger, hold e saque

- **RF-091 [R]** Movimentação financeira gera lançamento imutável de partidas dobradas.
- **RF-092 [R]** Saldos: **PENDENTE** , **PROTEGIDO** , **EM_HOLD** , **DISPONIVEL** , **CONGELADO** , **EM_Saque** , **PAGO** , **ESTORNADO** .
- **RF-093 [C]** Confirmação bilateral inicia sete dias de retenção.
- **RF-094 [R]** Padrão: 168 horas a partir de **completedAt** , em UTC.
- **RF-095 [R]** Disputa, chargeback ou risco pausa liberação.
- **RF-096 [R]** Liberação exige pagamento conciliado, pedido concluído e nenhum bloqueio.
- **RF-097 [R]** A tela “Saldo de vendas” mostra início, previsão e motivo por lote administrado pelo PSP; **/conta/carteira** permanece apenas como alias técnico legado e não representa carteira própria ou custódia Midas.
- **RF-098 [R]** Saque usa apenas saldo disponível.
- **RF-099 [R]** Saque possui estados e recuperação de falha.
- **RF-100 [R]** Reembolso/saque crítico usa maker-checker.
- **RF-101 [R]** Taxas e retenções são exibidas antes da venda.
- **RF-102 [D]** Regras finais dependem do PSP e análise jurídica/financeira.

Compre do Midas

- **RF-103 [C]** Aba separada “Compre do Midas”.
- **RF-104 [C]** Apenas autorizados gerenciam estoque próprio.
- **RF-105 [C]** Midas define os preços.
- **RF-106 [C]** Itens Midas mantêm craft, gold, gráfico e entrega.
- **RF-107 [R]** Card/página exibem “Vendido pelo Midas”.
- **RF-108 [R]** Busca global pode misturar origens com rotulagem inequívoca.
- **RF-109 [R]** Estoque, receita e margem Midas são separados do P2P.

Tickets e caixa de e-mail

- **RF-110 [C]** Usuário cria e acompanha tickets no perfil.
- **RF-111 [C]** Contato por e-mail ou mensagem interna.
- **RF-112 [R]** Ticket possui categoria, prioridade, estado, SLA e responsável.
- **RF-113 [R]** Estados cobrem novo, aberto, esperas, resolvido, fechado e reaberto.
- **RF-114 [C]** Staff opera caixa de e-mail própria dentro do backoffice.
- **RF-115 [R]** Headers e token de thread evitam duplicação.
- **RF-116 [R]** Resposta aparece no portal e pode seguir por e-mail.
- **RF-117 [R]** Inbox possui filas, atribuição, macros, notas, tags e escalonamento.
- **RF-118 [R]** Anexo passa por tipo, tamanho, quarentena e antivírus.
- **RF-119 [R]** Segredos nunca aparecem em e-mail operacional.
- **RF-120 [R]** Bounce fica visível e oferece canal alternativo.

Master, administração e auditoria

- **RF-121 [C]** Master cria e gerencia administradores.
- **RF-122 [C]** Master edita capacidades granulares.
- **RF-123 [C]** Master delega catálogo.
- **RF-124 [R]** Painel combina templates e permissões atômicas.
- **RF-125 [R]** Grants possuem escopo e validade.
- **RF-126 [R]** Configurações abrangem catálogo, taxa, hold, pagamento, limites, e-mail, integrações e flags.
- **RF-127 [R]** Mudança sensível exige impacto, step-up e auditoria.
- **RF-128 [R]** Auditoria registra ator, ação, alvo, antes/depois redigido, hora, dispositivo e motivo.
- **RF-129 [R]** Auditoria e ledger não têm edição/exclusão na interface.
- **RF-130 [R]** Kill switches pausam anúncio, checkout, saque ou integração separadamente.
- **RF-131 [R]** Exportação respeita escopo, mascaramento e expiração.
- **RF-132 [R]** Ação automática identifica regra/modelo e versão.

Notificações e analítica

- **RF-133 [R]** Notificações cobrem moderação, proposta, pagamento, entrega, disputa, hold, saque, ticket e segurança.
- **RF-134 [R]** Alertas críticos não podem ser totalmente desativados.
- **RF-135 [R]** Eventos seguem taxonomia versionada.
- **RF-136 [R]** Dashboards separam P2P e Midas.

- **RF-137 [R]** Recomendação possui retenção e controles próprios.
- **RF-138 [R]** Analytics nunca carrega chat, senha, token ou segredo.

Disputa, evidência e recurso

- **RF-139 [R]** Comprador, vendedor, suporte autorizado ou regra de risco podem abrir disputa vinculada a um pedido elegível, com motivo estruturado e proteção contra duplicidade.
- **RF-140 [R]** A abertura congela entrega decisória, lote financeiro e ações incompatíveis, preservando snapshot de pedido, anúncio, confirmações e políticas aplicáveis.
- **RF-141 [R]** Evidência possui tipo, autoria, hash, classificação, prazo de envio, estado de análise e acesso por menor privilégio; anexos passam por quarentena e conteúdo secreto usa cofre próprio.
- **RF-142 [R]** A disputa possui janela de evidência, lembretes, encerramento auditável e tratamento explícito para ausência de uma parte; nenhum prazo presume automaticamente que houve entrega.
- **RF-143 [R]** Staff sem conflito decide **BUYER**, **SELLER** ou **SPLIT**, com reason code, fundamentação, valores e política versionada.
- **RF-144 [R]** A decisão gera comandos financeiros idempotentes de refund, release, split ou freeze; staff não edita ledger nem saldo diretamente.
- **RF-145 [R]** Cada parte pode recorrer dentro da janela configurada; recurso preserva a decisão anterior, cria revisão própria e, quando possível, é analisado por pessoa diferente.
- **RF-146 [R]** Conta restrita ou banida mantém acesso ao pedido, evidências necessárias, suporte e recurso sem recuperar funções de risco.
- **RF-147 [R]** Abertura, prazo, pedido de evidência, decisão, execução e recurso geram notificações internas e transacionais sem conteúdo secreto.
- **RF-148 [R]** Toda leitura, exportação, decisão, override e reversão de disputa/recurso é auditada e sujeita a retenção/legal hold aprovado.

Elegibilidade do vendedor, posse e capacidade do item

- **RF-149 [D/R]** Cadastro de vendedor possui estados **DRAFT**, **PENDING_VERIFICATION**, **ACTIVE**, **RESTRICTED**, **REJECTED** e **CLOSED**, com requisitos definidos por território, PSP e risco.
- **RF-150 [D/R]** KYC/KYB é executado pelo PSP ou fornecedor contratado, com compartilhamento minimizado de status e IDs; documentos brutos não entram no banco geral Midas.
- **RF-151 [R]** Destino de recebimento é cadastrado por fluxo tokenizado/verificado; inclusão ou mudança exige step-up, notificação e cooling-off configurável.
- **RF-152 [R]** Vendedor não publica, recebe pagamento ou solicita saque quando os gates obrigatórios do seu estado/território estiverem vencidos ou incompletos.
- **RF-153 [D/R]** Cada anúncio exige prova autorizada de posse e disponibilidade compatível com o publisher, com origem, timestamp, validade e vínculo à unidade anunciada.

- **RF-154 [R]** A prova expira e é revalidada antes da reserva/checkout; falha bloqueia a compra e abre recuperação sem cobrar o comprador.
- **RF-155 [R]** Perda de disponibilidade suspende o anúncio, invalida reservas ainda não pagas e cria caso operacional quando houver pagamento ou divergência.
- **RF-156 [R]** Catálogo define `craftEligible`; o controle “Tem craft?” só aparece para item-base ativo e explicitamente elegível.
- **RF-157 [R]** Capacidades por tipo — craft, quantidade, mídia, entrega, prova de posse e atributos — são versionadas e congeladas na revisão/pedido.

Idade, privacidade, personalização e cookies

- **RF-158 [D/R]** O produto executa avaliação de acesso provável por crianças/adolescentes e aplica age assurance proporcional antes de funções definidas pela política.
- **RF-159 [D/R]** Sinal de idade guarda somente faixa/resultado, método, confiança, validade e contestação; imagem/cópia de documento é eliminada de modo imediato e irreversível após extração quando a lei assim exigir.
- **RF-160 [D/R]** Faixas protegidas recebem defaults restritivos de chat, personalização, compra, notificações e supervisão/consentimento responsável conforme matriz jurídica aprovada.
- **RF-161 [R]** Titular solicita acesso, confirmação, correção, exportação, oposição, revisão e eliminação em fluxo autenticado com protocolo, prazo, estado e resposta justificável.
- **RF-162 [R]** Pedido de direito valida identidade de forma proporcional, separa dado exportável de segredo de terceiros e permite extensão/negação apenas com base e motivo registrados.
- **RF-163 [R]** Eliminação anonimiza o dispensável e preserva somente obrigação, prevenção à fraude, exercício de direito ou legal hold válidos, informando categorias preservadas.
- **RF-164 [D/R]** Registro de tratamento identifica finalidade, base, controlador/operador, subprocessador, compartilhamento, transferência internacional, retenção e canal do encarregado.
- **RF-165 [R]** Preferências distinguem cookies estritamente necessários, analytics, personalização e comunicação; escolhas são versionadas, revogáveis e não usam consentimento empacotado.
- **RF-166 [R]** Desligar personalização interrompe novos eventos individualizados, limpa/reconstrói o perfil dentro do SLA e mantém apenas agregados autorizados; navegação continua funcional.

Segurança do inbound de e-mail

- **RF-167 [R]** Webhook inbound valida assinatura, timestamp, provider message ID e política anti-replay antes de aceitar conteúdo.
- **RF-168 [R]** Token de thread é opaco, escopado, expirável e rotacionável; remetente precisa estar autorizado no ticket ou seguir fluxo de verificação/escalonamento.
- **RF-169 [R]** E-mail com assinatura inválida, token vazado, remetente divergente ou anexo inseguro não entra na conversa: vai para quarentena/caso com motivo auditado.

Acesso, políticas públicas e fiscal/contábil

- **RF-170 [R]** Todo gráfico de preço oferece tabela/descrição textual equivalente, valores de início/fim/mínimo/máximo, fonte, **asOf** e navegação por teclado/leitor de tela.
- **RF-171 [R]** O site publica e torna pesquisáveis termos, privacidade, cookies, taxas, vendedor, disputa, arrependimento, conteúdo, antiscam, acessibilidade e canais de denúncia/suporte.
- **RF-172 [R]** Checkout e pedido congelam versão das políticas, oferta, taxas e consentimentos aplicáveis e disponibilizam comprovante conservável ao usuário.
- **RF-173 [D]** Antes de transação real, jurídico/contábil definem papel comercial e fiscal da Midas, comissão, reconhecimento de receita, obrigações do vendedor e documentos fiscais por território.
- **RF-174 [D/R]** Emissão/integração de documento fiscal e recibo de taxa é configurável, idempotente e reconciliada, sem inventar obrigação ou layout antes da definição competente.
- **RF-175 [R]** Relatórios contábeis separam principal de terceiros, comissão Midas, estoque próprio, taxas PSP, refunds, chargebacks, reservas e tributos, reconciliados ao ledger/PSP.

Pagamento tardio e expiração segura

- **RF-176 [R]** Reserva não retorna o anúncio à venda até o intent ser cancelado/expirado no estado canônico do PSP ou entrar em exceção controlada.
- **RF-177 [R]** Evento de sucesso recebido após TTL entra em **PAYMENT_QUARANTINED** ; não marca venda concluída, não abre sala e não revela contato/segredo automaticamente.
- **RF-178 [R]** O sistema tenta reassumir atômicamente a mesma unidade somente se ela continuar disponível e vinculada ao mesmo pedido; caso contrário inicia refund idempotente.
- **RF-179 [R]** Pagamento tardio, reassunção e refund notificam comprador, vendedor e operação, mantendo a oferta indisponível apenas pelo tempo necessário à decisão.
- **RF-180 [R]** Corridas entre expiração, cancelamento e webhook são auditadas, reconciliadas e cobertas por teste P0; nenhum resultado pode gerar dois pedidos pagos para uma unidade.

13. Regras de negócio

1. Anúncio P2P nunca é público antes de aprovação.
2. Comprador vê somente versão publicada; staff autorizada vê histórico.
3. Item sem elegibilidade de craft tem zero posições; item elegível em modo craft tem exatamente quatro posições persistidas.
4. Desmarcar craft limpa posições após confirmação do usuário.
5. Preço em gold é informativo, com fonte e timestamp próximos.
6. Preço próprio do Midas não é alterado automaticamente pelo feed.
7. Contato e segredo ficam ocultos antes de pagamento canônico, conciliado e compatível com uma reserva ainda válida ou reassumida.

8. Mensagem anti-PII bloqueada não é entregue e não entra em logs comuns.
9. A terceira violação restringe imediatamente; revisão humana decide o banimento definitivo.
10. Pagamento só muda por evento autenticado/idempotente e reconciliável.
11. Venda conclui quando `buyerConfirmed && sellerConfirmed` e não há disputa bloqueante.
12. Hold inicia em `completedAt` e expira em `completedAt + 168h`.
13. Liberação exige relógio + conciliação + ausência de freeze.
14. Configuração nova não reescreve contrato passado.
15. Ninguém aprova a própria operação financeira.
16. “Popular”, “desconto” e “últimas unidades” exigem dados reais.
17. Dispositivo confiável reduz fricção, mas não substitui step-up crítico.
18. Um anúncio unitário só pode ter uma reserva ativa e um pedido vendido.
19. Reserva expirada só libera a unidade depois de confirmação canônica de cancelamento/expiração do intent ou tratamento explícito de exceção.
20. Pagamento tardio nunca revela entrega; reassunção ou refund ocorre antes de qualquer continuação.
21. Disputa congela o lote e decisões financeiras são comandos idempotentes, nunca edição de saldo.
22. Recurso preserva a decisão anterior, sua evidência e seu autor; não sobrescreve histórico.
23. Vendedor precisa estar elegível e a prova de posse/disponibilidade válida antes da reserva.
24. Preferência revogada não autoriza novos eventos individualizados; obrigação legal preservada é informada separadamente.
25. Mensagem inbound de e-mail só entra no ticket após autenticação do provedor, thread e remetente.
26. “Saldo de vendas” é visão de obrigações administradas pelo PSP; não representa depósito, conta de pagamento ou custódia própria da Midas.

14. Máquinas de estado de produto

Anúncio

RASCUNHO → ENVIADO → EM_REVISAO → APROVADO → PUBLICADO → RESERVADO → VENDIDO

Alternativas: AJUSTES_SOLICITADOS, REJEITADO, PAUSADO, EXPIRADO, SUSPENSO; reserva expirada retorna a PUBLICADO somente após cancelamento/expiração canônica do intent ou resolução da exceção de pagamento.

Pagamento/pedido

CRIADO → PAGAMENTO_PENDENTE → PAGO → ENTREGA_EM_ANDAMENTO → AGUARDANDO_CONFIRMACOES → CONCLUIDO

Alternativas: CANCELAMENTO_PENDENTE , CANCELADO , FALHOU , EXPIRADO , PAYMENT_QUARANTINED , REEMBOLSO_PENDENTE , REEMBOLSADO , EM_DISPUTA , CHARGEBACK . PAYMENT_QUARANTINED só segue para PAGO após reassunção atômica da mesma unidade; caso contrário segue para REEMBOLSO_PENDENTE .

Saldo de vendas administrado pelo PSP

NAO_FINANCIADO → PROCESSANDO_PSP → PROTEGIDO → EM_HOLD → DISPONIVEL → EM_SAQUE → PAGO

Alternativas: CONGELADO , ESTORNADO , DIVIDA_CHARGEBACK .

Conta/PII

ATIVA[0..2 strikes] → RESTRITA_PENDENTE_REVISAO[3] → ATIVA | SUSPENSA | BANIDA

BANIDA/RESTRITA → RECURSO_ABERTO → EM_REVISAO_RECURSO → RECURSO_ACEITO | RECURSO_NEGADO ; aceite retorna ao estado determinado pela decisão humana.

Disputa

ABERTA → COLETA_EVIDENCIA → EM_REVISAO → DECIDIDA_BUYER | DECIDIDA_SELLER | DECIDIDA_SPLIT → EXECUCAO_FINANCEIRA → ENCERRADA

Alternativa: ENCERRADA → RECURSO_ABERTO → EM_REVISAO_RECURSO → DECISAO_RECURSO → ENCERRADA . Cada ciclo cria versão própria; nenhum retorno apaga a decisão anterior.

Cadastro de vendedor

DRAFT → PENDING_VERIFICATION → ACTIVE

Alternativas: RESTRICTED , REJECTED , CLOSED ; verificação vencida ou destino de recebimento em cooling-off impede publicação, pagamento ou saque conforme política.

Dispositivo

DESCONHECIDO → VINCULADO → CONFIAVEL → DESAFIADO → CONFIAVEL

Qualquer estado pode ir a QUARENTENA , REVOGADO ou EXPIRADO .

15. Critérios de aceite críticos

Craft

Cenário: skin sem craft

Dado que o vendedor escolheu uma skin válida
Quando marca “Não possui craft”
Então os quatro slots não são exibidos
E nenhum adesivo segue na submissão

Cenário: skin com craft

Dado que o item-base possui craftEligible=true
Quando marca “Possui craft”
Então vê exatamente quatro posições ordenadas
E só seleciona adesivos ativos do catálogo
E preenche ao menos uma posição para enviar

Cenário: item não elegível

Dado que o item-base possui craftEligible=false
Então o controle “Tem craft?” não é exibido
E qualquer payload com slots é rejeitado no servidor

Moderação

Cenário: aprovação segregada

Dado um anúncio EM_REVISAO
E um moderador com listing.approve sem conflito
Quando completa o checklist e aprova
Então a versão analisada fica registrada
E o anúncio pode ser publicado
E o vendedor é notificado

Preço

Cenário: feed atualizado

Dado um anúncio com craft
E uma fonte autorizada disponível
Quando o comprador abre a página
Então vê oferta monetária separada de gold
E vê preço da skin e de cada adesivo
E vê fonte e horário
E o gráfico representa a skin base

Cenário: feed indisponível
Então nenhum valor é inventado ou exibido como zero
E o último valor, se houver, aparece como desatualizado

Cenário: alternativa acessível ao gráfico
Quando uma pessoa usa teclado ou leitor de tela
Então acessa tabela ou resumo equivalente por período
E os mesmos valores, fonte, horário e frescor ficam disponíveis sem depender de cor

PII

Cenário: terceira tentativa de alta confiança
Dado que o usuário possui dois strikes válidos
Quando tenta novamente compartilhar contato
Então a mensagem não é entregue
E a conta fica RESTRITA_PENDENTE_REVISAO
E o usuário é direcionado ao recurso

Pagamento e revelação

Cenário: pagamento pendente
Então WhatsApp, mensagem secreta e cofre permanecem ocultos

Cenário: webhook confirmado
Dado um evento assinado, único e reconciliado
E uma reserva válida ou reassumida atômicamente
Quando o pagamento muda para PAGO
Então a sala de entrega é criada uma vez
E os dados pós-pagos autorizados ficam acessíveis

Cenário: pagamento confirmado após expiração
Dado que a reserva expirou
Quando chega um sucesso tardio do PSP
Então o pedido entra em PAYMENT_QUARANTINED
E nenhum contato, mensagem secreta ou cofre é revelado
E a mesma unidade é reassumida atômicamente ou um refund idempotente é iniciado

Confirmação e hold

Cenário: apenas uma parte confirmou
Então o pedido não conclui e o hold não inicia

Cenário: ambas confirmaram e não há disputa

Então o pedido conclui

E o lote entra em hold por 168 horas

E a data prevista fica visível

Cenário: disputa durante o hold

Então o lote fica CONGELADO e não pode ser sacado

Idempotência

Cenário: webhook repetido cem vezes

Dado o mesmo providerEventId

Quando o evento é reenviado

Então existe exatamente uma transição financeira e um journal válido

Cenário: compras concorrentes

Dado um anúncio unitário ativo

Quando cem checkouts tentam reservá-lo

Então exatamente um pedido vence

E-mail unificado

Cenário: resposta por e-mail

Dado um webhook assinado e não repetido

E um token de thread válido

E um remetente autorizado ou verificado

Quando o e-mail chega

Então ele vira mensagem no ticket existente

E não cria duplicata

E o portal preserva o histórico mesmo em caso de bounce posterior

Cenário: remetente ou assinatura inválida

Então o conteúdo não entra na conversa

E um caso de quarentena auditado é criado sem notificar o cliente como se fosse resposta válida

Disputa e recurso

Cenário: decisão dividida

Dado que a janela de evidência encerrou

E o analista não possui conflito

Quando decide DECIDIDA_SPLIT com valores e reason code

Então a decisão e a política ficam versionadas
E comandos financeiros idempotentes somam exatamente o valor elegível
E as partes são notificadas sobre decisão e prazo de recurso

Cenário: recurso

Dado que a parte está dentro da janela
Quando apresenta recurso fundamentado
Então nasce uma revisão sem apagar decisão ou evidência anterior
E, quando possível, outro analista recebe o caso

Vendedor, posse e disponibilidade

Cenário: prova vencida no checkout

Dado que o anúncio estava publicado
E a prova autorizada de disponibilidade venceu
Quando o comprador tenta reservar
Então o checkout não cobra
E o anúncio é suspenso ou enviado à revalidação

Cenário: mudança de destino de recebimento

Quando o vendedor cadastra novo destino
Então ocorre step-up e notificação
E o cooling-off bloqueia o saque pelo prazo configurado

Direitos sobre dados e idade

Cenário: desligar personalização

Quando o usuário revoga personalização
Então novos eventos deixam de alimentar perfil individual
E o perfil derivado é limpo ou reconstruído dentro do SLA
E a navegação não personalizada continua funcionando

Cenário: documento usado para aferição de idade

Quando o sinal mínimo de faixa etária é extraído
Então imagem e cópia são eliminadas de modo imediato e irreversível quando exigido
E ficam apenas resultado, método, confiança, validade e trilha de contestação

16. Estados vazios e recuperação

Situação	Mensagem/estado	Próxima ação
Busca sem resultado	termo e filtros visíveis	remover filtro, corrigir ou criar alerta
Item sem anúncio	item e gráfico sem card falso	favoritar/avisar disponibilidade

Situação	Mensagem/estado	Próxima ação
Feed fora	último valor rotulado ou indisponível	navegar ou tentar novamente
Item ausente no catálogo	envio bloqueado sem perder rascunho	solicitar item à staff
Anúncio rejeitado	motivos por campo	corrigir e reenviar
Reservado por outro	estado inequívoco	ver ofertas semelhantes
Pagamento pendente	processamento sem duplicar cobrança	atualização automática/suporte
Pagamento tardio	análise sem entrega liberada	acompanhar reassunção ou refund
Mensagem com PII	conteúdo não enviado + strike	editar e ler regra
Conta restrita	motivo e acesso limitado	abrir recurso
Cadastro de vendedor pendente	gate e requisito faltante visíveis	concluir verificação/contestar
Prova de posse vencida	anúncio suspenso sem cobrança	revalidar por fonte autorizada
Vendedor atrasado	prazo e lembretes	abrir disputa/ticket
Partes discordam	pedido congelado	enviar evidência
Disputa em recurso	decisão anterior e prazo visíveis	acompanhar revisão
Hold ativo	início, previsão e motivo	acompanhar
Saque falho	razão corrigível	ajustar destino e tentar novamente
E-mail retornou	falha de entrega no ticket	portal ou corrigir endereço
Dispositivo novo	desafio de segurança	passkey/2FA/recuperação
Integração fora	módulo degradado identificado	pausar fluxo afetado
Solicitação LGPD em andamento	protocolo, prazo e escopo	acompanhar ou complementar identidade
Preferência sem consentimento	experiência essencial preservada	revisar escolhas

17. Requisitos não funcionais

- **RNF-01:** autorização server-side em toda operação privilegiada.
- **RNF-02:** TLS e criptografia em repouso para dados sensíveis.
- **RNF-03:** senha, token, 2FA, PII crítica e segredo nunca em logs.
- **RNF-04:** webhook assinado, idempotente e tolerante a repetição/ordem invertida.
- **RNF-05:** ledger e auditoria append-only.
- **RNF-06:** reserva, venda e saldo são transacionais.
- **RNF-07:** SLOs definidos e medidos antes do lançamento.
- **RNF-08:** modo degradado para preço/e-mail sem corromper pedidos.
- **RNF-09:** meta WCAG 2.2 AA.
- **RNF-10:** datas em UTC, exibidas no fuso do usuário.
- **RNF-11:** correlação entre pedido, pagamento, entrega, disputa e ledger.
- **RNF-12:** backup, restauração e desastre testados.
- **RNF-13:** retenção distinta por finalidade e classe.

- **RNF-14:** integrações com timeout, retry, circuit breaker e conciliação.
- **RNF-15:** testes concorrentes cobrem reserva, webhook, hold e saque.
- **RNF-16:** nenhum PAN/CVV trafega ou é persistido pela Midas.
- **RNF-17:** admin possui origem e política de sessão mais restritas.
- **RNF-18:** mensagens em tempo real possuem sequência e idempotência por cliente.
- **RNF-19:** toda corrida expiração/cancelamento/webhook preserva a unicidade da unidade e do efeito financeiro.
- **RNF-20:** inbound de e-mail valida assinatura, timestamp, thread, remetente e replay antes da persistência.
- **RNF-21:** fluxos de direitos do titular possuem SLA, trilha, segregação de terceiros e exportação segura.
- **RNF-22:** gráficos possuem equivalente textual/tabular testado com teclado e leitor de tela.
- **RNF-23:** checkout hospedado mantém escopo PCI aplicável documentado e nenhum PAN/CVV no Midas.
- **RNF-24:** relatório financeiro diferencia obrigação PSP/terceiros de receita própria e fecha por moeda.
- **RNF-25:** política pública e comprovante de contratação permanecem versionados, conserváveis e acessíveis.

18. Métricas

Funil protegido

- busca → anúncio aberto;
- anúncio → chat/proposta;
- proposta → checkout;
- checkout → pagamento confirmado;
- pago → confirmação bilateral;
- conclusão → saldo liberado;
- tempo e abandono por etapa/motivo.

Oferta e operação

- rascunho abandonado;
- aprovação na primeira submissão;
- SLA e motivos de moderação;
- tempo até primeira venda;
- disponibilidade por canal;
- pedidos presos por estado/idade;
- divergência PSP/ledger;

- holds vencidos não liberados;
- pagamentos tardios por resultado: reassumido, refundado, divergente e tempo de resolução;
- falha/tempo de saque;
- tickets fora de SLA e reabertura.

Confiança

- disputa/chargeback/reembolso por 100 pedidos;
- tempo de disputa, decisão split, recurso e taxa de reversão;
- PII bloqueada, reincidência e recurso procedente;
- falso positivo do detector;
- conta comprometida;
- decisão administrativa revertida;
- segredo detectado fora do cofre: objetivo zero.

Dados e recomendação

- cobertura e frescor de preço;
- lacunas de histórico;
- zero-result rate;
- diversidade por vendedor/item;
- conversão incremental com guarda de disputa/reclamação;
- ativo sem proveniência ou licença: objetivo zero publicado.
- cadastros de vendedor pendentes/rejeitados por motivo e tempo;
- prova de posse vencida, revalidação falha e compra bloqueada antes de cobrança;
- solicitações de titular dentro/fora do SLA;
- usuários com personalização desligada e tempo de limpeza do perfil;
- cobertura da alternativa acessível ao gráfico: objetivo 100%.

19. Anti-métricas

Não otimizar isoladamente:

- GMV bruto;
- tempo no site;
- quantidade de mensagens ou banimentos;

- CTR sem transação protegida;
- velocidade de aprovação sacrificando qualidade;
- liberação sacrificando risco;
- escassez/urgência sem fato;
- exposição que favorece Midas escondendo oferta P2P melhor;
- concentração de recomendação;
- tickets fechados rapidamente e reabertos.

20. Questões que bloqueiam contrato técnico final

1. PSP, métodos, moeda, países, taxas e limites.
2. Recebedor, split/subconta, reserva e saldo negativo.
3. Autorização escrita da Axlebolt para comércio externo e entrega.
4. Fonte autorizada de catálogo, PNG, preço e histórico.
5. Mecanismo oficial de transferência/entrega.
6. Cadência mínima que poderá ser chamada “tempo real”.
7. Evidência aceita e prazos de disputa.
8. Regra para inatividade de uma parte; recomendação MVP: sem confirmação automática.
9. Janela e expiração de strikes.
10. Contatos bloqueados além de telefone, e-mail, nick, Pix e redes.
11. WhatsApp por texto, deep link ou integração oficial.
12. Retenção de sinais de recomendação e dispositivo.
13. Provedor de e-mail, domínios e aliases.
14. Passkey obrigatória para quais perfis.
15. Valores que exigem maker-checker.
16. Aprovação do próprio estoque Midas.
17. Conteúdo editável pelo Master/CMS.
18. Comissão P2P versus Midas.
19. SLAs de moderação, entrega, disputa, suporte e saque.
20. Idade mínima, identidade do vendedor e KYC aplicável.
21. Bases legais, transparência e direitos do titular.
22. Papel contratual e financeiro da Midas em cada fluxo: marketplace/intermediadora, merchant of record, agente de cobrança ou outro enquadramento aprovado.
23. Escopo PCI DSS, modelo de checkout hospedado/tokenizado e responsabilidades entre Midas e PSP; PAN/CVV não podem entrar nos sistemas Midas.

24. Documento fiscal de venda/comissão, responsável pela emissão, eventos tributáveis, retenções e relatórios exigidos por jurisdição.
25. Método de garantia de idade, eventual consentimento do responsável e tratamento regional de menores.
26. Papéis de controlador/operador, canal do encarregado, SLAs por direito LGPD, retenção, fornecedores e transferência internacional.
27. TTL e fonte de verdade do PSP para expiração, cancelamento e liquidação tardia; regra comercial de reaquisição ou reembolso.
28. Forma autorizada, validade e cadência de revalidação da prova de posse/disponibilidade do item.
29. Critérios, periodicidade e provedor de KYC/KYB, titularidade do destino de recebimento e tratamento de revalidação/reprovação.

21. Critério de prontidão

O PRD está pronto para implementação quando:

- dependências críticas de publicador, preço, ativos, pagamento, entrega e categoria de conta estão resolvidas;
- estados e transições não possuem caminho órfão;
- RBAC/ABAC, maker-checker e segregação financeira foram aprovados;
- modelo PSP, enquadramento contratual, fiscal/contábil e escopo PCI foram aprovados;
- onboarding do vendedor, KYC/KYB, destino de recebimento e prova autorizada de posse/disponibilidade foram contratados;
- exceções de pagamento, liquidação tardia, disputa, recurso, split/refund e hold foram contratadas;
- idade mínima/garantia de idade, direitos LGPD, cookies e personalização opt-out foram aprovados;
- uma matriz gerada automaticamente liga cada RF MVP a superfície, contrato/domínio, evento/estado e evidência de aceite, sem RF nem artefato órfão;
- ameaça P0 possui controle e teste;
- fontes e direitos estão registrados;
- piloto financeiro, procedimento operacional e políticas públicas versionadas foram aprovados.

Status atual: NO-GO. O gate **G4 — Domínio permanece PENDENTE** até a geração automatizada e a revisão da matriz por requisito. A matriz manual abaixo cobre todos os intervalos de RF e fornece ligações representativas, mas não comprova rastreabilidade perfeita nem substitui testes, contratos ou revisão humana.

22. Matriz de rastreabilidade por blocos

Esta matriz oferece cobertura contínua de **RF-001** a **RF-180**. As ligações de cada linha são representativas do bloco; o detalhamento automatizado um-a-um exigido por G4 ainda deve demonstrar, para cada RF, superfície, contrato/domínio, evento/estado, teste e responsável.

RFs	Superfícies principais	Contrato/domínio	Estado ou evento principal	Evidência de aceite representativa	Épico
RF-001-010	/entrar , /cadastro , /conta/seguranca , /admin/confianca	identidade, sessão, passkey/MFA, device trust	sessão/dispositivo confiável, desafiado ou revogado	BOLA/IDOR, step-up, revogação e recuperação testados	E2, E3
RF-011-018	/admin/catalogo , /itens/:slug	catálogo, taxonomia, mídia e proveniência	item/adesivo/ativo em rascunho, aprovado, desativado	importação idempotente, licença/proveniência e fallback visual	E4
RF-019-036	/vender/novo , /vender/anuncios , /anuncios/:id	anúncio, craft, conta condicional e cofre	RASCUNHO → EM_REVISAO → PUBLICADO ou correção/rejeição	cenários de craft, quatro slots e conta bloqueada em Standoff 2	E5
RF-037-043	/admin/anuncios , /admin/usuarios	fila de moderação, checklist e decisão	aprovado, correção solicitada, rejeitado	motivo obrigatório, permissão atômica e impedimento de autoaprovação	E5, E14
RF-044-052	/ , /market , /midas , /buscar	busca, ranking, recomendação e diversidade	busca/visualização/favorito/compra alimentam ou não o perfil conforme preferência	relevância, diversidade, explicação e fallback não personalizado	E6, E15
RF-053-062	/itens/:slug , /anuncios/:id	cotação, histórico, frescor e proveniência	preço atual, atrasado ou indisponível	fonte/data visíveis, sem total enganoso de craft e alternativa tabular/textual	E7
RF-063-076	/mensagens , /anuncios/:id , /admin/confianca , /conta/recurso	conversa, proposta, anti-PII, strikes e restrição	mensagem aceita/bloqueada; conta advertida/restrita/em recurso	testes adversariais de PII/ofuscação, concorrência de strikes e recurso	E8
RF-077-090	/checkout/:intentId , /pedidos/:id/entrega , /conta/compras , /conta/vendas	reserva, pedido, pagamento, entrega e segredo pós-pagamento	reserva/pagamento/pedido conforme máquinas da seção 14	webhook assinado e idempotente, revelação somente após pagamento válido e dupla confirmação	E9, E11
RF-091-102	/conta/carteira (alias), /conta/saques , /admin/financeiro	ledger, hold, conciliação, saldo de vendas e payout via PSP	PENDENTE → EM_HOLD → DISPONIVEL → SAQUE_SOLICITADO → PAGO	partidas balanceadas, reconciliação, retry/idempotência e nenhum PAN/CVV	E10, E12
RF-103-109	/midas , /admin/midas	estoque próprio, preço e identificação do canal	item Midas disponível, reservado, vendido ou retirado	separação P2P/Midas, transparência do operador e estoque consistente	E6
RF-110-120	/conta/suporte , /admin/suporte	tickets, inbox, threading, anexos e SLA	ticket aberto, em atendimento, aguardando, resolvido/reaberto	e-mail↔ticket sem duplicidade, isolamento de anexos e segredo redigido	E13
RF-121-132	/admin , /master , /master/auditoria	IAM administrativo, grants, configuração, feature flag e auditoria	concessão/revogação e mudança versionada	menor privilégio, maker-checker, log imutável e break-glass auditado	E14

RFs	Superfícies principais	Contrato/domínio	Estado ou evento principal	Evidência de aceite representativa	Épico
RF-133-138	/conta , /admin , canais de notificação	notificação, outbox e analítica de produto	evento transacional gera entrega, retry ou dead-letter	deduplicação, preferência de canal e eventos sem PII/segredo indevido	E13, E15
RF-139-148	/pedidos/:id/entrega , /conta/recurso , /admin/pedidos , /admin/financeiro	disputes, evidence, decisions, appeals e execução financeira	ABERTA → EVIDENCIAS → EM_REVISAO → DECIDIDA → EXECUTADA → ENCERRADA , com recurso	TTL, acesso bilateral, decisão BUYER / SELLER / SP LIT , refund/split idempotente e recurso	E11
RF-149-157	/vender/cadastro , /vender/novo , /admin/usuarios , /admin/anuncios	seller onboarding, KYC/KYB, payout destination, ownership proof e capabilities	vendedor pendente/aprovado/rejeitado/suspensão; prova válida/vencida	gates de elegibilidade, titularidade do destino, revalidação no checkout e craftEligible	E0, E5
RF-158-166	/cadastro , /conta/privacidade , /conta/preferencias	age assurance, privacy, consent/preferences e data-rights	idade pendente/verificada/reusada; solicitação LGPD recebida/validada/atendida	defaults protetivos, exportação/correção/eliminação e limpeza do perfil no opt-out	E0, E2, E15
RF-167-169	/admin/suporte , webhook de e-mail	inbound email, assinatura, replay defense, thread token e quarantine	mensagem aceita, rejeitada ou em quarentena	assinatura/timestamp /nonce, remetente autorizado, token escopado/expirável e replay bloqueado	E13
RF-170-175	/itens/:slug , /anuncios/:id , /checkout/:intentId , /admin/financeiro , rotas públicas	acessibilidade, policy snapshot, recibo, fiscal e contabilidade	política/oferta congelada por versão; documento fiscal pendente/emitido/falho	tabela equivalente ao gráfico, aceite versionado, taxas claras e separação entre obrigação PSP e receita Midas	E0, E7, E10, E16
RF-176-180	/checkout/:intentId , /admin/financeiro	payment intent, reservation, late-payment exception e refund	CANCELAMENTO_PENDENTE / PAYMENT_QUARENTINED / REEMBOLSO_PENDENTE até desfecho	corrida P0 entre expiração e webhook, reaquisição atômica ou reembolso idempotente, sem dupla venda	E9, E10, E16

Saída exigida para fechar G4: artefato gerado no pipeline que expanda as linhas acima para RF-001 a RF-180 , falhe em RF/tela/API/evento/estado/teste órfão e seja revisado por Produto, Engenharia, Segurança, Operações e Financeiro. Até essa evidência existir, esta matriz é um scaffold de handoff, não um sign-off.

UML E ARQUITETURA — MIDAS MARKETPLACE

1. Decisão arquitetural

Estilo

Começar como **monólito modular orientado a domínios**, com três processos implantáveis:

1. API HTTP/BFF.
2. Gateway de chat em tempo real.
3. Workers assíncronos.

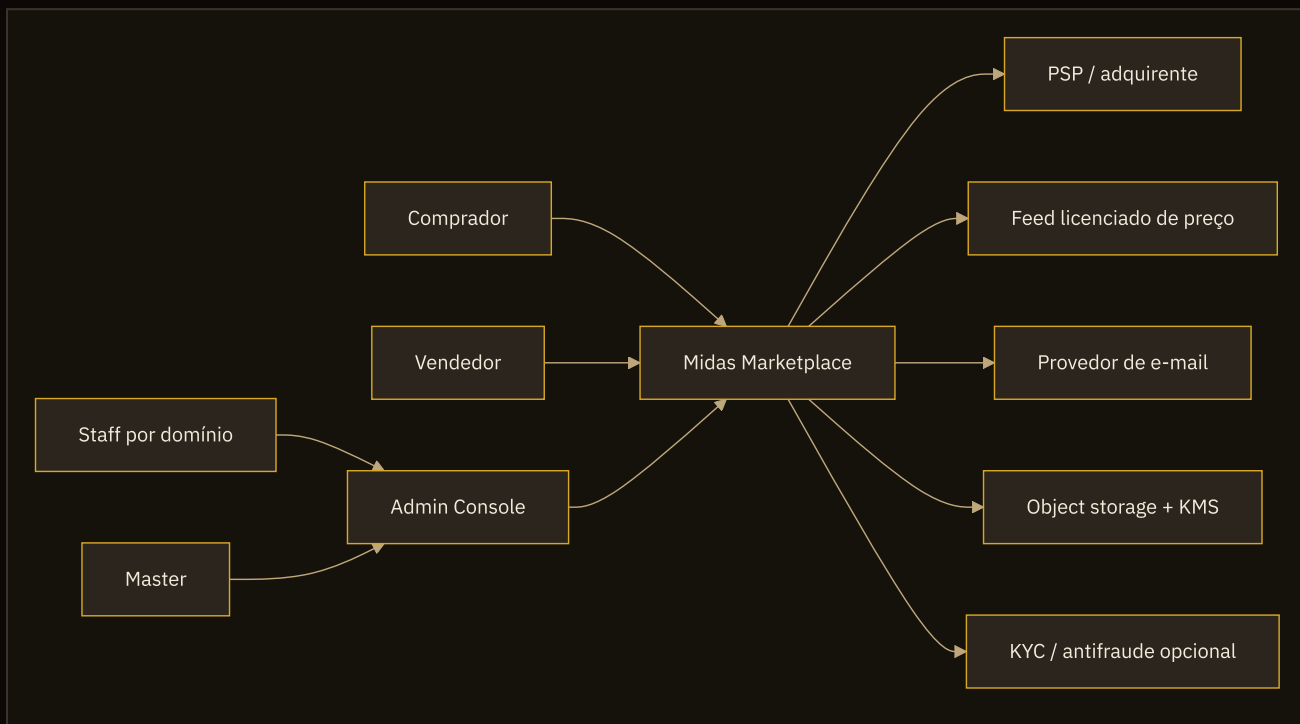
Essa decisão mantém transações e evolução simples no MVP. Limites de domínio, schemas, eventos e permissões já preparam extrações futuras. Microserviços prematuros aumentariam falhas distribuídas justamente nos fluxos de dinheiro e estado.

Fundamentos

- PostgreSQL é a fonte canônica.
- Redis atende sessão, cache, presença e rate limit; não é fonte de verdade.
- Broker recebe eventos com entrega pelo menos uma vez.
- Outbox/inbox transacional e consumidores idempotentes evitam perda/duplicação.
- OpenSearch é projeção de busca, reconstruível.
- Object storage guarda mídia; KMS/Secrets Manager guarda chaves e segredos.
- Ledger é append-only, partidas dobradas e isolado por schema/credencial.
- PSP movimenta dinheiro real; Midas orquestra e registra obrigações.
- Preço entra somente por adaptador público/documentado/licenciado.
- Expiração de reserva, cancelamento do pagamento e reativação do anúncio formam uma única invariável entre agregados: o anúncio só volta a **ACTIVE** depois que o PSP confirmar canonicamente o intent como cancelado/expirado.

- Settlement tardio nunca libera entrega diretamente: entra em **PAYMENT_QUARANTINED** e só sai por reassociação atômica segura ou reembolso confirmado.

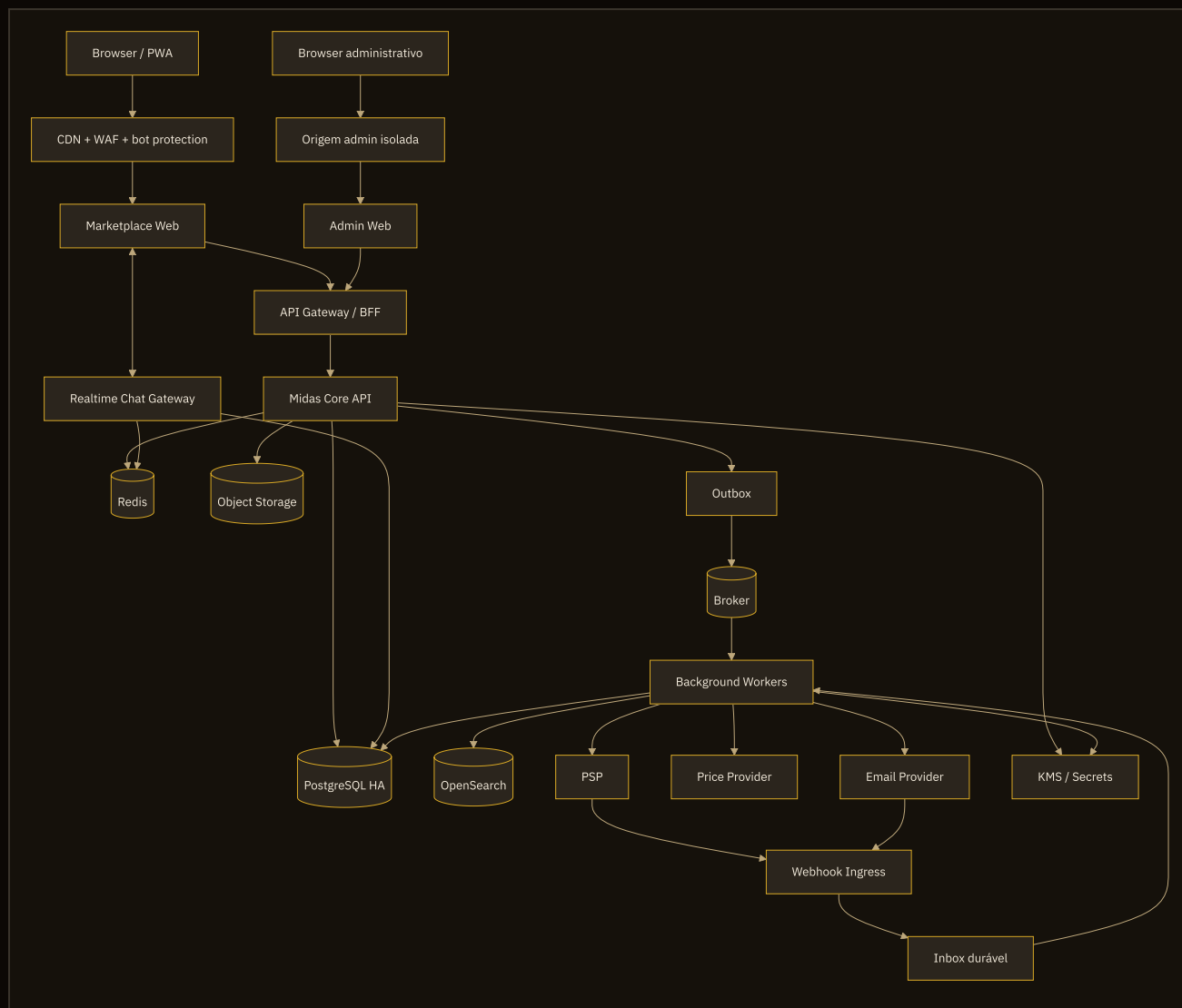
2. Contexto do sistema



Responsabilidades externas

Sistema	Responsabilidade
PSP	checkout, tokenização, Pix/cartão, captura, reembolso, chargeback, KYC/subconta e payout conforme contrato
Feed de preço	IDs, observações/candles em gold, proveniência, limites e licença
E-mail	envio, inbound parse, bounce, complaint e autenticação de domínio
Storage/KMS	objeto versionado, URLs assinadas, envelope encryption e rotação
KYC/risco	validação adicional quando política/PSP exigir

3. Containers



Admin usa CSP, origem, cookie, step-up e duração de sessão mais restritivos do que o marketplace público.

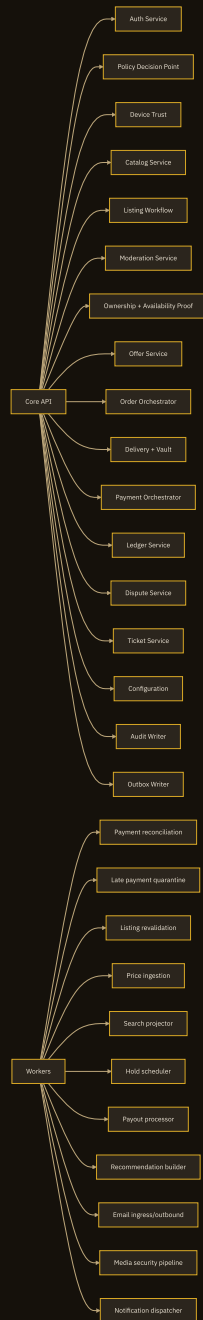
4. Bounded contexts

Contexto	Dados próprios e responsabilidade
Identity	usuário, credencial, passkey, MFA, recuperação e sessão
IAM	roles, permissions, grants, política ABAC e delegação
Device Trust & Risk	vínculos, desafios, sinais, confiança e decisão
Catalog	ítems, versões, stickers, taxonomia, imagens e proveniência

Contexto	Dados próprios e responsabilidade
Listings & Moderation	rascunho, revisão, craft, prova de posse/disponibilidade, decisão, publicação e reserva
Offers & Conversation	sala pré-compra, mensagens, propostas e moderação
Market Data & Pricing	instrumentos, observações, candles, cotação e qualidade
Search & Discovery	índice, filtros, ranking e tombstones
Recommendation	eventos, afinidade, candidatos, ranking e impressão
Orders & Delivery	pedido, unidade, template de pronta-entrega, pacote consumido, sala, confirmações e cofre
Payments	intent, tentativa, evento PSP, refund e chargeback
Ledger & Payouts	journal, posting, lote, hold, saldo e saque
Disputes & Reputation	disputa, evidência, decisão, recurso, reputação e sanção
Support & Mailbox	ticket, thread, e-mail, SLA e anexo
Notifications	e-mail transacional, inbox e push futuro
Administration	configuração tipada, flags, console, seller onboarding e emergência
Audit & Compliance	evento auditável, retenção, exportação, restrição/recurso e direitos do titular

Regra: cada contexto escreve somente suas tabelas. Outros contextos recebem IDs e eventos versionados; não alteram cópias internas.

5. Componentes do backend



- UUIDv7 ou equivalente ordenável.
- `timestampz` UTC.
- Dinheiro: `amount_minor bigint + currency char(3)`.
- Gold: `numeric(20,4)`, jamais no ledger fiduciário.
- Proibido `float` para valor.

- `version bigint` para concorrência otimista.
- JSONB somente com schema validado.
- Mudança de configuração não altera snapshot do pedido.
- Sem soft delete universal; usar estado, tombstone e anonimização seletiva.

Invariantes

SellerAccount e onboarding

- `INDIVIDUAL` possui exatamente um membership `OWNER`; `ORGANIZATION` e `PLATFORM` possuem um ou mais membros;
- permissões de venda são avaliadas sobre usuário, membership e seller account;
- somente seller account com onboarding `APPROVED` e sem restrição pode submeter ou publicar;
- quando possível, documentos financeiros/KYC ficam no onboarding hospedado do PSP; Midas guarda apenas IDs, estado e evidência mínima.

Listing

- um anúncio ativo representa uma unidade vendável;
- um índice único parcial garante uma reserva ativa por anúncio;
- cada `Reservation` referencia o `PaymentIntent` que precisa ser encerrado antes de liberar a unidade;
- vendido não volta a ativo; revenda cria outro anúncio;
- alteração material cria nova revisão;
- `channel=MIDAS` usa seller account da plataforma e rotulagem pública.
- submissão exige `OwnershipProof` obtida por meio autorizado, com checksum, proveniência, validade e decisão auditada; nunca senha do jogo nem endpoint privado;
- disponibilidade é revalidada antes da aprovação, na publicação, periodicamente enquanto ativo e imediatamente antes da reserva; prova expirada move o anúncio para `SUSPENDED_REVALIDATION`;
- reserva vencida entra em `EXPIRY_PENDING`; o anúncio permanece indisponível até o PSP confirmar canonicamente o intent como `CANCELED` ou `EXPIRED`;
- somente a transação que registra esse cancelamento canônico pode finalizar o pedido como expirado/cancelado e devolver o anúncio a `ACTIVE`.

Craft

- `NONE` possui zero `CraftSlot`;
- `CRAFT` possui exatamente quatro posições únicas `1..4`;
- `CRAFT` só é válido quando o item base é `SKIN`, está ativo e possui `craftEligible=true` na versão congelada do catálogo;
- cada item selecionado é `STICKER` ativo;
- ao menos uma posição preenchida;
- pedido congela nome, imagem, ID e preço gold observados.

Pronta-entrega

- `SecureDeliveryTemplate` pertence simultaneamente à `ListingRevision` publicada e à unidade vendável; revisão ou unidade diferente não pode reutilizá-lo;
- aprovação congela `contentHash` , `ciphertextHash` , versão da política e envelope KMS do template;
- após settlement regular, uma única transação bloqueia unidade/template/pedido, verifica vínculo e hash, marca o template como consumido e cria um `SecureDeliveryPackage` imutável para aquele pedido;
- índice único em `templateId` consumido e em `orderId` impede dupla entrega; falha transacional não consome o template;
- settlement tardio em `PAYMENT_QUARANTINED` não consome template nem abre sala; consumo só ocorre depois de reassociação atômica bem-sucedida e novo evento canônico;
- produtos Standoff 2 mantêm `credentialDeliveryAllowed=false` : login, senha, token, cookie ou recovery code são rejeitados no servidor. O template pode conter apenas instrução permitida e contato pós-pagamento.

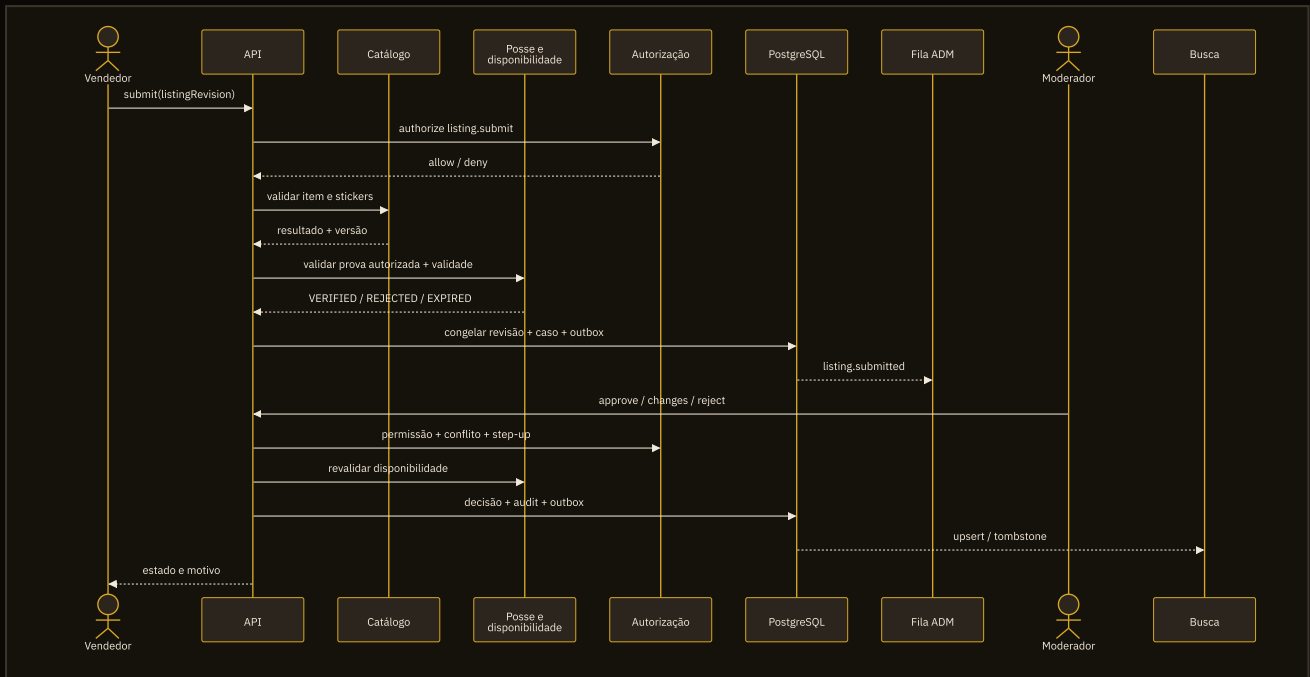
Order

- um anúncio por pedido no MVP;
- comprador e vendedor são derivados da sessão/anúncio;
- snapshot inclui oferta, craft, fees, política de hold e contato liberável;
- confirmações são registros independentes únicos por papel.
- pedido só se torna `PAID` a partir de settlement persistido e journal balanceado; `FAILED` , `EXPIRED` , `REFUNDED` e `CHARGEBACK` possuem saídas explícitas nas máquinas abaixo;
- evento tardio para pedido cancelado/expirado entra em `PAYMENT_QUARANTINED` , sem entrega, notificação de sucesso ou consumo de pronta-entrega;
- resolução de quarantine bloqueia atômicamente payment, order, listing unit e reserva atual: se a unidade continua livre e sem comprador posterior, reassocia e conclui settlement; se não, solicita reembolso idempotente.

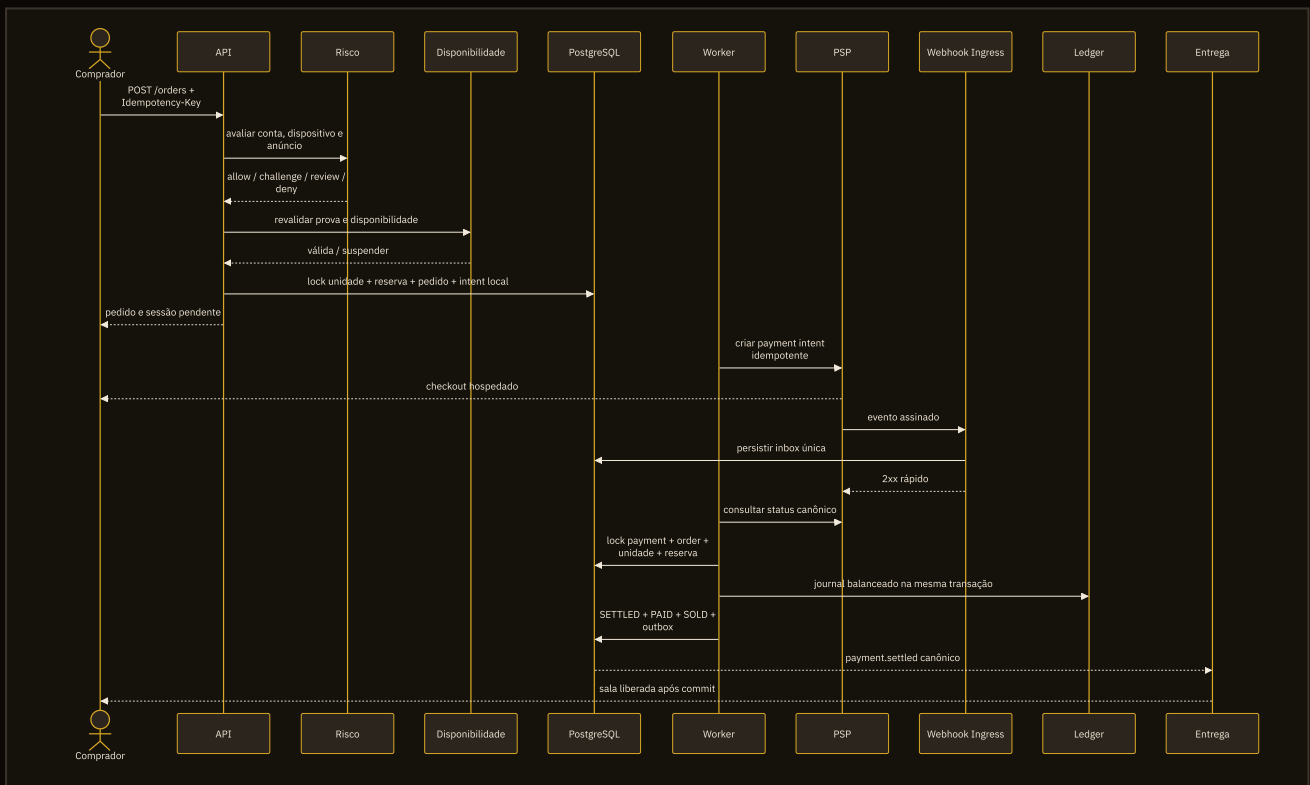
Ledger

- journal não é atualizado; correção usa reversão;
- dois ou mais postings somam zero por moeda;
- `postingKey` único evita duplicação;
- saldo é projeção do razão, nunca campo editável.
- payout `FAILED` ou `RETURNED` nunca desaparece nem vira `PAID` : segue para revisão e retry com nova `PayoutAttempt` , ou cancelamento com lançamento compensatório de `PAYOUT_IN_TRANSIT` / `PAYOUT_RESERVED` para `AVAILABLE` .

8. Sequência — anúncio e aprovação

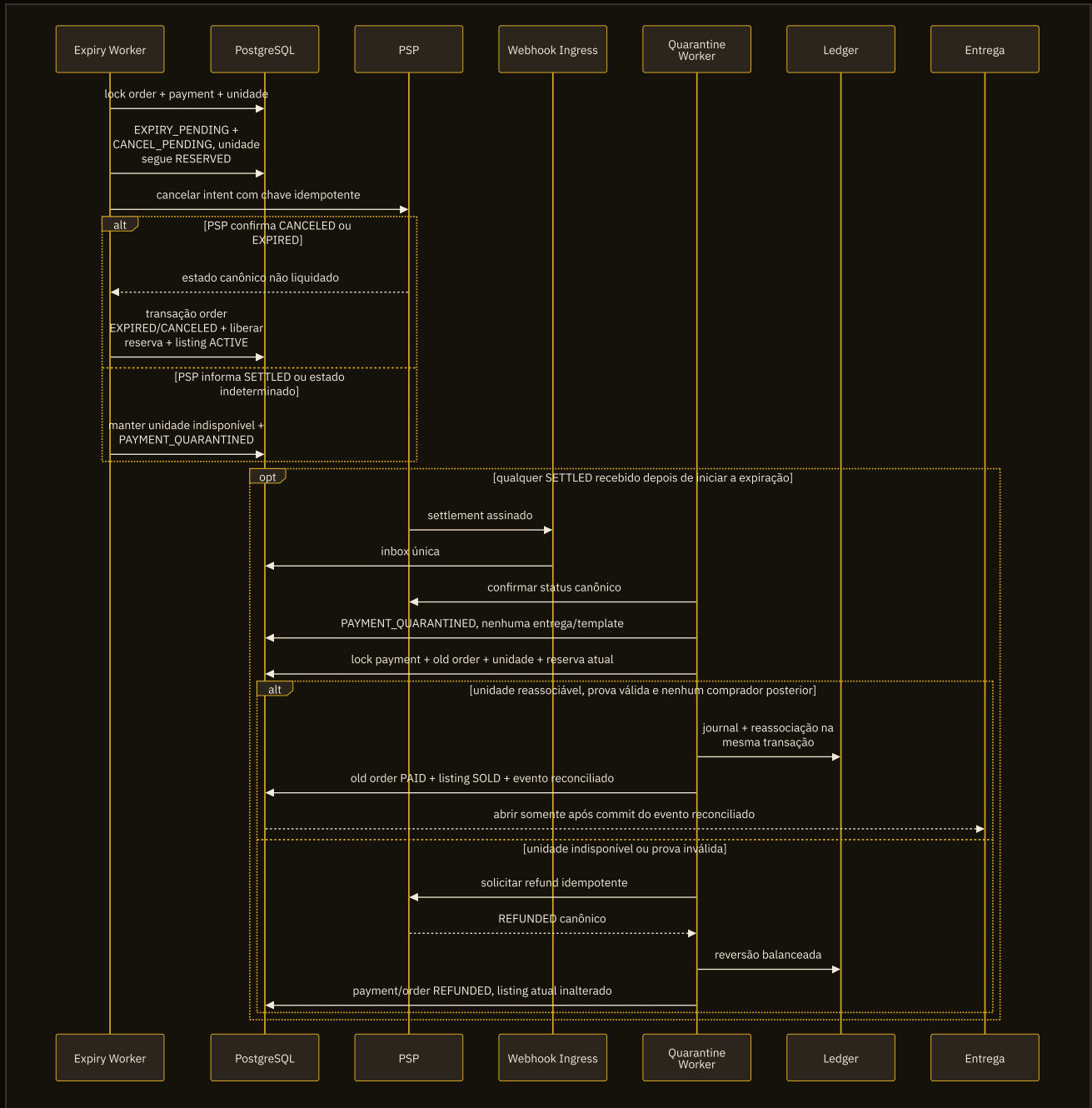


9. Sequência — compra e pagamento



Redirect do browser nunca confirma pagamento.

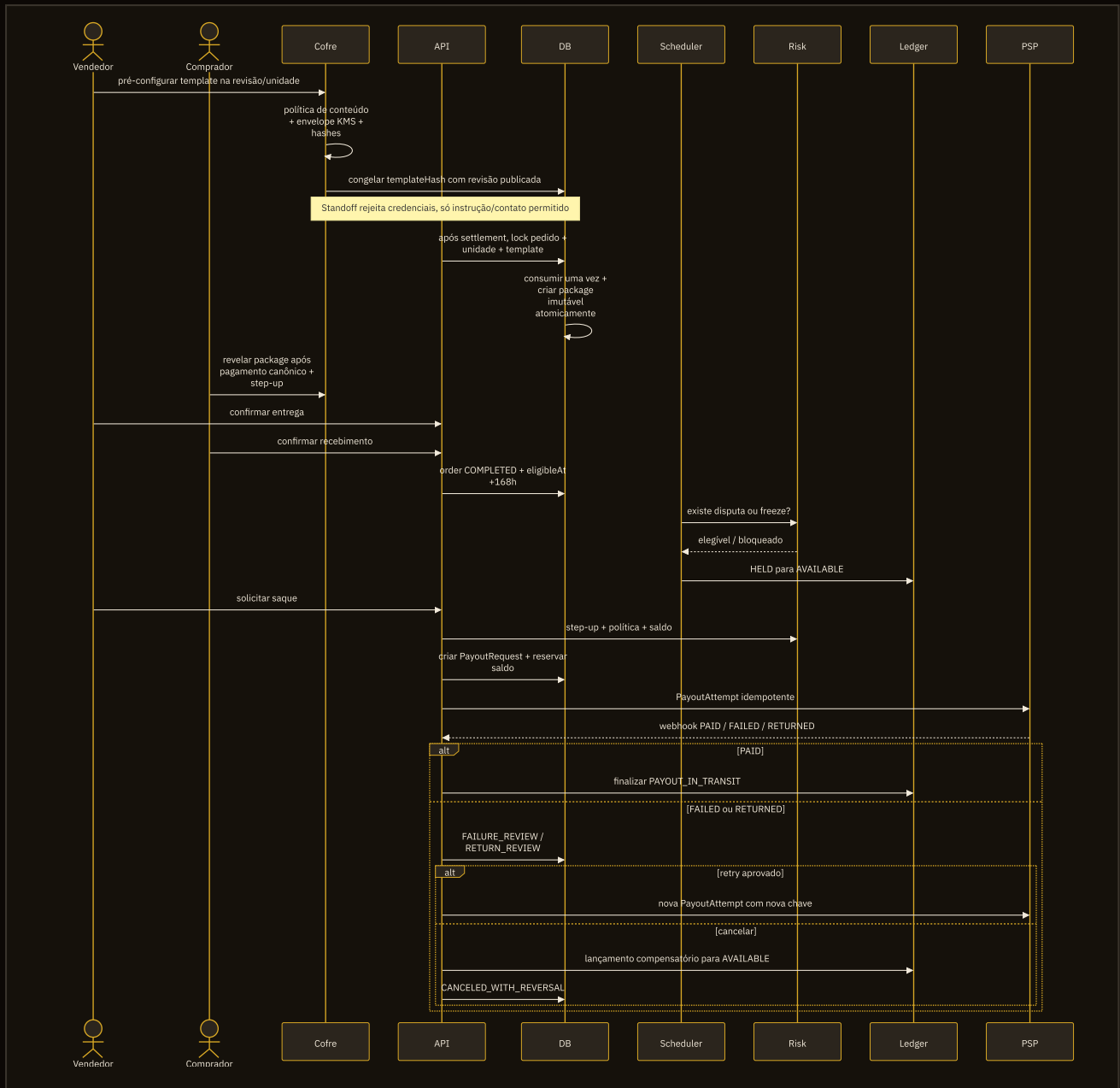
Corrida crítica — reserva expirada versus settlement tardio



PAYMENT_QUARANTINED nunca é gatilho de entrega. Apenas o evento pós-commit

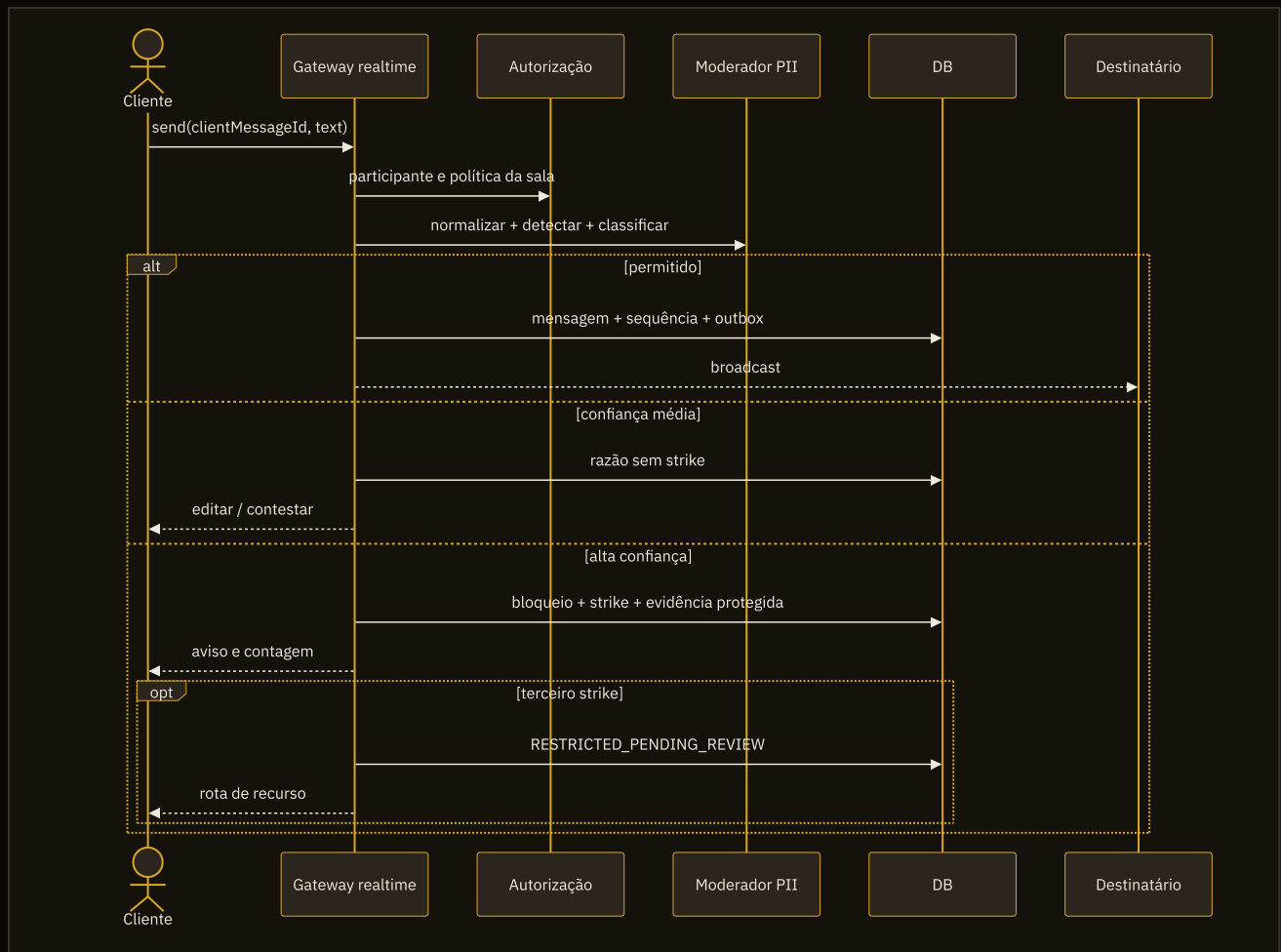
payment.quarantine_reassociated pode liberar a sala; se reassociação não for comprovadamente segura, o único caminho é reembolso ou revisão financeira com fundos congelados.

10. Sequência — entrega, hold e saque



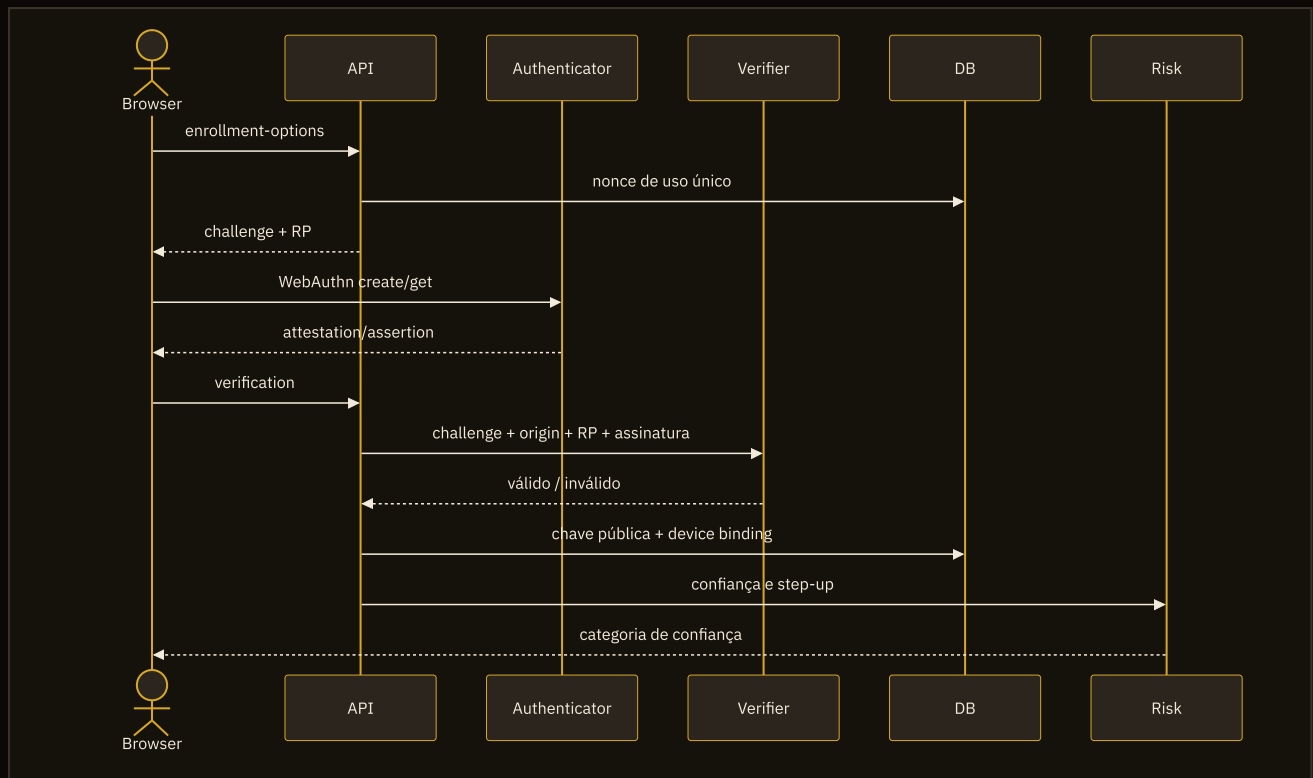
FAILED e **RETURNED** não são baixados como sucesso. Cada tentativa preserva provider ID, razão, timestamps e eventos; retry cria nova tentativa, e cancelamento só termina depois da reversão contábil idempotente.

11. Sequência — chat e PII

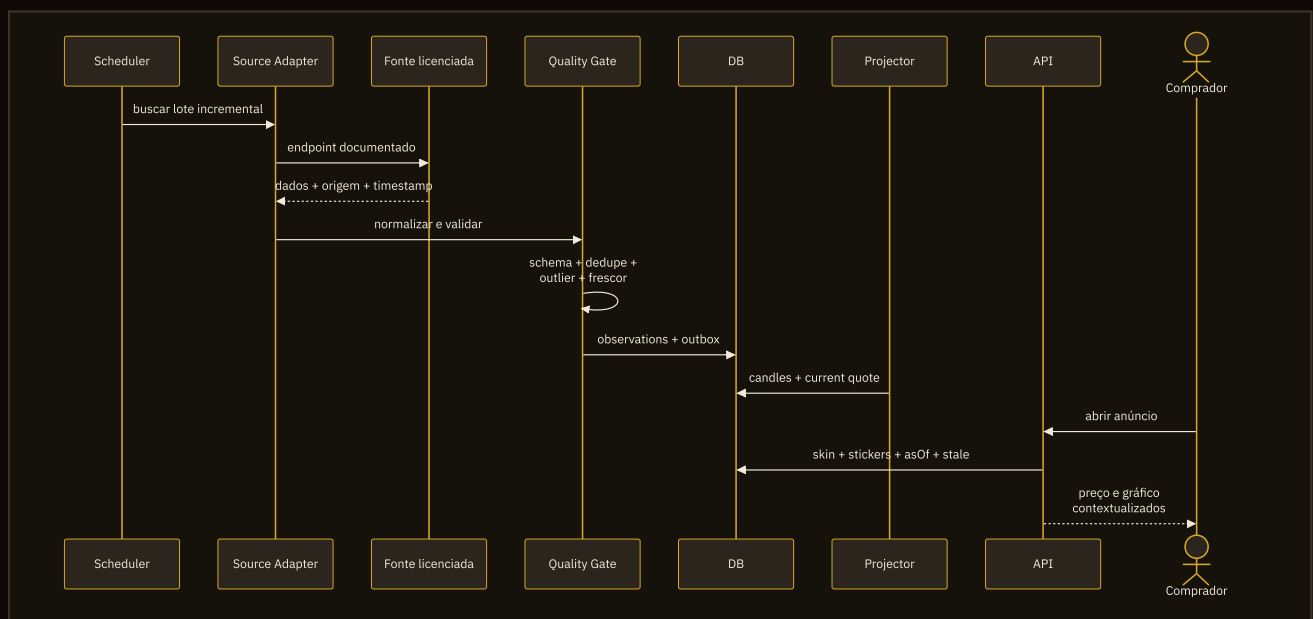


Pipeline: NFKC, remoção de zero-width, confusables, e-mail, telefone, URL, Pix, social, nick e leetspeak. Conteúdo bloqueado não entra em analytics/log operacional.

12. Sequência — dispositivo confiável

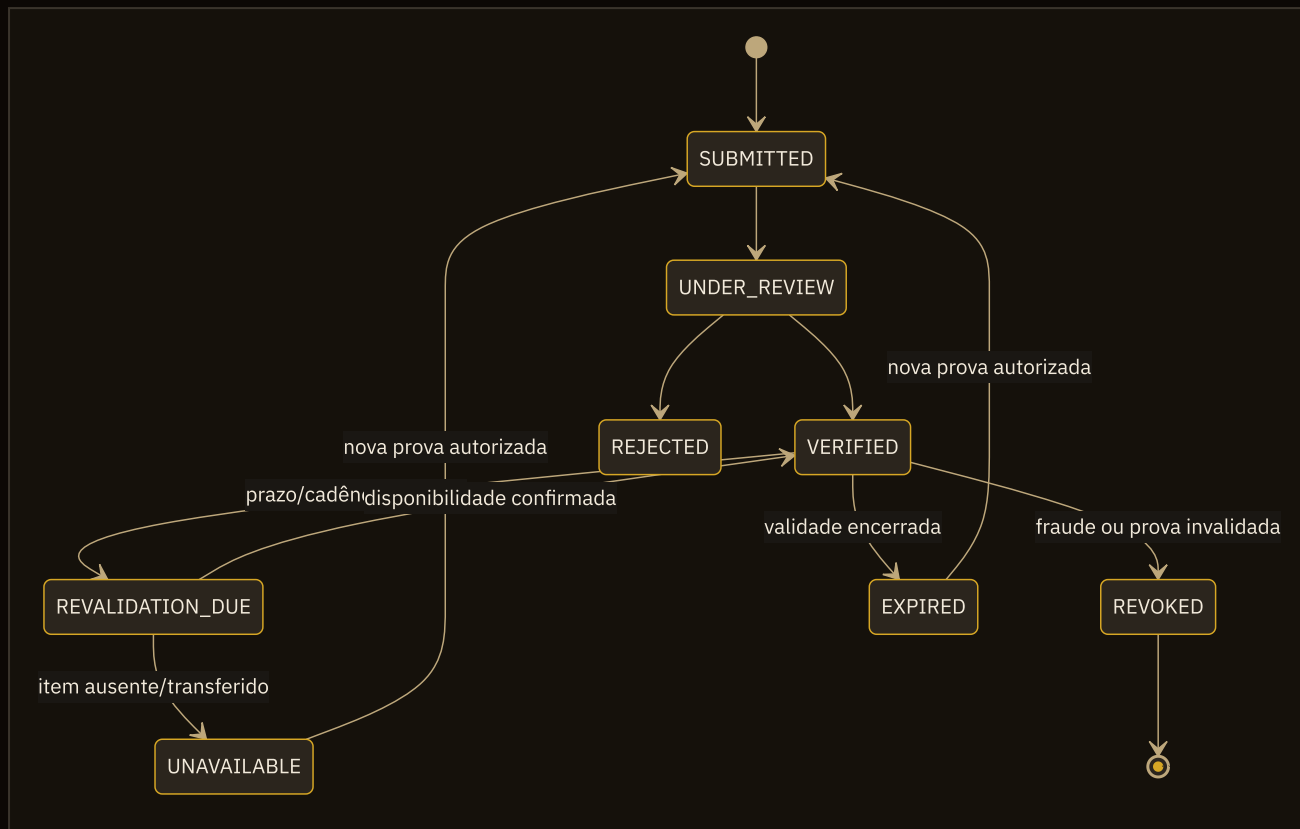


13. Sequência — ingestão de preço



Anúncio

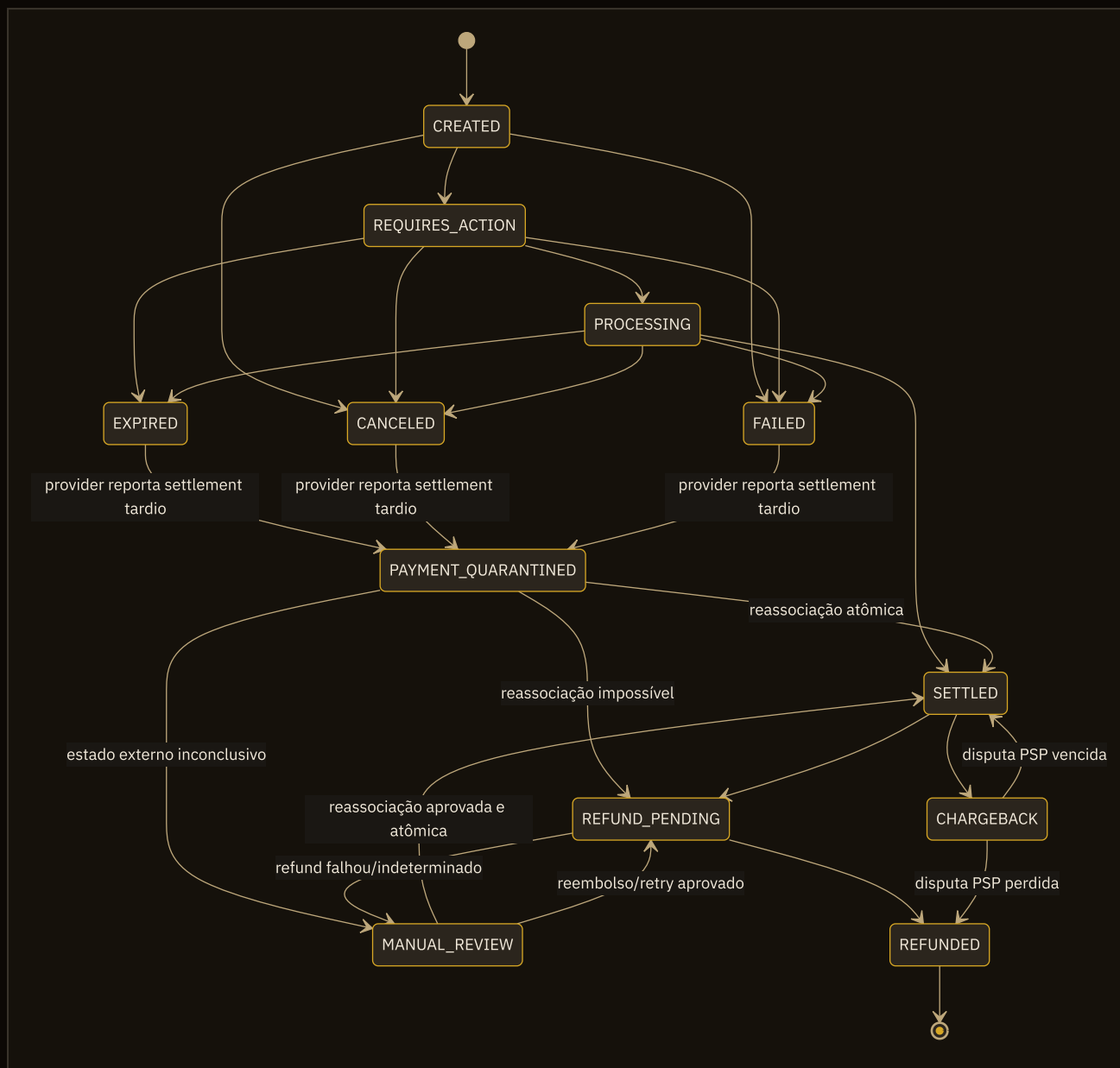
Prova de posse e disponibilidade



Somente **VERIFIED** permite publicar ou reservar. **OwnershipProof** contém evidência mínima e autorizada; confirmação automatizada só usa integração oficial/documentada.

Pedido e entrega

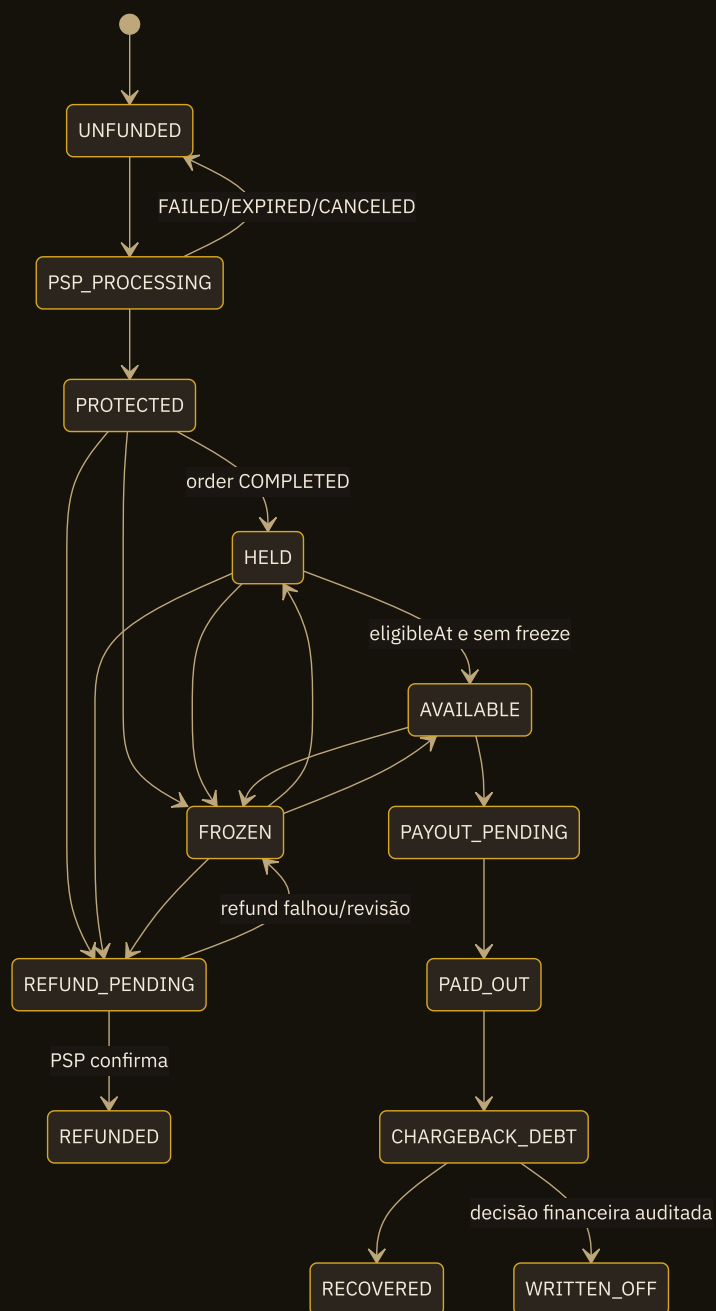
Pagamento / PaymentIntent



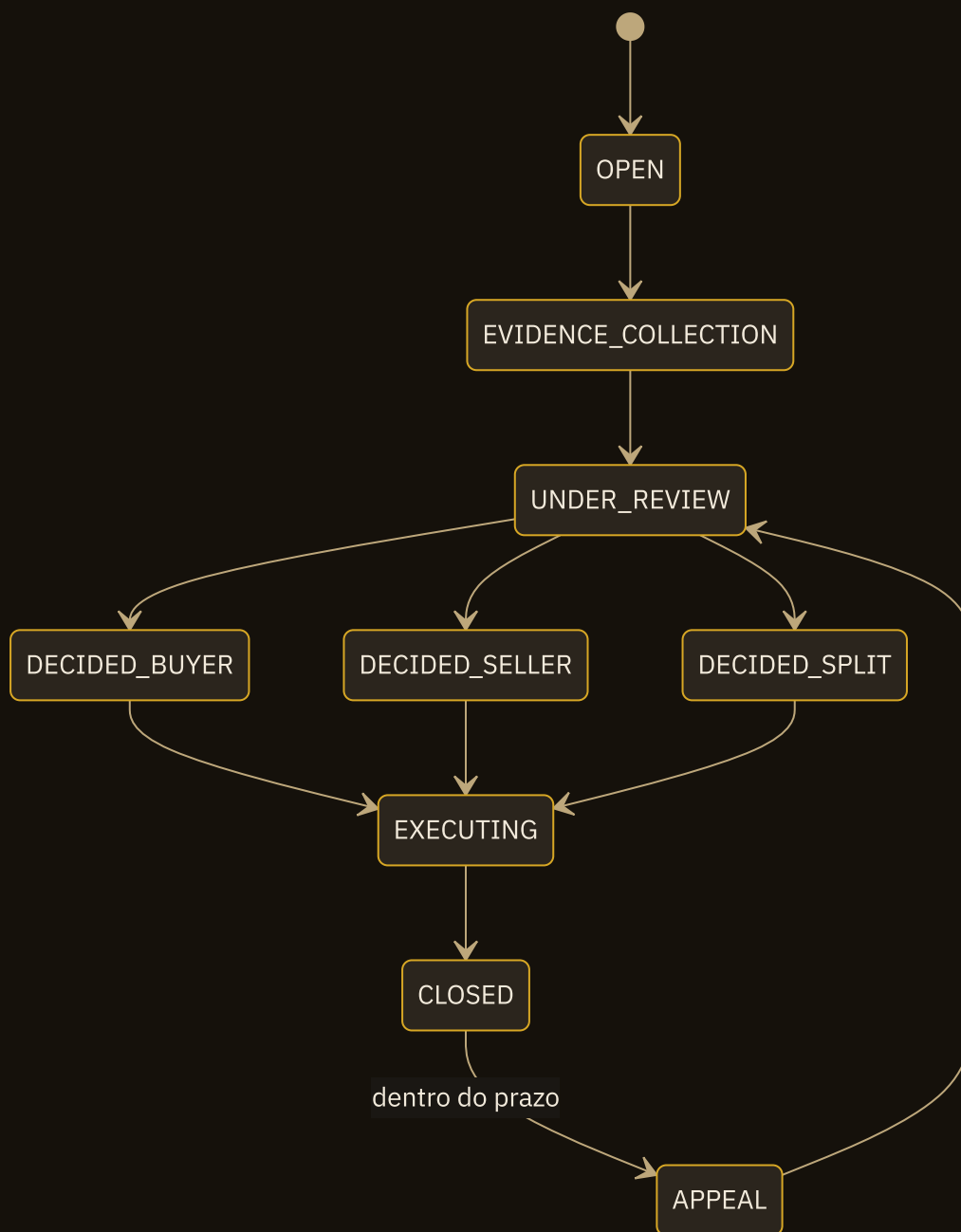
Estados terminais locais não impedem evento financeiro tardio: a inbox ainda aceita e deduplica webhooks, mas qualquer transição de **FAILED|EXPIRED|CANCELED** por settlement passa obrigatoriamente por **PAYMENT_QUARANTINED**.

Cada **PaymentIntent** mantém zero ou mais **PaymentAttempt**; retry cria tentativa nova sem apagar a anterior. Estado canônico vem do PSP, enquanto tentativas preservam request, provider ID, erro e idempotency key.

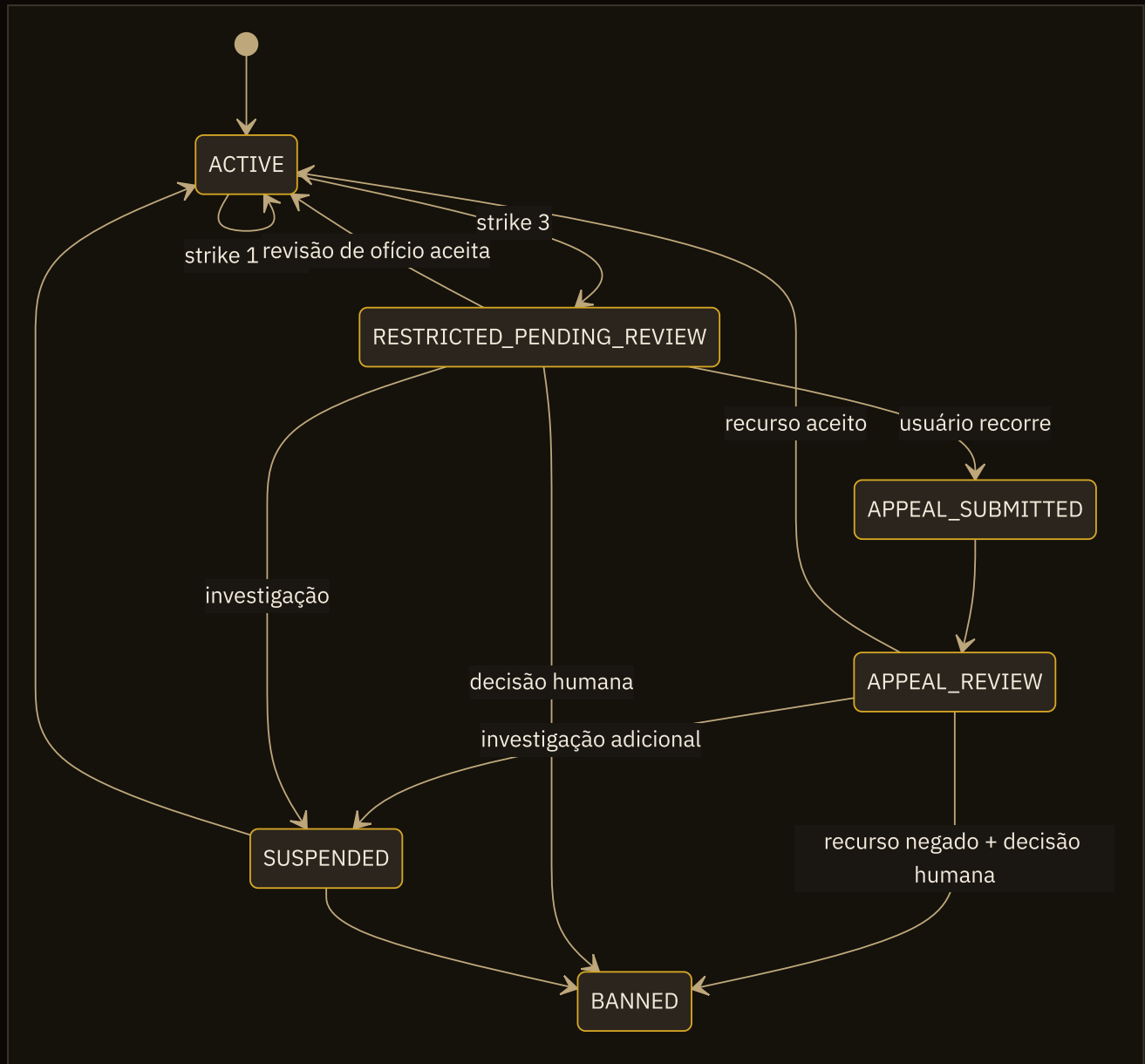
Fundos



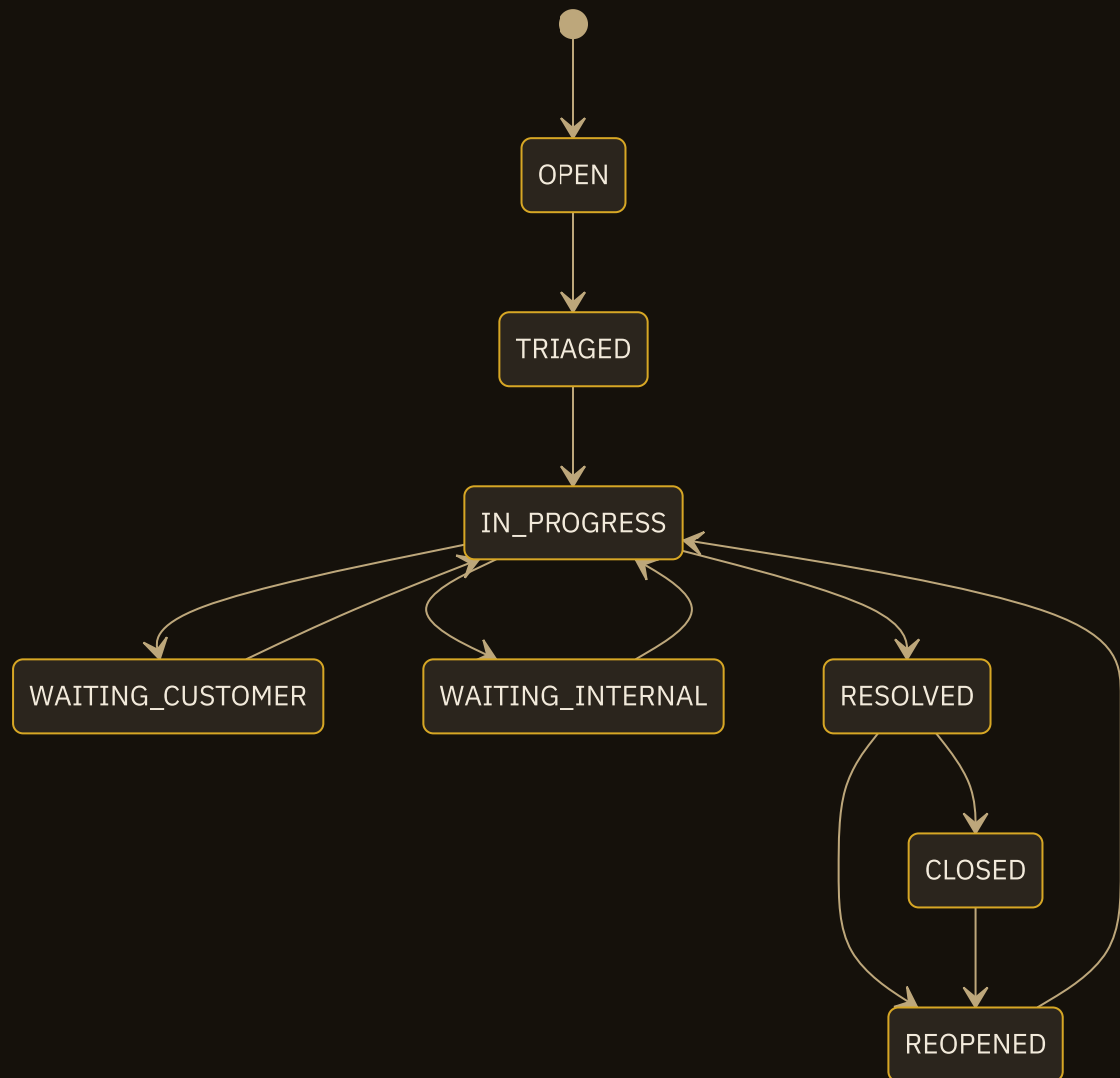
Disputa



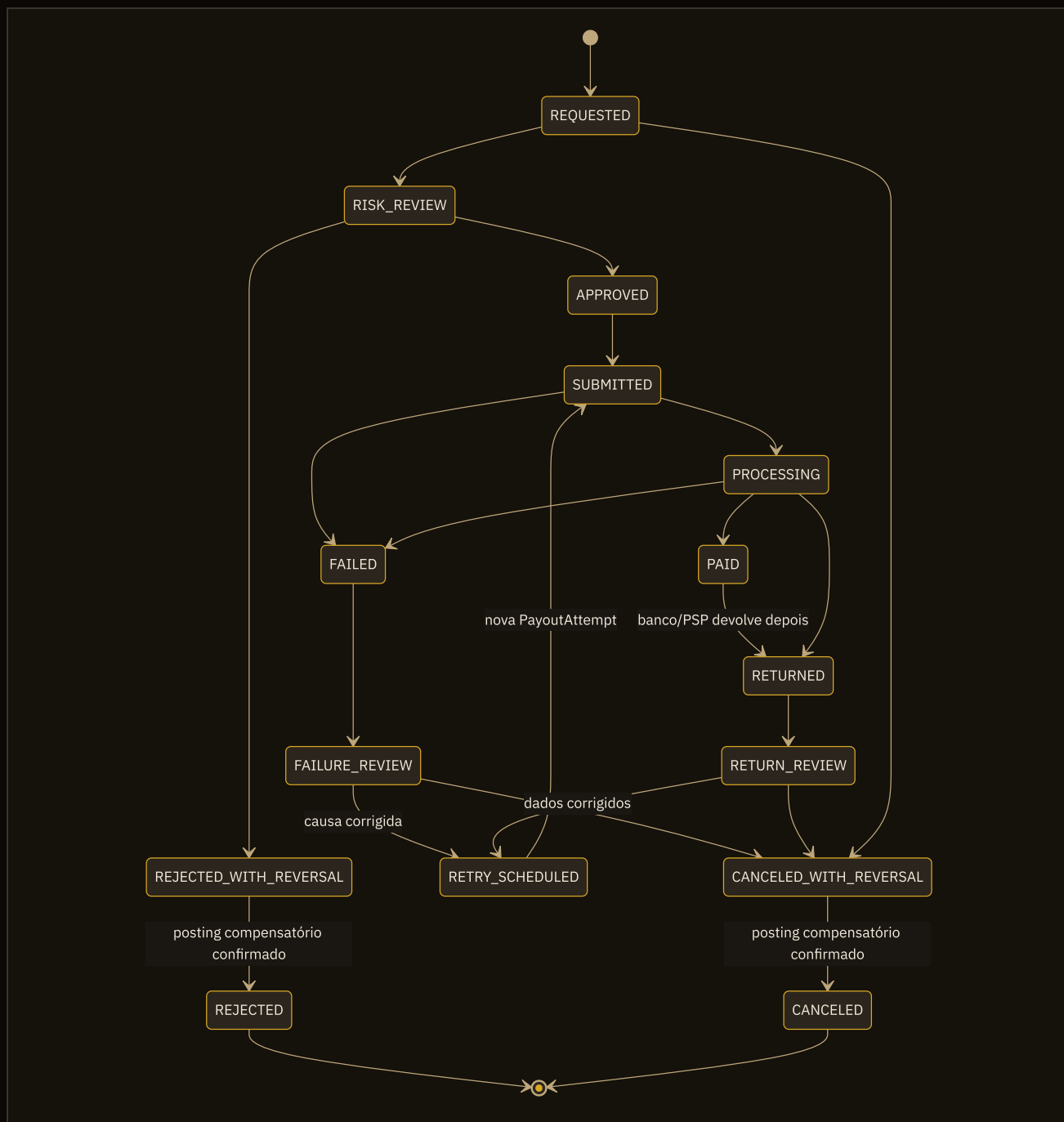
Restrição de conta



Ticket



Saque



FAILED e **RETURNED** são estados de tentativa, não autorização para criar saldo. Durante revisão, o valor continua reservado; retry cria nova **PayoutAttempt**. Cancelamento só termina depois da reversão idempotente para **SELLER_AVAILABLE**.

15. API REST proposta

Convenções

- `/v1`, JSON e OpenAPI 3.1.
- Erro `application/problem+json` com código estável e recuperação.
- Cursor pagination.
- `ETag/If-Match` em revisões/configuração.
- `Idempotency-Key` em pedido, pagamento, confirmação, reembolso e saque.
- `202 Accepted` para trabalho assíncrono.
- autorização por objeto e campo em toda rota.

Rotas essenciais

```
POST /v1/auth/register
POST /v1/auth/login
POST /v1/auth/webauthn/registration-options
POST /v1/auth/webauthn/registration-verification
POST /v1/auth/webauthn/authentication-options
POST /v1/auth/webauthn/authentication-verification
POST /v1/auth/mfa/totp
GET /v1/me/sessions
DELETE /v1/me/sessions/{id}
POST /v1/seller-accounts
GET /v1/me/seller-accounts
POST /v1/seller-accounts/{sellerAccountId}/onboarding
GET /v1/seller-accounts/{sellerAccountId}/onboarding
POST /v1/seller-accounts/{sellerAccountId}/onboarding/provider-session
POST /v1/seller-accounts/{sellerAccountId}/payout-destinations
GET /v1/seller-accounts/{sellerAccountId}/members
POST /v1/seller-accounts/{sellerAccountId}/members
DELETE /v1/seller-accounts/{sellerAccountId}/members/{membershipId}
GET /v1/admin/seller-onboarding
POST /v1/admin/seller-onboarding/{id}/approve
POST /v1/admin/seller-onboarding/{id}/reject

GET /v1/catalog/items
POST /v1/admin/catalog/items
POST /v1/admin/catalog/imports
POST /v1/admin/catalog/items/{id}/publish

POST /v1/listings
PATCH /v1/listings/{id}/draft
POST /v1/listings/{id}/submit
POST /v1/listings/{id}/ownership-proofs
PUT /v1/listing-revisions/{revisionId}/secure-delivery-template
DELETE /v1/listing-revisions/{revisionId}/secure-delivery-template
POST /v1/admin/listings/{id}/claim-review
POST /v1/admin/listings/{id}/ownership-proofs/{proofId}/verify
POST /v1/admin/listings/{id}/revalidate
POST /v1/admin/listings/{id}/approve
```

```

POST /v1/admin/listings/{id}/request-changes
POST /v1/admin/listings/{id}/reject

GET /v1/search
GET /v1/listings/{id}
GET /v1/prices/items/{catalogItemId}
GET /v1/prices/items/{catalogItemId}/candles
GET /v1/listings/{id}/component-quotes
GET /v1/channels/midas/listings

POST /v1/conversations
POST /v1/conversations/{id}/messages
POST /v1/listings/{id}/offers
POST /v1/offers/{id}/counter
POST /v1/offers/{id}/accept

POST /v1/orders
GET /v1/orders/{id}
POST /v1/orders/{id}/payment-session
POST /v1/orders/{id}/delivery-confirmations
POST /v1/orders/{id}/disputes
POST /v1/disputes/{id}/evidence
POST /v1/admin/disputes/{id}/decisions
POST /v1/disputes/{id}/appeals
POST /v1/orders/{id}/secure-package
POST /v1/orders/{id}/secure-package/reveal

GET /v1/admin/payments/quarantined
POST /v1/admin/payments/{paymentId}/quarantine/reconcile
POST /v1/admin/payments/{paymentId}/quarantine/refund

GET /v1/sales-balance
GET /v1/sales-balance/ledger
GET /v1/wallet # alias técnico legado; nunca comunica custódia Midas
GET /v1/wallet/ledger # alias técnico legado
POST /v1/payouts
GET /v1/payouts/{id}
POST /v1/payouts/{id}/retry
POST /v1/payouts/{id}/cancel
POST /v1/admin/payouts/{id}/review

POST /v1/tickets
GET /v1/tickets
POST /v1/tickets/{id}/messages
POST /v1/admin/tickets/{id}/assign
POST /v1/admin/tickets/{id}/resolve

GET /v1/me/account-restrictions
POST /v1/account-restrictions/{id}/appeals
POST /v1/me/data-rights-requests
GET /v1/me/data-rights-requests/{id}
GET /v1/admin/data-rights-requests
POST /v1/admin/data-rights-requests/{id}/resolve

GET /v1/admin/roles
POST /v1/admin/roles
PUT /v1/admin/users/{id}/grants
GET /v1/admin/audit

```

- **seller-accounts/{id}/onboarding** valida o sujeito vendedor e, quando o PSP suportar, devolve sessão hospedada; documentos financeiros não trafegam pela API Midas sem necessidade comprovada.
- evidência de disputa é append-only, classificada, submetida por URL assinada e vinculada ao prazo; decisão ADM exige motivo, escopo financeiro e policy version.
- recurso de disputa e de restrição possui idempotency key e no máximo uma instância ativa por decisão/restrrição.

- `data-rights-requests` aceita tipos versionados como `ACCESS`, `CORRECTION`, `PORTABILITY`, `DELETION` e `OBJECTION`; execução respeita legal hold, minimização e auditoria.
- resolução de pagamento em quarantine nunca aceita “marcar como pago” isoladamente: a rota dispara o mesmo comando transacional de reassociação ou reembolso usado pelo worker.

Device trust

```
POST /v1/devices/enrollment-options
POST /v1/devices/enrollments
GET /v1/me/devices
PATCH /v1/me/devices/{deviceId}
DELETE /v1/me/devices/{deviceId}
POST /v1/devices/{deviceId}/challenge
POST /v1/devices/{deviceId}/challenge-verification
POST /internal/v1/risk/evaluations
```

16. Idempotência e eventos

Registro de idempotência:

```
scope = actorId + method + canonicalRoute + idempotencyKey
requestHash
state = PROCESSING | COMPLETED | FAILED_RETRYABLE
responseStatus / responseBody / resourceId
expiresAt
```

- mesma chave e payload: mesmo resultado;
- mesma chave e payload diferente: `409 IDEMPOTENCY_KEY_REUSED`;
- IDs externos determinísticos por operação;
- constraints únicas em provider event, posting, client message e reserva;
- cancelamento de intent usa chave estável `payment:{paymentId}:cancel:v1`; relógio local apenas inicia `EXPIRY_PENDING`, nunca reativa anúncio;
- resolução de settlement tardio usa comando único por `providerEventId`, com locks ordenados `payment -> order -> listingUnit -> reservation -> template`;
- consumo de pronta-entrega possui unicidade permanente em `templateId` e `orderId`;
- retry de payout cria `PayoutAttempt` nova, mas o `PayoutRequest` e a reserva do saldo permanecem os mesmos até pagamento ou reversão;
- retry exponencial com jitter, DLQ e replay auditado.

Envelope:

```
{
  "eventId": "uuid",
  "eventName": "order.payment_settled",
  "schemaVersion": 1,
  "aggregateType": "order",
  "aggregateId": "uuid",
  "aggregateVersion": 7,
  "occurredAt": "UTC",
  "correlationId": "uuid",
  "causationId": "uuid",
  "actor": {"type": "system|user|admin", "id": "uuid"},
  "dataClassification": "INTERNAL",
  "payload": {}
}
```

Eventos principais:

user.registered, seller.onboarding_started, seller.onboarding_approved, device.trust_changed, catalog.item_published, listing.ownership_proof_verified, listing.availability_revalidation_failed, listing.submitted, listing.approved, listing.reserved, listing.expiry_pending, listing.reactivated_after_payment_cancel, listing.sold, delivery.template_frozen, delivery.template_consumed, offer.accepted, chat.message_blocked, account.restricted, account.restriction_appealed, price.observation_ingested, price.feed_stale, order.created, order.expired, payment.failed, payment.expired, payment.settled, payment.quarantined, payment.quarantine_reassociated, payment.refunded, payment.chargeback_opened, delivery.opened, delivery.party_confirmed, order.completed, dispute.opened, dispute.evidence_submitted, dispute.decided, dispute.appealed, ledger.entry_posted, funds.hold_started, funds.available, payout.requested, payout.failed, payout.returned, payout.retry_scheduled, payout.reversed, payout.paid, data_rights.requested, data_rights.resolved, ticket.created, risk.decisioned.

Payload nunca carrega senha, token, segredo ou conteúdo integral de chat.

17. Busca e recomendação

Documento derivado de busca:

```
listingId, status, channel, catalogItemId, category,
weapon, rarity, stickerIds[4], priceMinor, currency,
referenceGold, sellerRating, sellerRiskTier,
publishedAt, titleNormalized, availability
```

- somente **ACTIVE** aparece;
- banco revalida disponibilidade/autorização;

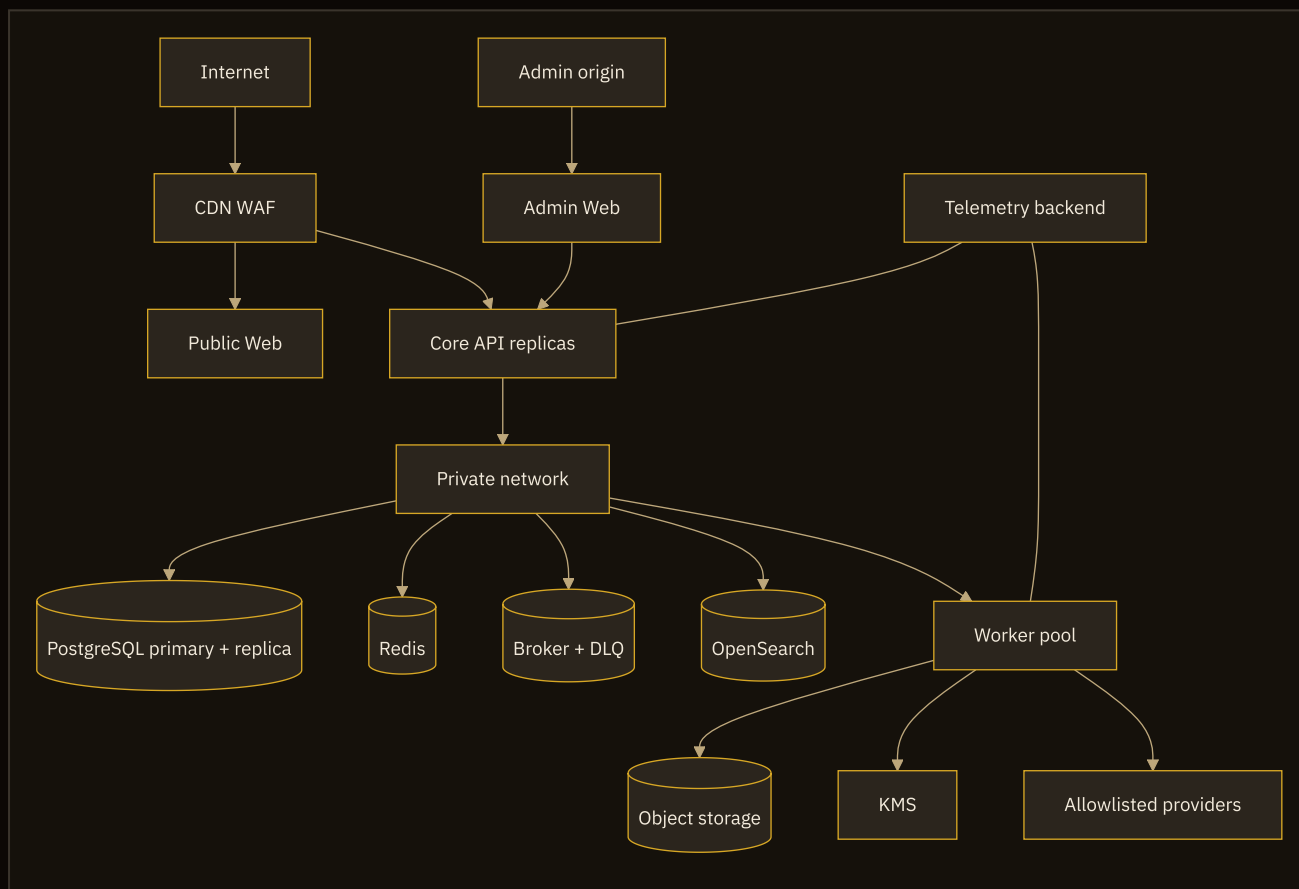
- venda/suspensão emite tombstone;
- `search_after` evita paginação profunda;
- nenhum chat, e-mail, contato ou PII é indexado.

Recomendação v1:

1. coletar `SEARCH`, `VIEW`, `CLICK`, `FAVORITE`, `OFFER`, `PURCHASE`, `HIDE` ;
2. calcular afinidade por item, arma, raridade, sticker e faixa;
3. gerar candidatos por conteúdo, popularidade real e semelhança;
4. ranquear por afinidade, disponibilidade, confiança e diversidade;
5. filtrar vendido, bloqueado, próprio e repetitivo;
6. registrar impressão/posição para avaliação.

ML colaborativo só depois de volume suficiente e teste contra diversidade, disputa, concentração e fraude.

18. Deploy e evolução



Primeiras candidatas a extração futura: chat, busca, pricing e recomendação. Payments/ledger só se separam quando contratos, reconciliação e operação estiverem maduros.

19. SLOs iniciais

Capacidade	Disponibilidade	Latência/frescor
Navegação/busca	99,9% mensal	p95 ≤ 400 ms
Auth e pedido	99,95%	p95 ≤ 800 ms sem tempo externo
Webhook financeiro durável	99,95%	ack p95 ≤ 1 s; processar p95 ≤ 60 s
Chat	99,9%	aceite→broadcast p95 ≤ 500 ms
Admin/suporte	99,5%	p95 ≤ 1 s
Ledger	100% dos journals balanceados	divergência crítica imediata
Pricing	depende do fornecedor	stale após 2× cadência; UI mostra asOf

SLOs são ponto de partida a validar por custo e piloto, não promessa comercial.

20. Backup e DR

- PostgreSQL com PITR, WAL contínuo e backup diário.
- Backups criptografados/imutáveis em conta ou região separada.
- Restore mensal e exercício trimestral.
- Object storage versionado.
- Redis/OpenSearch reconstruíveis.
- Broker com retenção e DLQ suficientes para replay.
- RPO financeiro/pedido ≤ 5 min; RTO ≤ 60 min.
- RPO chat/suporte ≤ 15 min; RTO ≤ 4 h.
- Busca/recomendação podem ser reconstruídas.

21. Testes PO de consistência e concorrência

Caso	Preparação/interleaving	Resultado obrigatório
Expiração × settlement antes do cancel ack	TTL vence; cancel é enviado; PSP liquida antes de confirmar cancelamento	anúncio nunca fica ACTIVE ; um settlement, um journal, uma venda
Cancel ack × settlement tardio	cancel canônico libera anúncio; webhook SETTLED chega depois	PAYMENT_QUARANTINED ; zero sala, zero template consumido, zero aviso de compra concluída
Reassociação segura	pagamento em quarantine; unidade continua livre, prova válida e sem reserva posterior	locks dos quatro agregados, um journal, anúncio SOLD , pedido PAID ; entrega abre somente pelo evento pós-commit

Caso	Preparação/interleaving	Resultado obrigatório
Novo comprador × settlement antigo	após liberação canônica, outro comprador reserva/compra; settlement do intent antigo chega	reserva/pedido novo permanecem intactos; pagamento antigo segue para refund, nunca reassocia
Refund de quarantine falha	PSP retorna timeout/erro/estado indeterminado	permanece congelado em MANUAL_REVIEW ; nenhum saldo disponível e nenhuma entrega
Webhooks duplicados e fora de ordem	repetir SETTLED , CANCELED , REFUNDED e CHARGEBACK em todas as ordens	uma inbox por evento, transições monotônicas, journals únicos e saldo correto
Falha no meio da transação	abortar após locks, após journal e antes de outbox	rollback integral ou recovery por outbox; jamais estado pago sem journal/evento correspondente
Template concorrente	dois workers tentam consumir o mesmo SecureDeliveryTemplate	exatamente um SecureDeliveryPackage ; hash confere; perdedor é no-op idempotente
Política Standoff	tentar salvar login, senha, token, cookie ou recovery code	rejeição server-side; nada persiste em ciphertext, log ou evento
Prova e craft	prova expirada, item indisponível ou craftEligible=false	anúncio suspenso/rejeitado; reserva e craft impossíveis
Payout FAILED	PSP falha antes/depois de PROCESSING ; webhook repetido	não vira PAID ; revisão/retry ou reversão única para AVAILABLE
Payout RETURNED pós-pagamento	PSP/banco devolve depois de informar sucesso	RETURN_REVIEW ; nova tentativa ou lançamento compensatório, sem crédito duplicado

Executar esses casos com barreiras concorrentes reais no banco, fault injection e property tests das máquinas de estado. Mock sequencial sem disputa de lock não satisfaz o gate.

22. Critérios técnicos inegociáveis

1. Webhook repetido não duplica dinheiro.
2. Duas compras não vendem a mesma unidade.
3. Reserva expirada não reativa anúncio antes do cancelamento canônico do intent.
4. Settlement tardio passa por quarantine e nunca abre entrega diretamente.
5. Template de pronta-entrega é vinculado, congelado e consumido exatamente uma vez; Standoff não aceita credenciais armazenadas.
6. Papel nenhum lê objeto fora de ownership/escopo.
7. Segredo não aparece em log, e-mail, busca ou analytics.
8. Todo journal balanceia por moeda.
9. Toda ação financeira manual cria comando e lançamento, nunca edição direta.
10. **FAILED** / **RETURNED** de payout terminam em retry rastreável ou reversão contábil, nunca em baixa silenciosa.
11. Todo estado operacional possui saída, recurso ou explicação; evento financeiro tardio continua reconciliável.
12. Todo preço mostra origem, **asOf** e frescor.
13. Todo privilégio é explícito, limitado e auditável.

14. Toda restauração crítica é testada antes do lançamento.

NO-GO de release

- anúncio volta a **ACTIVE** por cron local sem confirmação canônica do PSP;
- **PAYMENT_QUARANTINED** dispara entrega, saldo, template ou mensagem de sucesso;
- refund/quarantine pode ser resolvido por update manual de status;
- payout **FAILED** / **RETURNED** não possui tentativa, revisão e posting compensatório rastreáveis;
- pronta-entrega pode ser consumida duas vezes, mudar depois da aprovação ou conter credenciais de Standoff;
- anúncio publica/reserva sem prova válida de posse/disponibilidade ou com craft em item não elegível;
- ausência de rotas auditáveis para evidência, decisão, recurso, direitos do titular ou seller onboarding;
- relação usuário-vendedor depende de role global sem **SellerMembership** e escopo explícito.

1. Conceito

Midas Foundry é a direção de arte proposta: uma oficina noturna de comércio digital. O ouro não é luxo ornamental; é o sinal de valor validado. O carvão representa a infraestrutura e a cautela. A interface deve parecer precisa sob pressão, não um cassino de skins.

Vibe: **forja noturna, ouro, precisão, confiança.**

DNA transportado em clean room

Da Nesha Store, transportamos apenas princípios:

- densidade de catálogo;
- leitura rápida de preço e disponibilidade;
- categorias visíveis e filtros persistentes;
- produto como centro visual;
- contexto de pagamento/entrega perto do CTA;
- confiança como parte da jornada.

Do painel de preços observado, transportamos:

- leitura temporal;
- alternância de período;
- preço atual, mínimo, máximo e média;
- separação entre compra e venda quando a fonte suportar;
- tabela comparativa com variação, spread e volatilidade.

Não transportamos marcas, paletas exatas, layouts pixel a pixel, ilustrações, imagens, textos ou código.

2. Princípios visuais

1. **Valor tem uma cor; estado tem uma forma.** Ouro identifica ação/valor. Erro, sucesso e risco usam ícone + texto + cor.

2. **Densidade sem aperto.** Cards compactos, mas controles com alvo mínimo de 44 px e respiro consistente.
3. **Gold não é real.** Preço em gold e preço fiduciário nunca compartilham o mesmo tratamento.
4. **Origem e frescor são visíveis.** Toda cotação mostra fonte, horário e estado `atual`, `desatualizado` ou `indisponível`.
5. **Persuasão honesta.** Sem cronômetro, estoque baixo, desconto ou popularidade inventados.
6. **O produto domina; o cromado recua.** Imagem, nome, craft, preço e segurança vencem a decoração.
7. **Midas e P2P são parentes, não gêmeos.** Mesmo sistema, identificação de canal inequívoca.

3. Sistema cromático proposto

Tokens canônicos em OKLCH:

```
:root {
  --color-paper:      oklch(13% 0.012 75);
  --color-paper-2:    oklch(17% 0.014 75);
  --color-paper-3:    oklch(22% 0.016 75);
  --color-ink:         oklch(94% 0.012 85);
  --color-ink-2:       oklch(78% 0.012 80);
  --color-muted:       oklch(66% 0.012 75);
  --color-rule:        oklch(31% 0.016 75);
  --color-rule-2:      oklch(26% 0.014 75);
  --color-accent:      oklch(78% 0.160 80);
  --color-accent-ink:  oklch(18% 0.018 75);
  --color-focus:       oklch(84% 0.190 80);
  --color-danger:      oklch(65% 0.190 28);
  --color-success:     oklch(72% 0.130 150);
  --color-info:        oklch(74% 0.120 225);
}
```

- Ouro ocupa no máximo ~3–5% de uma tela: CTA, foco, valor-chave, estado ativo.
- Verde, vermelho e ciano são **semânticos**, não decorativos.
- Sem preto ou branco puros; superfícies são levemente aquecidas.
- Gráficos usam ouro para a série principal, ciano apenas para comparação autorizada e padrões/ícones para não depender de cor.

4. Tipografia

Família

- **Display:** Big Shoulders Display, 700/800 — industrial, condensada, usada em títulos curtos.

- **Corpo/UI:** IBM Plex Sans, 400/700 — leitura, formulários, tabelas e operação.
- **Dados/mono:** IBM Plex Mono, 400/600 — IDs, preços, timestamps e código técnico.

Todas são gratuitas. Nenhum título usa itálico. Máximo de três famílias.

Escala

Razão de 1,25, corpo de 16 px, medida de leitura entre 45–75 ch. Dados numéricos usam `tabular-nums`. Títulos longos caem um nível antes de quebrar a composição. Rótulos podem usar caixa alta curta com tracking controlado; parágrafos nunca.

5. Estrutura das superfícies

Navegação pública

Desktop: cabeçalho compacto com busca como ação dominante; acesso direto a `Market`, `Compre do Midas`, `Vender`, `Mensagens` e `Conta`.

Mobile: barra inferior para Início, Market, Midas, Mensagens e Conta; “Vender” aparece como ação contextual na Conta e no cabeçalho do Market.

Início

- busca acima da dobra;
- entrada separada para P2P e Midas;
- categorias por arma/tipo;
- recomendações com explicação;
- vistos recentemente;
- educação curta: aprovação, pagamento, entrega e hold.

Não usar carrossel automático. Se houver faixa editorial, avanço é manual e pausável.

Catálogo e cards

O card contém apenas o que decide clique:

- imagem licenciada;
- nome e variante;

- canal `P2P` ou `Midas` ;
- preço da oferta;
- referência em gold com `as0f` ;
- badge de craft e contagem de adesivos;
- reputação/estado do vendedor quando aplicável;
- disponibilidade real.

Sem card dentro de card, borda lateral colorida ou sombra brilhante. Elevação em dark mode é feita por aumento de luminosidade.

Página do anúncio

Desktop em duas zonas assimétricas:

- esquerda maior: imagem, craft posicionado e detalhes;
- direita: preço, vendedor, estado, proposta e compra;
- abaixo: gráfico, componentes em gold, condições de entrega, chat e ofertas semelhantes.

No mobile, preço e CTA formam uma barra inferior fixa que não encobre conteúdo; o gráfico vira área rolável por período sem tabela de dez colunas.

Wizard de anúncio

Fluxo vertical por etapas:

1. Tipo do produto.
2. Item-base do catálogo.
3. Craft (`não` ou `sim`), exibido somente quando o item-base tiver `craftEligible=true` na versão autorizada do catálogo.
4. Quatro posições de adesivo, somente se `sim` .
5. Preço, descrição e entrega.
6. Prévia e envio para revisão.

Ao trocar craft para `não` , explicar que os slots serão limpos. Salvar rascunho. Erros apontam campo, motivo e correção.

Admin/Master

Workbench denso e sóbrio, com navegação lateral por domínio. Tabelas viram listas orientadas a ação no mobile. Toda decisão sensível exibe escopo, objeto, efeito e exigência de step-up antes da confirmação.

6. Componentes que constroem confiança

- **Price provenance:** valor + fonte + `observedAt` + frescor.
- **Seller capsule:** nome público, reputação verificável, histórico e status.
- **Approval trace:** data, estado e motivo de moderação sem expor staff.
- **Craft rail:** quatro posições fixas, sticker, preço gold e vazio explícito.
- **Delivery timeline:** pago → sala aberta → vendedor confirmou → comprador confirmou → hold → saldo disponível no fluxo do PSP.
- **Hold clock:** data prevista, pausas e motivo; nunca apenas um contador.
- **Moderation notice:** mensagem bloqueada, regra, strike e via de contestação.
- **Secure reveal:** step-up, aviso `no-store`, revelação auditada e expiração.
- **Feed stale state:** último valor rotulado; ausência nunca vira zero.
- **Price table:** toda série gráfica possui alternativa tabular com data/hora, valor, mínimo, máximo, média, origem e frescor; leitura não depende de cor, hover ou visão.

7. Conteúdo e microcopy

Vocabulário canônico

- `Entrar`, não alternar com “Login”.
- `Criar anúncio`, não “Cadastrar produto”.
- `Enviar para revisão`, não “Submit”.
- `Preço da oferta` e `Referência em gold`.
- `Saldo de vendas em retenção no PSP`, não “carteira” ou “dinheiro preso”.
- `Abrir disputa`, `Confirmar entrega`, `Confirmar recebimento`.
- `Compre do Midas` sempre por extenso em títulos.

Erro de PII

Primeira tentativa:

Esta mensagem não foi enviada porque contém informação de contato. Negocie aqui para manter a proteção da compra. Esta é sua primeira ocorrência.

Segunda:

Esta mensagem não foi enviada. Uma nova tentativa de compartilhar contato restringirá sua conta e abrirá revisão da staff.

Terceira:

Sua conta foi restringida para revisão. Você ainda pode acessar esta tela e enviar um recurso à staff.

Estados vazios

Todo vazio contém: o que está vazio, por que importa e uma ação. Exemplo: “Nenhum anúncio enviado. Seus rascunhos e revisões aparecerão aqui. Criar anúncio.”

8. Motion e interação

Movimento só comunica mudança:

- 120 ms para press/toggle;
- 180–220 ms para hover e menu;
- 250–300 ms para modal e troca de conteúdo;
- sem `transition-all`, bounce, parallax ou fade em cada seção;
- foco aparece instantaneamente;
- resultados de busca usam debounce e anunciam contagem;
- sucesso visível é silencioso; erro oferece recuperação;
- `prefers-reduced-motion` reduz movimento espacial a crossfade de até 150 ms.

9. Acessibilidade e responsividade

- Meta WCAG 2.2 AA.
- Contraste mínimo 4,5:1 para texto e 3:1 para componentes/ícones grandes.
- Foco visível em todos os elementos interativos.
- Alvos mínimos de 44 × 44 px.

- Labels visíveis; placeholder nunca substitui label.
- Estado não depende apenas de cor.
- Gráfico sempre tem resumo textual, tabela navegável por teclado e valores expostos ao leitor de tela.
- 320, 375, 414, 768, 1280 e 1440 px são viewports obrigatórios de revisão.
- Sem rolagem horizontal; `overflow-x: clip` no documento.
- CTAs e links de navegação não quebram em duas linhas.
- Diálogos nativos, popovers acessíveis e navegação completa por teclado.

10. Regras contra design manipulativo

Bloqueado:

- contagem regressiva sem prazo operacional real;
- “última unidade” sem estoque real;
- preço riscado que não foi praticado;
- “mais vendido” sem amostra e período;
- prova social fabricada;
- default que adiciona seguro/taxa opcional;
- botão de cancelamento escondido;
- recomendações pagas sem rótulo;
- urgência visual em disputa, saque ou segurança.

11. Stamp do sistema

```
Hallmark · macroestrutura: Long Document / workbench transacional  
tema: custom · vibe: “forja noturna, ouro, precisão, confiança”  
display: Big Shoulders Display · corpo: IBM Plex Sans · dados: IBM Plex Mono  
eixos: dark / display-condensed-bold / chromatic-amber  
DNA estudado: Nesha + painel de preços, reconstruído em clean room
```

SEGURANÇA, COMPLIANCE E OPERAÇÕES — MIDAS

Planejamento técnico e de produto; não substitui parecer jurídico, contábil, regulatório ou contratual. As conclusões legais devem ser confirmadas por profissionais responsáveis antes de operação real.

1. Gate PO — direito de operar

Estado: NO-GO para Standoff 2

As [Regras oficiais do Standoff 2 em português](#), atualizadas em 03/07/2026, proíbem comércio externo e esquemas de intermediação envolvendo itens, moedas, contas ou APIs por dinheiro real, salvo permissão expressa. A [EULA oficial](#) proíbe comprar, vender, alugar ou compartilhar contas/credenciais e restringe o uso comercial de conteúdo e bens virtuais. O [Code of Conduct](#) também proíbe procurar compra/venda e compartilhar contato para esse fim.

Consequências:

- não publicar Market P2P nem Compre do Midas para Standoff 2;
- não habilitar venda/entrega de contas;
- não raspar/integrar endpoints internos ou não oficiais;
- não baixar/republicar PNGs sem licença comercial;
- não prometer entrega oficial P2P: a [FAQ de economia](#) afirma que o jogo não pretende oferecer troca direta entre amigos;
- solicitar autorização escrita da Axlebolt cobrindo negócio, território, tipos de item, transferência, API, caching, gráfico, ativos, marca e auditoria.

Até a autorização existir, o único caminho seguro é um motor genérico/protótipo com dados sintéticos e arte própria.

2. Gates de compliance

Gate	Condição de aprovação	Owner
LIC	autorização escrita do publicador por jogo	Direção/Jurídico
DATA	API pública/documentada/licenciada e direito de exibição	Produto/Engenharia
ASSET	licença comercial, proveniência e marca permitida	Design/Jurídico
PAY	PSP e fluxo de fundos/split/hold/payout aprovados; saldo de vendas administrado pelo PSP	Financeiro/Jurídico
AGE	acesso provável por menores, age assurance e parental controls	Privacidade/Produto
MOD	regras, evidência, recurso e revisão humana	Trust & Safety
SEC	MFA, IAM, auditoria, incidente, DR e testes	Segurança
CONS	oferta, checkout, entrega, arrependimento, disputa e suporte	Produto/Jurídico

3. Baseline de consumo no Brasil

A oferta deve ser clara e vinculante conforme o [Código de Defesa do Consumidor](#), especialmente arts. 6º, 14 e 30–39, e o [Decreto do Comércio Eletrônico](#).

Antes de pagar

Exibir e congelar no snapshot do pedido:

- razão social/CNPJ e canais da plataforma;
- identidade pública e papel do vendedor;
- item exato, versão, craft e quatro posições;
- preço total, taxas, moeda e referência em gold separada;
- disponibilidade, restrições e mecanismo de entrega;
- prazo de disponibilidade do saldo de vendas administrado pelo PSP, payout/saque e consequências de disputa/chargeback;
- política de cancelamento, arrependimento, reembolso e evidência;
- versão dos termos e consentimentos aplicáveis.

Arrependimento e cancelamento

O CDC, art. 49, prevê sete dias em contratos fora do estabelecimento. A aplicação a cada bem digital já entregue exige parecer específico; Midas não deve supor que “entrega instantânea” elimina automaticamente o direito. O produto precisa nascer com cancelamento/estorno e comunicação ao PSP.

Atendimento

O Decreto 7.962/2013 exige confirmação imediata da demanda e resposta eficaz em até cinco dias. O sistema de tickets deve ter protocolo, estado, SLA, responsável, escalonamento e histórico. Restrição ou banimento jamais elimina acesso a suporte/recurso.

Persuasão ética

Proibido:

- contador ou estoque falsos;
- preço riscado não praticado;
- avaliação/prova social inventada;
- CTA disfarçado ou cancelamento escondido;
- pressão em usuário vulnerável;
- recomendação paga sem rótulo;
- urgência sem fonte e expiração auditáveis.

4. Crianças e adolescentes

A [Lei 15.211/2025 — ECA Digital](#) vigora desde 17/03/2026 e alcança serviços dirigidos ou de acesso provável por menores, conforme a [orientação da ANPD](#).

Como o produto está ligado a jogo, **GATE-AGE** é P0. Um checkbox “tenho 18 anos” não encerra o problema.

Requisitos protetivos

- avaliação documentada de acesso provável e riscos;
- privacidade protetiva por padrão;
- aferição de idade proporcional;
- controle/supervisão parental quando aplicável;
- chat mais restrito por padrão;

- ranking contextual e personalização desligável;
- sem perfilamento para publicidade comercial de menores;
- sem padrões que estimulem uso compulsivo;
- limites de compra, notificação e horário conforme política aprovada.

O [Decreto 12.880/2026](#) exige minimização, finalidade exclusiva, auditabilidade e contestação na aferição.

Imagem/cópia de documento deve ser eliminada imediatamente após extrair o sinal necessário. Armazenar somente faixa/resultado, método, confiança e expiração — separado de marketing, recomendação, KYC e device risk.

Age assurance, responsável legal e contestação

- usar método proporcional ao risco e à funcionalidade, com modo mais protetivo quando a idade for desconhecida ou inconclusiva;
- guardar somente faixa etária/sinal, método, confiança, validade e trilha de contestação; data de nascimento exata e documento bruto não entram no perfil comum;
- separar o fornecedor de age assurance dos demais usos: ele atua como operador quando tratar dados em nome do Midas, com contrato, instruções, retenção e subprocessadores definidos;
- quando a lei, a avaliação de risco ou a jornada exigir participação do responsável, verificar o vínculo/autoridade por mecanismo próprio, registrar escopo e versão da autorização e permitir revogação ou troca do responsável;
- conta de menor e conta do responsável permanecem distintas; o responsável recebe somente controles e informações compatíveis com seu papel, sem acesso indiscriminado a mensagens ou segredos;
- revalidar o sinal em mudança material, expiração, indício de fraude ou evolução de faixa etária, sempre com recurso acessível e revisão humana;
- compras, chat, personalização e notificações aplicam a política da faixa mais protetiva até a aferição ser concluída.

5. LGPD e privacidade

Base: [Lei Geral de Proteção de Dados](#), princípios, bases, transparência, direitos, segurança e registro de operações.

Inventário de finalidades

Finalidade	Dados mínimos	Controle obrigatório
Conta/auth	e-mail, hash, fator, sessão	passkey/MFA, recuperação, retenção
Device risk	chave, IP truncado, ASN, UA family, eventos	minimização, TTL, contestação
Catálogo/anúncio	item, preço, mídia, seller	provenance e publicação governada

Finalidade	Dados mínimos	Controle obrigatório
Pagamento	IDs PSP, valor, estado	sem PAN/CSV, conciliação, segregação
Chat	participantes, ciphertext, regra/strike	transparência, acesso limitado, TTL
Entrega	confirmações e pacote secreto	KMS, no-store, revelação auditada
Recomendação	eventos pseudonimizados e afinidades	opt-out, explicação, limpeza
Suporte	ticket, contato, contexto necessário	ABAC, anexos seguros, retenção
Auditoria	ator, ação, alvo e diff redigido	append-only, acesso auditado
Idade	faixa/resultado e validade	finalidade exclusiva e segregação

Direitos dos titulares e Privacy Center

O Privacy Center deve permitir pedido autenticado, protocolo e acompanhamento para: confirmação e acesso; correção; exportação/portabilidade em formato interoperável quando aplicável; anonimização, bloqueio ou eliminação; informação sobre compartilhamentos; revogação de consentimento; oposição ao tratamento; e revisão de decisão automatizada. A identidade do solicitante será verificada de forma proporcional, sem pedir mais dados que o necessário.

- cada pedido recebe owner, prazo legal/operacional, evidência de atendimento e resposta em linguagem clara;
- exportação aplica autorização, redaction de dados de terceiros, arquivo criptografado, link de curta duração e auditoria;
- eliminação propaga-se a operadores e backups conforme política; exceção por obrigação legal, exercício regular de direitos, fraude ou contrato deve ser específica, documentada e informada;
- oposição e revogação interrompem os tratamentos dependentes daquela base, sem prejudicar tratamentos sustentados por outra base válida;
- revisão humana informa resultado e razão compreensível, sem revelar regra antifraude explorável;
- usuário suspenso ou banido mantém acesso ao Privacy Center, suporte e recurso.

Papéis, contratos e cadeia internacional

- o Midas documenta, por finalidade e fluxo, quando atua como controlador; PSP, antifraude ou outro parceiro que determine finalidades próprias deve ser mapeado como controlador independente ou conjunto, conforme a realidade, e não rotulado automaticamente como operador;
- operadores recebem instruções documentadas e DPA com confidencialidade, segurança, retenção, exclusão/devolução, auditoria, cooperação em direitos e SLA de incidente menor que o prazo regulatório;
- subprocessadores exigem inventário, finalidade, local de tratamento, mecanismo de autorização/notificação e obrigações equivalentes às do operador principal;
- transferência internacional só entra em produção após mapear países e acessos remotos, avaliar o mecanismo previsto na LGPD/regulamentação da ANPD, documentar salvaguardas e refletir isso no aviso de privacidade;
- manter registro de operações, data map, bases legais, fornecedores, decisões de controlador/operador e evidência de due diligence; mudança de fornecedor ou país reabre a avaliação.

Cookies, analytics e opt-out

- separar cookies estritamente necessários de analytics, personalização e publicidade; não essenciais ficam desligados até a escolha válida quando consentimento for a base adotada;
- banner sem caixa pré-marcada, com “aceitar” e “recusar” igualmente acessíveis; preferências granulares e revogação tão simples quanto a aceitação;
- analytics coleta o mínimo, evita IDs cross-site e payloads com e-mail, chat, termo sensível ou segredo; parâmetros de URL são redigidos antes do envio;
- registrar versão do aviso, categorias, fornecedores, finalidade, escolha e expiração; sincronizar opt-out entre cliente, servidor, CDP e recomendador;
- usuários menores ou de idade desconhecida recebem o modo mais protetivo, sem cookies não essenciais ou publicidade comportamental por padrão;
- inventário e scanner de cookies impedem que novo SDK/tag seja publicado sem owner, base legal, retenção, país e revisão de segurança.

Perfil comportamental

Busca, clique, favorito e compra podem formar perfil pessoal. O recomendador precisa de base legal por finalidade, minimização, retenção, LIA/RIPD, explicação “por que estou vendo”, desligamento e separação entre orgânico/patrocinado. O [Guia de Legítimo Interesse da ANPD](#) orienta finalidade, necessidade e balanceamento.

Decisão automatizada

A LGPD, art. 20, assegura revisão e informação sobre critérios de decisão automatizada que afete interesses. Assim:

- mensagem pode ser bloqueada imediatamente por alta confiança;
- banimento permanente não será decidido só pelo classificador;
- terceiro strike cria `RESTRICTED_PENDING_REVIEW` ;
- usuário recebe reason code, contagem e via de recurso;
- humano autorizado decide restaurar, suspender ou banir;
- modelo/regra, versão, confiança e reversão são auditados;
- falsos positivos e grupos afetados são medidos.

Monitoramento de chat

Escanear telefone/e-mail/nick é tratamento de dados. Informar finalidade antifraude/moderação, restringir acesso, não reutilizar conversa para treinar modelo sem fundamento separado e nunca vaziar o dado detectado em log/push. O [Marco Civil da Internet](#), art. 10, protege conteúdo de comunicações privadas.

6. Plataforma, denúncia e moderação

O [Decreto 12.975/2026](#) ampliou deveres de governança, denúncia e transparência; a [ANPD mantém resumo oficial](#).

Requisitos:

- representante/canal permanente conforme aplicabilidade;
- denúncia de fraude/conteúdo;
- políticas versionadas e acessíveis;
- reason codes e recurso;
- transparência de moderação/risco;
- se houver boost pago, rótulo “Patrocinado” e guarda de anunciante, criativo, período, pagamento e decisões pelo prazo aplicável;
- nenhuma métrica de moderação baseada só em volume de banimentos.

7. Pagamentos e desenho regulatório

Posição

Midas não deve criar carteira própria sacável, captar depósitos nem custodiar fundos na conta operacional. O valor devido ao vendedor será denominado **saldo de vendas administrado pelo PSP**: o PSP contratado mantém/administra o fluxo financeiro; o ledger Midas apenas espelha eventos e obrigações para UX, conciliação e auditoria. A interface não usará “carteira Midas”, “depósito” ou “escrow” sem produto e enquadramento contratual/regulatório correspondentes. A [Lei 12.865/2013](#) disciplina instituições/arranjos e contas de pagamento; o [Banco Central explica as modalidades](#). Marketplaces que recebem e repassam após comissão podem atuar como subcredenciadores, segundo o [FAQ oficial do BCB](#).

Contratar PSP compatível com:

- marketplace/subcontas ou split;
- Pix/cartão sem PAN/CVV no Midas;
- KYC/KYB de vendedor;
- delayed payout/reserva se contratualmente suportado;
- refund, dispute e chargeback;
- saldo negativo e reserva de risco;
- payout e webhook assinado;
- relatórios de settlement e reconciliação.

Verificar autorização no [Encontre uma instituição do BCB](#).

Nomenclatura e estados financeiros

- **PENDING** : pagamento ainda não liquidado pelo PSP; não compõe saldo do vendedor;
- **ADMINISTERED_HOLD** : saldo de vendas administrado pelo PSP, indisponível até a data/motivo informado;
- **AVAILABLE_FOR_PAYOUT** : saldo de vendas administrado pelo PSP elegível a payout, ainda não transferido;
- **PAYOUT_PROCESSING** , **PAID_OUT** , **REVERSED** e **DISPUTED** : estados derivados de eventos canônicos do PSP;
- nenhum valor muda de estado por retorno do navegador, cron sem prova ou edição administrativa direta; correção financeira ocorre por lançamento compensatório e evento idempotente;
- telas e extratos separam valor bruto, comissão Midas, tarifa PSP, ajustes, reserva/disputa e líquido, sempre com origem e **asOf** .

Hold de sete dias

Não existe autorização legal geral encontrada para reter o saldo de vendas administrado pelo PSP por sete dias. O prazo precisa ser:

- contratual e suportado pelo PSP;
- informado antes da venda;
- ligado a risco objetivo;
- iniciado em marco inequívoco;
- pausado por disputa/chargeback;
- visível com início, fim e motivo;
- liberado por evento idempotente;
- nunca chamado “escrow” sem produto jurídico/contratual correspondente.

Ledger e conciliação

- ledger interno registra obrigação; não prova custódia;
- partida dobrada por moeda;
- correção somente por reversão;
- clearing PSP reconciliado intradiária e diariamente;
- divergência congela o payout relacionado;
- browser redirect nunca confirma pagamento;
- webhook exige raw body, assinatura, timestamp, ID único e consulta canônica quando disponível.

PCI DSS mesmo com checkout hospedado

Checkout redirecionado, hosted fields ou tokenização reduzem o escopo, mas não eliminam as responsabilidades do comerciante. Antes do go-live, PSP/adquirente e, quando necessário, QSA devem definir o escopo e a validação aplicável conforme o [PCI Security Standards Council](#).

- Midas nunca recebe, registra, captura em analytics ou persiste PAN completo, CVV ou dados equivalentes;
- inventariar páginas, scripts, tags e integrações que possam afetar a página de pagamento; terceiros entram por allowlist, versionamento, CSP e monitoramento de alteração;
- cumprir o SAQ/atestação indicado pelo adquirente, varreduras e testes aplicáveis, sem presumir automaticamente SAQ A apenas por usar iframe ou redirect;
- manter diagrama de fluxo, responsabilidade compartilhada, evidência anual e contato de incidente do PSP/adquirente;
- incidente com página/script de checkout aciona contenção, preservação de evidência e notificação contratual específica, além do runbook LGPD quando houver dados pessoais.

Fiscal, contábil, comissão e documento fiscal

Antes da operação, contador e jurídico tributário devem validar CNPJ, regime, município, código de serviço, natureza da intermediação e obrigações de cada vendedor. O [Portal Nacional da NFS-e](#) é referência operacional, mas não substitui a análise do ente competente nem define sozinho a tributação do modelo.

- pedido, ledger, settlement e extrato distinguem venda bruta, comissão/serviço Midas, tarifa PSP, desconto/cupom financiado por cada parte, retenção tributária se aplicável, reembolso, chargeback, reserva e líquido ao vendedor;
- Midas emite o documento fiscal relativo à sua própria comissão/serviço quando exigido; a responsabilidade do vendedor pelo documento da venda depende de sua natureza e regime e deve constar do onboarding/contrato;
- emissão “em nome do vendedor” só existe com fundamento, mandato e integração aprovados; ausência de documento fiscal não pode ser mascarada como simples recibo da plataforma;
- cada documento guarda chave/identificador, competência, valor, status, cancelamento/substituição e vínculo ao pedido/lote de payout;
- conciliação diária compara PSP, ledger, documentos fiscais, comissão, estornos e conta bancária; divergência material bloqueia somente o payout relacionado e abre caso com owner;
- contabilidade define plano de contas, reconhecimento de receita da comissão versus valores de terceiros, fechamento mensal e retenção documental; regras fiscais não serão codificadas antes desse parecer.

8. Identity e autenticação

- Passkeys/WebAuthn como preferência, conforme [W3C WebAuthn](#).
- Passkey obrigatória para Master/admin financeiro/segurança, salvo break-glass controlado.
- Senha fallback com Argon2id calibrado.
- TOTP e recovery codes com hash; e-mail não é segundo fator forte.

- Step-up para IAM, mudança de e-mail/MFA, destino/saque, reembolso, segredo e exportação.
- Recuperação invalida sessões e aplica cooling-off financeiro.
- Cookie opaco `HttpOnly` , `Secure` , `SameSite` , escopo mínimo.
- CSRF em mutações; rotação após login, step-up e mudança de privilégio.
- Sem token duradouro em `localStorage` .
- Tela de sessões/dispositivos e revogação remota.
- Práticas alinhadas à [OWASP Session Management Cheat Sheet](#).

9. API própria de dispositivo confiável

O que ela prova

Confiança de vínculo e contexto de risco; não identidade física, idade ou unicidade universal.

```
POST /v1/devices/enrollment-options
POST /v1/devices/enrollments
GET /v1/me/devices
PATCH /v1/me/devices/{deviceId}
DELETE /v1/me/devices/{deviceId}
POST /v1/devices/{deviceId}/challenge
POST /v1/devices/{deviceId}/challenge-verification
POST /internal/v1/risk/evaluations
```

Controles

- nonce de uso único;
- validação de challenge, RP ID, origem, assinatura e contador;
- guardar chave pública/credential ID, nunca chave privada;
- sinais auxiliares minimizados: ASN, IP truncado, UA family, timezone, idade do vínculo, falhas e velocidade;
- sem fingerprint cross-site;
- retenção curta e acesso RBAC;
- cliente recebe tier/ação, não score ou regra explorável;
- decisão pode ser contestada.

O [Decreto 8.771/2016](#) inclui identificadores eletrônicos no conceito relevante de dados pessoais.

10. IAM — RBAC + ABAC

Papéis são templates; autorização real combina permissão, objeto e condição.

Condições ABAC:

- ownership;
- canal P2P/Midas;
- departamento;
- categoria/faixa de valor;
- risco/país/horário;
- step-up recente;
- conflito de interesse;
- dupla aprovação.

Regras:

- deny by default e deny explícito vence;
- ninguém concede o que não possui;
- Master não edita ledger, senha, token ou auditoria;
- reembolso, hold manual, payout, destino e privilégio usam segregação;
- toda policy/grant registra diff, motivo, versão e sessão;
- acesso ao audit log também é auditado;
- break-glass é curto, dual-control, alertado e revisado.

11. Chat anti-PII e devido processo

Políticas por sala

- **PRE_PURCHASE** : bloqueia telefone, e-mail, URL, Pix, WhatsApp, Instagram, nick e codificação.
- **DELIVERY** : somente após **payment.settled** ; permite o necessário à entrega conforme política.
- **SUPPORT** : PII acessível apenas por agentes autorizados.

Decisão

```
mensagem
-> autenticação + participante
-> rate limit
-> Unicode NFKC
-> remover zero-width / tratar confusables
-> regras de e-mail, telefone, URL, Pix, social, nick e leetspeak
-> classificador e confiança
-> allow | block_no_strike | block_strike | restrict_review
```

- alta confiança: bloqueia e contabiliza;
- média: bloqueia sem strike e permite edição/contestação;
- baixa: aceita; amostragem somente redigida e governada;
- 1º/2º: aviso contextual;
- 3º dentro de janela configurável: restrição imediata e recurso;
- humano decide ban definitivo.

Persistir conteúdo aceito criptografado. Para bloqueado, preferir razão, versão, confiança e fingerprint HMAC; conteúdo bruto só se indispensável ao recurso, em cofre separado e TTL curto.

12. Secure Delivery Vault

Login, senha, token e recuperação nunca entram em chat, ticket, e-mail ou log.

- DEK única por pacote;
- envelope encryption com KMS;
- pacote congelado após pagamento;
- reveal somente ao comprador do pedido, com step-up se risco;
- token curto, **Cache-Control: no-store** e proteção contra indexação;
- auditoria da revelação sem conteúdo secreto;
- notificação ao vendedor;
- expiração e crypto-shredding após conclusão + janela de disputa;
- suporte genérico não vê o segredo;
- screenshots/exportações do admin não contêm plaintext.

Para Standoff 2, o cofre de credenciais de conta fica desabilitado, pois a venda/compartilhamento de contas contraria os termos atuais.

13. WhatsApp e Instagram

Antes do pagamento: bloqueados pelo anti-PII.

Depois do pagamento:

- mostrar somente se vendedor consentiu e política permitir;
- deep link controlado é suficiente no MVP;
- informar que conversa externa pode reduzir a evidência disponível;
- não coletar agenda/contatos;
- integração de mensagens futura só por API oficial e permissões adequadas;
- nunca automatizar acesso, scraping ou login de terceiros.

14. Caixa de e-mail e tickets

“Caixa própria” significa uma experiência Midas apoiada em provedor, não construir MTA do zero.

- endereço no domínio Midas;
- inbound webhook validado sobre raw body com assinatura, timestamp e ID de evento; usar mTLS/allowlist de origem quando o provedor oferecer e buscar a mensagem canônica pela API antes de qualquer mutação sensível;
- janela curta de aceitação, cache anti-replay e unicidade de `providerMessageId` /evento; retries repetem a mesma resposta e produzem um único efeito;
- validar envelope sender, destinatário/alias, `From`, `Reply-To` e associação ao ticket; SPF/DKIM/DMARC são sinais contra spoofing, não autorização suficiente para vincular usuário ou pedido;
- `Reply-To` com token opaco, escopo de tenant/ticket/thread e destinatário, expiração curta e hash em repouso; rotacionar após uso, mudança de participante ou incidente e invalidar tokens anteriores;
- HTML sanitizado e imagens remotas bloqueadas;
- anexos em quarentena, MIME real, limite e antivírus;
- SPF, DKIM e DMARC;
- bounce/complaint e lista de supressão;
- remover histórico citado, assinatura e cabeçalhos encaminhados antes de publicar a resposta no ticket; mensagem encaminhada pode vaziar cadeia completa, anexos, e-mails, tokens e dados de terceiros;
- detectar e redigir segredos/PII em assunto, corpo, histórico e nome de anexo; URL de ação autenticada nunca é reenviada na citação;
- resposta vinda de endereço diferente, encaminhamento, alias desconhecido ou token expirado entra em quarentena/revisão, sem revelar se pedido, usuário ou ticket existe;
- nota interna separada da resposta;
- ticket pode vincular pedido, anúncio, disputa e usuário;
- SLA, fila, responsável e escalonamento;
- segredo nunca em assunto/notificação/e-mail.

15. Classificação de dados

```
PUBLIC
INTERNAL
CONFIDENTIAL
RESTRICTED_PII
SECRET_AUTH
SECRET_DELIVERY
FINANCIAL
```

Cada schema/evento define classificação. Logs são allowlist por campo, não redaction improvisada. A [OWASP Logging Cheat Sheet](#) orienta excluir token, senha, chave e PII sensível.

16. Controles de aplicação e infraestrutura

- TLS, HSTS e CSP estrita.
- Output encoding e sanitização.
- BOLA/BFLA testados em toda API, conforme [OWASP API Security](#).
- Queries parametrizadas.
- Rate limit por conta, dispositivo, IP e fluxo.
- Banco/cache/broker em rede privada.
- Workload identity e egress allowlist.
- Field-level encryption para TOTP, contato, PII crítica e cofre.
- Secrets Manager; nada no repositório.
- Upload por URL assinada, re-encode e remoção de EXIF.
- SBOM, lockfile, SAST, SCA, secret scan, DAST e artefato assinado.
- Branch protegida e dupla revisão em auth/finance.
- Baseline [OWASP ASVS](#).
- Telemetria vendor-neutral com [OpenTelemetry](#).

17. Threat model priorizado

P	Ameaça	Controle	Teste obrigatório
P0	webhook forjado/replay credita saldo	assinatura raw, janela, inbox única, consulta canônica, ledger	100 repetições = um efeito
P0	corrida vende item duas vezes	lock + índice/reserva única	100 checkouts = um vencedor

P	Ameaça	Controle	Teste obrigatório
P0	saque duplicado	lotes bloqueados + idempotência PSP	retries/timeouts sem duplicar
P0	IDOR/BOLA	ownership + PDP central	buyer/seller/admin/estranho
P0	abuso administrativo	SoD, step-up, deny e audit	autor não aprova própria ação
P0	vazamento de credencial	Vault/KMS/no-store/redaction	segredo ausente de todos os sinks
P1	account takeover	passkey, MFA, device risk	mudança crítica exige step-up
P1	XSS em listing/chat/e-mail	texto seguro, sanitização, CSP	corpus de payloads
P1	evasão PII	Unicode/confusables/regras+modelo	corpus adversarial pt-BR
P1	preço manipulado	provenance/outlier/quarantine	pico não vira current quote
P1	SSRF por mídia/URL	sem fetch arbitrário, allowlist	metadados/IP privado inacessíveis
P1	provedor comprometido	schema/limite/estado monotônico	payload inesperado não muda dinheiro
P1	DDoS/bot	WAF, quota, backpressure	carga não derruba checkout
P2	gaming de ranking	dedupe, confiança, circularidade	autoclique não muda exposição

18. Auditoria

Campos:

```
eventId, occurredAt, actorType/id, actingRole,
sessionIdHash, action, resourceType/id,
authorizationDecisionId, policyVersion,
beforeRedacted, afterRedacted, reasonCode,
requestId, correlationId, ipPrefix, userAgentFamily,
dataClassification
```

- append-only por role de banco;
- storage WORM periódico;
- lote assinado/Merkle root como reforço;
- nasce na mesma transação da ação;
- segredo e conteúdo integral nunca entram;
- exportação é autorizada, redigida, expira e fica auditada.

19. Retenção baseline

Valores abaixo são desenho inicial sujeito a DPO/jurídico/contabilidade/contratos:

Dado	Baseline
Registro de acesso à aplicação	6 meses, conforme Marco Civil art. 15, em ambiente segregado
Sessão operacional	timeout + histórico de segurança até 90 dias
Sinais brutos de dispositivo/IP	30 dias, minimizados
Perfil derivado de risco	180 dias após última necessidade
Eventos de recomendação	180 dias; agregados 12 meses se necessários
PII bloqueada	plaintext somente se indispensável, cofre até 30 dias; razão pelo prazo de recurso
Chat pré-compra	6–12 meses após encerramento, validar finalidade
Chat/evidência de disputa	janela contratual/legal e legal hold
Segredo de entrega	crypto-shred após conclusão + disputa, teto sugerido 30 dias
Ticket/e-mail	24 meses após fechamento, salvo obrigação/legal hold
Observação de preço	13 meses bruto; candle conforme licença
Ledger do saldo de vendas administrado pelo PSP/pedido/audit financeiro	prazo fiscal/contratual definido por especialista
Documento de idade	eliminação imediata após extrair o sinal necessário
Registro de incidente relevante	ao menos 5 anos, conforme orientação ANPD
Backup operacional	35 dias; mensal até 12 meses conforme política

Exclusão de conta anonimiza o dispensável e preserva somente o que possui obrigação/finalidade válida.

20. Incidente e continuidade

A **ANPD orienta** comunicar incidentes com risco ou dano relevante à Agência e aos titulares em três dias úteis e manter registros por pelo menos cinco anos.

Runbook de incidente

1. Detectar e classificar.
2. Preservar evidência sem espalhar PII.
3. Conter sessão, chave, integração ou módulo.
4. Acionar jurídico/DPO/direção/PSP.
5. Avaliar risco/dano e população.

6. Comunicar nos prazos aplicáveis.
7. Corrigir, rotacionar e restaurar.
8. Monitorar fraude/chargeback.
9. Fazer postmortem sem culpa, com owner/prazo.

Fornecedor crítico precisa de SLA de notificação inferior ao prazo regulatório.

DR

- PITR e WAL contínuo;
- backup diário criptografado e imutável;
- conta/região separada;
- restore mensal;
- simulado trimestral;
- RPO financeiro ≤ 5 min, RTO ≤ 60 min;
- cofre/KMS e runbooks incluídos no teste.

21. Operações diárias

Filas

- anúncios por risco/idade;
- PII/recurso;
- disputa/evidência;
- divergência PSP/ledger;
- hold vencido;
- payout falho/retornado;
- ticket fora de SLA;
- feed stale/lacuna;
- asset sem licença/proveniência;
- dispositivo/ATO.

Kill switches

Separados para:

- novos anúncios;
- publicação;
- checkout;
- revelação de segredo;
- payout;
- ingestão de preço;
- e-mail outbound;
- recomendação.

Pausar um módulo não deve apagar fila nem corromper pedido.

Runbooks obrigatórios

1. Webhook atrasado/duplicado/fora de ordem.
2. Divergência de settlement.
3. Reserva presa.
4. Vendedor/comprador não confirma.
5. Disputa e evidência.
6. Chargeback após payout.
7. Segredo revelado indevidamente.
8. ATO/Master perdido.
9. PII falso positivo/recurso.
10. Feed manipulado/stale.
11. Asset retirado por direito autoral.
12. E-mail spoof/bounce/complaint.
13. Incidente LGPD.
14. Restore e continuidade.

22. RACI de governança

Legenda: **A** aprova e responde pelo gate; **R** executa; **C** é consultado antes da decisão; **I** é informado. Toda linha precisa de evidência anexada ao gate e suplente nomeado; uma pessoa pode acumular papéis no início, mas a segregação de funções financeira e administrativa continua obrigatória.

Domínio/gat e	Direção	Jurídico	DPO/Privaci dade	Fiscal/Contá bil	Risk/Fraude	Segurança	Produto/Ops	FinOps
LIC/DATA/AS SET e NO-GO por jogo	A	R	C	I	C	C	C	I
Direitos LGPD, DPA, subprocessad ores, transferência s e cookies	I	C	A	I	C	R	R	I
Age assurance e responsável legal	I	C	A	I	R	C	R	I
PSP, split, saldo de vendas administrado pelo PSP, hold e payout	I	C	C	C	R	C	C	A/R
Comissão, escrituração, conciliação e documento fiscal	I	C	C	A/R	C	I	R	R
Antifraude, chargeback, strikes e revisão	I	C	C	I	A/R	C	R	R
Segurança, e-mail inbound, vulnerabilida de e incidente	I	C	C	I	C	A/R	R	C
Oferta, suporte, moderação e direitos do consumidor	I	A	C	I	R	C	R	C

O go-live exige aceite nominal dos **A**, ausência de conflito não mitigado e registro de pendências com prazo. DPO/encarregado mantém o canal de titulares; Fiscal/Contábil fecha classificação e documentos; Risk/Fraude define apetite, métricas, exceções e revisão humana.

23. Checklist de lançamento

- ☐ Axlebolt autorizou formalmente comércio, transferência, API, dados e assets.
- ☐ Tipos proibidos, sobretudo contas, permanecem desabilitados.
- ☐ PSP contratado e autorizado, com fluxo de fundos diagramado e UX usando “saldo de vendas administrado pelo PSP”.

- ☐ Termos, privacidade, oferta, arrependimento, disputa e suporte aprovados.
- ☐ Age assurance/ECA Digital, vínculo do responsável, revalidação e contestação implementados conforme análise.
- ☐ Privacy Center cobre acesso, correção, exportação, eliminação, oposição, revogação e revisão automatizada.
- ☐ Data inventory, bases, LIA/RIPD, retenção, controlador/operador, DPAs, subprocessadores e transferências internacionais aprovados.
- ☐ Cookies/analytics inventariados; consentimento e opt-out propagam-se a cliente, servidor e fornecedores.
- ☐ Escopo PCI, fluxo de cartão, SAQ/atestação e responsabilidades com PSP/adquirente confirmados.
- ☐ Comissão, plano de contas, documento fiscal, conciliação e obrigações dos vendedores aprovados por Fiscal/Contábil.
- ☐ Passkey/MFA, IAM, step-up, SoD e audit ativos.
- ☐ Webhook, ledger, conciliação, hold e payout passam testes P0.
- ☐ Vault não vaza segredo.
- ☐ Detector PII tem recurso e revisão humana.
- ☐ E-mail inbound valida assinatura/remetente, expiração/rotação de token, anti-replay, histórico encaminhado e anexos seguros; SPF/DKIM/DMARC ativos.
- ☐ ASVS, pentest, SAST/SCA/DAST e SBOM concluídos.
- ☐ Restore e incidente simulados.
- ☐ RACI aceito por DPO/Privacidade, Fiscal/Contábil, Risk/Fraude e demais owners; suplentes, runbooks e SLAs treinados.
- ☐ Piloto limitado sem divergência crítica.
- ☐ Go-live e rollback aprovados por todos os owners.

BACKLOG E ROADMAP

— MIDAS

MARKETPLACE

1. Regra do roadmap

Este roadmap é orientado por **gates de evidência**, não por datas inventadas. Prazo só pode ser estimado depois de equipe, PSP, fonte de dados, direitos e decisões jurídicas estarem fechados.

Escala: **S** pequeno, **M** médio, **L** grande, **XL** programa/risco elevado. Tamanho não é duração.

2. Gates

Gate	Pergunta	Evidência de saída	Estado inicial
G0 — Direito de operar	O marketplace e os ativos têm autorização?	autorização escrita da Axlebolt, escopo territorial/comercial, transferência, API e licença	BLOQUEADO / NO-GO
G1 — Dados de mercado	Existe feed permitido?	documentação, contrato, IDs, rate limits e licença de exibição	BLOQUEADO
G2 — Pagamentos	Existe PSP compatível?	desenho de split/subconta, hold/payout, KYC, refund e chargeback	pendente
G3 — Políticas	Regras de disputa, strike, taxa e seller estão fechadas?	políticas aprovadas e versionadas	pendente
G4 — Domínio	Estados, invariantes, APIs e RBAC estão coerentes?	matriz rastreável + revisão sem transição órfã, incluindo liquidação tardia	em correção/revisão
G5 — Segurança	Ameaças P0 têm controle e teste?	threat model, ASVS, pentest e DR	pendente
G6 — Operação	Staff consegue operar exceções?	runbooks, filas, SLAs, treinamento e piloto	pendente
G7 — Piloto	Fluxo real fecha sem divergência?	piloto limitado, reconciliação e métricas	pendente
G8 — Lançamento	Produto, jurídico, finanças e segurança aprovam?	sign-off e plano de rollback	pendente

Nenhum desenvolvimento comercial de integração ou ingestão de assets deve ultrapassar G0/G1 sem decisão formal.

Base do bloqueio: **Regras oficiais do jogo**, **EULA** e **Code of Conduct**. A autorização precisa ser expressa; silêncio, endpoint acessível ou site de terceiro não satisfazem G0.

3. Dependência principal



4. Épicos

E0 — Autorizações, contratos e políticas · XL

Resultado: o produto sabe o que pode vender, exibir e integrar.

- obter autorização escrita da Axlebolt para comércio por dinheiro real, intermediação, dados, API, transferência e assets;
- retirar contas do escopo Standoff 2; para outro jogo, exigir matriz de transferibilidade por publisher;
- contratar/licenciar catálogo e preço;
- escolher modelo do PSP;
- definir moeda, fee, limite, chargeback, saldo negativo e KYC;
- definir idade, seller onboarding, disputa, evidência e SLA;
- definir strike, retenção, direitos LGPD e atendimento;
- produzir termos, privacidade e contratos operacionais próprios.

Aceite: G0–G3 aprovados, com owner e versão.

E1 — Fundação de plataforma · XL

Resultado: base transacional, auditável e observável.

- repositório, ambientes e CI/CD;
- PostgreSQL, migrações e schemas por contexto;

- outbox/inbox, broker e DLQ;
- IDs, timestamps, dinheiro e convenções de erro;
- configuração tipada/versionada e feature flags;
- audit writer append-only;
- OpenTelemetry, logs redigidos e alertas básicos;
- backup, PITR e primeiro teste de restore.

Aceite: evento duplicado é idempotente; audit event nasce junto da ação; restore demonstrado.

E2 — Identidade, IAM e sessões · L

- cadastro, login e verificação de e-mail;
- senha Argon2id, passkey/WebAuthn, TOTP e recovery codes;
- sessões opacas em cookie seguro e CSRF;
- roles, grants, escopo, expiração e deny;
- step-up, revogação remota e break-glass;
- origem admin isolada e sessão curta.

Aceite: matriz BOLA/BFLA passa; staff não entra sem fator forte; privilege change é auditado.

E3 — Device Trust e risco v1 · L

- enrollment options e challenge;
- vínculo por chave pública;
- lista/revogação de dispositivo;
- sinais minimizados e score interno;
- decisões **ALLOW** , **CHALLENGE** , **REVIEW** , **DENY** ;
- cooling-off após recuperação, MFA ou destino de saque.

Aceite: fingerprint isolado nunca autentica; revogação invalida sessões; ação crítica exige assertion.

E4 — Catálogo, taxonomia e mídia · XL

- itens, versões, tipos, coleções, raridades e atributos;
- stickers e compatibilidade;
- assets com proveniência/licença/hash;
- upload direto, quarentena, MIME, antivírus, re-encode e EXIF;

- importação dry-run/diff;
- desativação sem quebrar histórico;
- fila de aprovação de asset.

Aceite: nenhum asset sem estado **APPROVED** aparece; importação pode ser revertida logicamente.

E5 — Anúncio, craft e moderação · XL

- wizard/rascunho/prévia;
- seleção exclusiva do catálogo;
- **NONE** versus **CRAFT** ;
- quatro posições ordenadas;
- preço, descrição, entrega e WhatsApp pós-pago;
- revisions imutáveis;
- fila, claim, checklist, aprovação, ajuste e rejeição;
- segregação de criador/aprovador.

Aceite: alterações materiais não sobrescrevem versão; craft inválido nunca é submetido; P2P não publica sozinho.

E6 — Market, Midas, busca e descoberta · XL

- catálogo público e detalhes;
- canal P2P e canal Midas;
- filtros, sort, favoritos e recentemente vistos;
- perfil/reputação pública;
- índice derivado e tombstone;
- validação canônica de disponibilidade;
- estados vazio/stale/indisponível.

Aceite: item vendido some dentro do SLO de projeção; Midas nunca se disfarça de P2P.

E7 — Pricing e gráfico · XL / dependente de G1

- adapter contract;
- mapeamento de instrumento;
- observação, cotação e candle;
- schema, dedupe, outlier e freshness;

- períodos e agregações;
- skin + quatro stickers;
- `as0f`, fonte, stale e fallback manual;
- alertas de feed.

Aceite: ausência não vira zero; origem está visível; endpoint não autorizado não existe na configuração.

E8 — Chat, proposta e anti-PII · XL

- WebSocket/reconexão/sequência;
- salas pré-compra, entrega e suporte;
- proposta/contraproposta com expiração;
- NFKC, zero-width, confusables, padrões e classificador;
- alta/média/baixa confiança;
- strikes, restrição e recurso;
- rate limit, spam e denúncia;
- evidência criptografada e redigida.

Aceite: bloqueada não chega; duplicada não duplica; corpus adversarial passa; falso positivo é recorrível.

E9 — Reserva, pedido e checkout · XL / dependente de G2

- reserva única com TTL;
- pedido com snapshot;
- Idempotency-Key;
- hosted checkout/tokenização;
- webhook raw body, assinatura, inbox e status canônico;
- retries e eventos fora de ordem;
- cancelamento/expiração/retorno à venda.

Aceite: 100 compradores simultâneos geram um vencedor; redirect não confirma pagamento; 100 webhooks geram um efeito.

E10 — Ledger, conciliação e PSP · XL

- plano de contas;
- journal/posting balanceado;

- clearing, protegido, held, available e payout in transit;
- refund, dispute reserve e chargeback debt;
- conciliação realtime/intradiária/diária;
- divergência e caso operacional;
- dashboard financeiro.

Aceite: nenhum lançamento desbalanceia; correção é reversão; settlement report reconcilia.

E11 — Entrega segura, disputa e reputação · XL

- sala pós-pagamento;
- Secure Delivery Vault com envelope encryption;
- reveal auditado/no-store/expiração;
- WhatsApp/Instagram pós-pago por deep link permitido;
- confirmações independentes;
- disputa, evidência, decisão e recurso;
- avaliação somente pós-conclusão.

Aceite: segredo não aparece em log/e-mail/busca/suporte genérico; disputa congela o lote.

E12 — Hold, saldo de vendas e saque · XL

- balance lots e `eligibleAt`;
- scheduler idempotente;
- freeze e unfreeze;
- saldo administrado pelo PSP, extrato espelho e previsão;
- solicitação, risco, maker-checker e payout;
- falha, retorno e chargeback posterior.

Aceite: 168h só libera quando todos os gates passam; saque nunca usa saldo em hold; retry não duplica payout.

E13 — Tickets, caixa de e-mail e notificações · L

- ticket, categoria, SLA, fila e ownership;
- inbound/outbound e threading;

- sanitização, imagem remota bloqueada e anexo em quarentena;
- SPF, DKIM, DMARC, bounce e complaint;
- macros, nota interna e escalonamento;
- notificações internas/transacionais.

Aceite: e-mail vira a thread correta; segredo não é enviado; bounce é recuperável.

E14 — Master e operação · XL

- home de filas/alertas;
- IAM e grants;
- catálogo, moderação, confiança, pedido, disputa, suporte e financeiro;
- configuração com preview/diff/rollback lógico;
- kill switches por módulo;
- audit explorer e exportação governada;
- maker-checker e conflitos.

Aceite: Master não altera ledger/audit; cada ação sensível mostra impacto e exige step-up.

E15 — Recomendação explicável · L

- taxonomia de eventos mínima;
- afinidades por conteúdo/preço;
- candidatos e regras de ranking;
- diversidade, dedupe e seller fairness;
- impressão/posição;
- “por que estou vendo”; opt-out e limpeza.

Aceite: perfil desligado para de receber eventos individualizados; itens indisponíveis não entram; CTR não é métrica única.

E16 — Qualidade, segurança e lançamento · XL

- testes unitários, contrato, integração, E2E e concorrência;
- SAST, SCA, secret scan, DAST, SBOM e imagem assinada;
- revisão ASVS, BOLA/BFLA e pentest;
- carga/soak/chaos controlado;

- DR, rotação de segredo e incidente simulado;
- acessibilidade, responsividade e conteúdo;
- runbooks, treinamento, piloto e rollback.

Aceite: G5–G8 aprovados.

5. Releases recomendadas

Release 0 — Provas, protótipos e contratos

Sem transação real. Entregas:

- design system e protótipos de jornada;
- modelo de domínio validado;
- sandbox PSP;
- prova de feed licenciado;
- catálogo somente com ativos autorizados;
- threat model e políticas.

Release 1 — Piloto fechado

- poucos vendedores aprovados;
- um método de pagamento;
- limites de valor/volume;
- moderação 100% manual;
- recomendação por regra;
- saque com revisão manual e dupla aprovação;
- observação intensiva e suporte humano.

Release 2 — MVP público controlado

- P2P + Midas;
- catálogo, craft, preço e gráfico autorizados;
- chat/proposta/anti-PII;
- pagamento, entrega, disputa, hold e saque;

- Master/ADM, tickets, e-mail e auditoria;
- device trust v1.

Release 3 — Eficiência operacional

- importação robusta;
- risco/reconciliação avançados;
- automação assistida de moderação;
- recommendation experiments;
- seller health e capacity planning.

Release 4 — Expansão condicionada

- contas somente em jogos cujos termos e autorização escrita permitam transferência;
- mais PSPs/moedas/regiões;
- alertas/portfólio/PWA;
- promoções rotuladas e programa de fidelidade.

6. Priorização do MVP

Must

- direitos e PSP aprovados;
- identidade/fator forte/IAM/audit;
- catálogo/asset provenance;
- anúncio/craft/revisão;
- P2P/Midas/busca;
- preço com frescor ou fallback explicitamente manual;
- chat/proposta/anti-PII/recurso;
- reserva/pedido/webhook/ledger;
- entrega/cofre/confirmações/disputa;
- hold/saldo de vendas/saque;
- tickets/inbox;
- operação/observabilidade/backup.

Should

- favoritos, vistos recentemente e alertas;
- recomendação explicável;
- seller reputation rica;
- importação em lote avançada;
- anexos moderados na entrega.

Could

- múltiplos PSPs;
- push/PWA avançada;
- alertas de preço;
- ML colaborativo;
- automação de moderação com decisão humana final.

Won't now

- conta sem autorização;
- carrinho multivendedor;
- crypto, crédito ou custódia própria;
- endpoint privado de mercado;
- asset sem licença;
- marketplace internacional antes de política por território.

7. Definition of Ready

Uma história entra em desenvolvimento quando:

- tem ator, problema e resultado;
- requisito/estado afetado está identificado;
- critérios de aceite e erros existem;
- dependências e classificação de dados estão definidas;
- autorização e feature flag estão claras;
- UX desktop/mobile e acessibilidade estão especificadas;
- evento, auditoria e métricas foram decididos;

- threat case foi avaliado;
- nenhuma questão G0–G3 está sendo assumida como resolvida.

8. Definition of Done

- aceite funcional automatizado ou demonstrado;
- autorização por objeto/campo testada;
- idempotência e concorrência testadas quando aplicável;
- logs redigidos, telemetria e alertas;
- migração reversível ou forward-fix ensaiado;
- acessibilidade e viewports obrigatórios revisados;
- documentação/API/eventos atualizados;
- runbook e rollback;
- revisão independente para auth, financeiro e segredo;
- nenhum P0/P1 aberto sem aceite formal.

9. Estratégia de testes

Camada	Cobertura principal
Unitário	invariantes, regras, detector, ranking, cálculo de hold
Property-based	ledger balanceado, transições válidas, money/gold
Contrato	PSP, feed, e-mail, eventos e OpenAPI
Integração	Postgres/outbox/inbox, KMS, storage e busca
Concorrência	reserva, webhook, confirmação, release e saque
E2E	anunciar→aprovar→negociar→pagar→entregar→liberar→sacar
Segurança	BOLA/BFLA, CSRF, XSS, SSRF, replay, upload e segredo
Adversarial	PII ofuscada, spam, seller gaming e preço anômalo
Acessibilidade	teclado, leitor, foco, contraste, zoom e reduced motion
Resiliência	timeout, provedor fora, evento fora de ordem, DLQ e restore
Operação	runbook de disputa, divergência, banimento e incidente

10. Casos de teste P0

1. Cem webhooks iguais geram um lançamento.
2. Cem compras simultâneas geram uma reserva/pedido vencedor.

3. Mesmo saque com timeout não paga duas vezes.
4. Estranho não lê pedido, sala ou ticket alheio.
5. Staff não concede permissão que não possui.
6. Proponente não aprova a própria ação financeira.
7. Segredo não aparece em logs, e-mail, busca, analytics ou backup de suporte.
8. Mensagem PII ofuscada é normalizada antes da decisão.
9. Pico anômalo não vira cotação atual sem quality gate.
10. Feed e e-mail fora não corrompem pedido.
11. Restore reproduz pedidos/ledger dentro do RPO.
12. Kill switch pausa apenas o módulo afetado.
13. Webhook liquidado após TTL/cancelamento entra em quarentena e nunca abre entrega para unidade já liberada.
14. Liquidação tardia só reassume a unidade com compare-and-set válido; caso contrário, produz reembolso idempotente.
15. Saque **FAILED** ou **RETURNED** reconcilia, reverte o trânsito e oferece revisão/retry sem duplicar pagamento.

11. RACI mínimo

Decisão	Accountable	Responsible	Consulted
Direito de operar/ativos	Direção Midas	Jurídico/licenciamento	Produto, publicador
PSP/modelo financeiro	Direção/Financeiro	Financeiro + Engenharia	Jurídico, contador, PSP
Política de disputa	Operações	Trust & Safety	Jurídico, suporte, financeiro
Catálogo/preço	Produto	Catálogo/Pricing	Licenciante, engenharia
IAM e segurança	Segurança	Engenharia	Master, privacidade
Privacidade e direitos	DPO/Encarregado	Privacidade + Produto	Segurança, Jurídico, Suporte
Fiscal, comissão e documentos	Direção/Financeiro	Fiscal/Contábil	Jurídico, PSP, Produto
Fraude e modelos de risco	Operações	Risk/Fraud + Trust & Safety	DPO, Segurança, Suporte
Design e conteúdo	Produto	Design	Suporte, acessibilidade
Go-live	Direção	Release manager	todos os owners de gate

12. Próxima ação autorizada

Enquanto G0/G1 estão bloqueados, a equipe pode avançar apenas em trabalho reversível e não comercial: protótipos clean-room, modelagem, documentação, provas em sandbox com dados sintéticos e negociação de fornecedores. Ingestão de PNGs, integração de endpoints não oficiais e lançamento real permanecem fora de escopo.

INVENTÁRIO DE REFERÊNCIAS E ATIVOS

1. Finalidade e limite

Este documento registra o que foi observado nas referências e o que pode orientar produto, UX e arquitetura. Ele **não concede licença** e não autoriza copiar marca, textos, CSS, imagens ou base de dados.

Data da coleta: 21 de agosto de 2026.

2. Neshastore — mapa funcional observado

Referência: <https://neshastore.com/>

O sitemap público retornou 33.266 URLs, majoritariamente páginas de item. As superfícies relevantes auditadas foram:

Superfície	Padrões observados	Aplicação no Midas
Início	banner promocional, categorias, ordenação, catálogo denso	busca, categorias e recomendação; sem promoção inventada
Produto	imagem dominante, preço, desconto, float, disponibilidade, CTA	anúncio com preço, craft, vendedor, gráfico e proteção
Carrinho	resumo, cupom, checkout e condição	pedido unitário no MVP; sem carrinho multivendedor
Login/conta	Steam e e-mail; pedidos/inventário	identidade própria, passkey/2FA, compras/vendas
Prime	vitrine premium separada	inspiração estrutural para “Compre do Midas”
Venda	cotação/fluxo em etapas	wizard de anúncio, mas com moderação e P2P real
FAQ	compra, entrega, pagamento e suporte	educação contextual e central de ajuda
Privacidade/termos	integrações e regras operacionais	apenas benchmark; documentos Midas serão próprios
Antiscam	educação sobre golpe e conta	central de confiança integrada às jornadas

Padrões visuais observados

- base quase preta e superfícies azul-carvão;
- acento ciano/teal e sinal amarelo;
- catálogo em cards compactos;
- tipografia condensada em títulos e sans em UI;
- preço, disponibilidade, estado e CTA próximos;
- banners, popup, cookie, prêmio e chat concorrendo por atenção.

Diagnóstico

Manter: densidade, leitura comercial, categorização, detalhe de produto, explicação de confiança.

Transformar: reduzir ruído, separar referência em gold do preço monetário da oferta, distinguir P2P/Midas, tornar estados operacionais explícitos.

Recusar: clone pixel a pixel, ativos, textos, escassez e métricas não verificadas.

3. Standoff 2 Shop — mapa funcional observado

Referência: <https://standoff-2.com/shop/>

Aviso de autoridade

O site informa em seu próprio cabeçalho/rodapé que é **não oficial**. Portanto:

- não representa necessariamente o publicador do jogo;
- nenhum endpoint é classificado como “API oficial”;
- disponibilidade pública não significa permissão de reuso;
- integração de produção depende de documentação/licença separada.

Além disso, as **Regras oficiais do Standoff 2**, atualizadas em 03/07/2026, proíbem comércio externo por dinheiro real e parsers/clientes de API não oficiais, salvo autorização expressa. A **EULA oficial** reserva os direitos sobre artwork, conteúdo e bens virtuais, e a **licença do Asset Kit** não foi confirmada para uso comercial do marketplace.

Interface observada

- seletor com 2.256 nomes;
- filtros por tipo, raridade, categoria e coleção;
- dados descritivos do item;

- preço atual, mínimo, máximo e médio em gold;
- alternância compra/venda;
- períodos 1 hora, 1 dia, 1 mês, 6 meses, ano e todo histórico;
- gráfico Plotly com overview inferior;
- tabela com preço, variações, spread e volatilidade.

Endpoints observados no JavaScript público

Endpoint	Uso observado	Status para Midas
<code>/skins-new.php?command=getNames</code>	lista de nomes	somente evidência de benchmark
<code>/skins-new.php?command=getModelInfo</code>	metadados e URL de imagem	somente pesquisa interna; licença pendente
<code>/skins-new.php?command=getStat&name=...</code>	série de compra	proibido integrar sem permissão/documentação
<code>/skins-new.php?command=getStatSale&name=...</code>	série de venda	proibido integrar sem permissão/documentação

As rotas de estatística retornaram `403` fora do contexto esperado durante a verificação. Esse comportamento reforça que não existe contrato público confiável para o Midas assumir.

4. Manifesto dos PNGs observados

Resultado do snapshot de `getModelInfo` :

Medida	Quantidade
Registros	1.782
Nomes únicos	1.777
URLs de imagem	1.782
URLs únicas	1.779
Extensão <code>.png</code>	1.782
Coleções preenchidas	49
Imagens ausentes	0

Tipos observados incluem armas, adesivos, facas, luvas, chaveiros, grafites e contêineres.

Qualidade e cobertura do manifesto

O manifesto é uma fotografia de uma fonte não oficial, sem contrato de esquema, garantia de completude ou identificador canônico. A lista de nomes e o snapshot de metadados não fecham entre si:

Verificação	Resultado observado	Consequência
Lista de nomes vs. metadados	2.256 nomes no seletor e 1.782 registros em <code>getModelInfo</code>	diferença bruta de 474; não pode ser interpretada automaticamente como 474 itens ausentes, porque há duplicidade e normalização desconhecida
Completude de campos	<code>type</code> : 512 vazios; <code>subtype</code> : 783; <code>rarity</code> : 784; <code>category</code> : 1.778	filtros, validação de craft e taxonomia ficariam incompletos
Duplicatas exatas	2 linhas exatamente duplicadas	contagem, importação e deduplicação por linha não são confiáveis
Colisões de nome	1.782 registros, mas 1.777 nomes únicos	nome não serve como chave primária; o mesmo rótulo pode representar linhas diferentes
Colisões de URL	1.782 URLs, mas 1.779 URLs únicas	URL de imagem não identifica item e pode ser compartilhada/repetida
Colisões de raridade	foram observados nomes/linhas com classificações de raridade conflitantes ou ambíguas	não escolher uma raridade “vencedora” sem fonte autoritativa e regra de reconciliação
Identificador estável	nenhum ID oficial, imutável e documentado foi fornecido	impossível garantir upsert, histórico, referência de preço ou migração segura

Essas anomalias não devem ser “corrigidas” por inferência silenciosa. Uma futura fonte autorizada deverá fornecer ID estável, versão/esquema, constraints, relação entre variantes, política de tombstone/merge e mecanismo de correção. Até lá, qualquer comparação serve apenas para auditoria da pesquisa.

Política de extração

O projeto gera um **CSV de URLs e metadados**, sem baixar ou republicar os binários. Seu status obrigatório é `PESQUISA_INTERNA_NAO_AUTORITATIVA` : ele **nunca será semente de catálogo**, migration, fixture de staging/produção, fonte de SKU, preço, craft, busca pública ou publicação de asset. Cada linha recebe:

- nome;
- tipo/subtipo;
- raridade;
- categoria/coleção;
- URL de origem;
- extensão;
- host;
- estado de direitos `PENDENTE_DE_LICenca` ;

- data de observação.

Download, transformação, ingestão no catálogo e publicação ficam bloqueados até existir autorização comercial escrita da Axlebolt e uma fonte autoritativa com ID estável. O **Asset Kit oficial** não substitui essa autorização; suas permissões precisam ser lidas no contexto da licença incluída. Quando autorizados, o pipeline deverá registrar hash SHA-256, autor/origem, licença, data, dimensões, revisão e derivados. A autorização futura não transforma retroativamente este CSV em fonte confiável: o catálogo deve nascer de nova ingestão autorizada e validada.

5. Contrato necessário para uma fonte de preço

O adaptador Midas só aceita uma fonte que ofereça:

1. documentação pública ou contrato;
2. direito de armazenar e exibir preço/histórico;
3. identificação estável de item;
4. limites e política de cache;
5. timestamp de observação;
6. semântica de compra/venda e moeda gold;
7. política de correção e indisponibilidade;
8. SLA ou expectativa de cadência;
9. termos de atribuição;
10. canal de suporte e mudança de versão.

Sem isso, o produto opera com importação administrativa identificada como manual, nunca como “tempo real”.

6. Modelo de proveniência de ativo

```
CatalogAsset
  id
  catalogItemId
  sourceType = OFFICIAL | LICENSED | USER_SUPPLIED | INTERNAL
  sourceUrl
  licenseId
  authorizationEvidence
  author
  observedAt
  importedAt
  sha256
  mimeType
  width / height
  status = QUARANTINED | APPROVED | BLOCKED | EXPIRED
  parentAssetId
  transformationRecipe
```

Nenhum ativo em **QUARANTINED** , **BLOCKED** ou **EXPIRED** pode aparecer no catálogo público.

7. Registro clean-room

Elemento da referência	Regra abstrata aprendida	Reexpressão Midas
Catálogo escuro e denso	comparação rápida pede alta densidade	charcoal aquecido, grid adaptativo e menos ruído
Categoria perto do catálogo	reduzir custo de navegação	busca dominante + filtros persistentes
Preço/estado no card	decisão antes do clique	oferta real + gold separado + asOf
Página de detalhe em duas zonas	imagem e decisão simultâneas	mídia/craft à esquerda, transação à direita
Gráfico e métricas	preço precisa de contexto temporal	série licenciada + frescor + modo degradado
Vitrine premium separada	origem da oferta importa	canal “Compre do Midas” inequivocamente rotulado

8. Conclusão do inventário

Há material suficiente para definir taxonomia, experiências, componentes e contrato de integração. Há, porém, evidência oficial de que a operação é proibida sem permissão expressa. Os PNGs, endpoints e o CSV observados **não podem** ser tratados como base, semente ou fallback de produção. O estado permanece **NO-GO**. O próximo passo externo obrigatório é obter autorização escrita da Axlebolt e fonte autoritativa com ID estável; até lá, usar apenas dados sintéticos e arte própria.

A INTERFACE VENDE. OS ESTADOS SUSTENTAM A VENDA.